

Daily Vulnerability Report - 2026-09-15

Window (UTC): 2026-09-14T11:18 to 2026-09-15T11:18 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-15 11:20:29 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
1877	3	195	602	592	182	306	620

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85706	10.0	CRIT	Yes	0.111	gitlab:gitlab	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-65400	9.8	CRIT	Yes	0.099	apple:macos	An authentication issue was addressed with improved state management. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.7.9, macOS Sonoma 14.8.9, macOS Tahoe 26.6.1, macOS Tahoe 26.7. An attacker on the network may be able to authenticate to Screen Sharing without valid credentials.
CVE-2026-76461	9.8	CRIT	Yes		cisco:secure email gateway	A vulnerability in the email parsing of Cisco AsyncOS Software for Cisco Secure Email Gateway could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system. This vulnerability is due to insufficient validation in the email parsing logic. An attacker could exploit this vulnerability by sending a crafted email message that contains malicious ...

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-25470	10.0	CRIT		0.004		Unauthenticated Remote Code Execution (RCE) in ACPT (Pro) - Custom Post Types Plugin for WordPress <= 2.0.47 versions.
CVE-2026-28659	10.0	CRIT		0.002	google:android_xr	In MicroXR Blobstore, there is a possible way to access other app's files due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-49883	10.0	CRIT		0.002	google:android	In checkReadPermission of PermissionsManager.java, there is a possible way to monitor sensitive device state data due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-81648	10.0	CRIT		0.003		The CryptoPayment Gateway WordPress plugin from 1.2.1 to 1.2.2 does not apply an authorization check on one of its AJAX endpoints, allowing unauthenticated users to invoke administrative operations, including deleting arbitrary files on the server, overwriting the payment gateway configuration and recovering stored wallet credentials in cleartext.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82434	10.0	CRIT				Description When ZooKeeper authentication is configured, Storm deliberately retains `storm.zookeeper.topology.auth.payload` in the topology configuration, because workers need it. Nimbus then served that configuration verbatim to any caller holding read-only topology permissions, so a user whose only grant was the ability to view a topology received its ZooKeeper credential. That credential is not read-only. The...
CVE-2026-16338	9.9	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-48273	9.9	CRIT		0.019	adobe:coldfusion	ColdFusion is affected by an Improper Neutralization of Directives in Dynamically Evaluated Code ('Eval Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-57138	9.9	CRIT				PraisonAI is a multi-agent teams system. From 1.4.0 until 1.7.2, codeMode in src/praisonai-ts/src/tools/builtins/code-mode.ts executes untrusted JavaScript with new Function() inside with(sandbox) and relies on a small source-code blacklist plus shadowed process and require properties. Code can use ({}).constructor.constructor to recover the real Function constructor, obtain process and process.mainModule.require,...
CVE-2026-82845	9.9	CRIT		0.004		The Masteriyo LMS WordPress plugin before 3.4.1 does not prevent user-supplied values held as metadata from being deserialized when they are read back, allowing users with a minimal account to inject arbitrary PHP objects and, by way of a class shipped in a library bundled with the Masteriyo LMS WordPress plugin before 3.4.1, write and execute arbitrary code on the server. A weaker form of the same issue is reac...
CVE-2026-87719	9.9	CRIT		0.006		GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization and perform server object lookup.
CVE-2026-89094	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2023-54237	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: net/smc: fix potential panic dues to unprotected smc_llc_srv_add_link() There is a certain chance to trigger the following panic: PID: 5900 TASK: ffff88c1c8af4100 CPU: 1 COMMAND: "kworker/1:48" #0 [ffff9456c1cc79a0] machine_kexec at ffffffff870665b7 #1 [ffff9456c1cc79f0] __crash_kexec at ffffffff871b4c7a #2 [ffff9456c1cc7ab0] crash_kexe...
CVE-2025-40074	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: ipv4: start using dst_dev_rcu() Change icmpv4_xrlim_allow(), ip_defrag() to prevent possible UAF. Change ipmr_prepare_xmit(), ipmr_queue_fwd_xmit(), ip_mr_output(), ipv4_neigh_lookup() to use lockdep enabled dst_dev_rcu().
CVE-2026-10536	9.8	CRIT		0.009	haxx:curl	A use-after-free vulnerability exists in libcurl when an application configures an HTTP/2 stream-dependency tree via `CURLOPT_STREAM_DEPENDS` or `CURLOPT_STREAM_DEPENDS_E`, subsequently invokes `curl_easy_reset()`, and finally terminates the handle with `curl_easy_cleanup()`. During this final cleanup phase, libcurl attempts to access and modify an internal structure that was already freed during the reset operation.
CVE-2026-11856	9.8	CRIT		0.007	haxx:curl	Successfully using libcurl to do a transfer to a specific HTTP origin (`hostA`) with **Digest** authentication and then changing the origin to a different one (`hostB`) for a second transfer, reusing the same handle, makes libcurl wrongly pass on the `Authorization:` header field meant for `hostA`, to `hostB`.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19931	9.8	CRIT		0.012	haxx:curl	A flaw in libcurl makes it wrongly reuse an HTTP connection setup for a given hostname using Negotiate authentication, when the initial request is done using empty credentials. This can make user B's request get sent over user A's previously authenticated connection.
CVE-2026-20353	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20353 are related to issues with impr...
CVE-2026-28780	9.8	CRIT		0.014	apache:http_server	Heap-based Buffer Overflow vulnerability in mod_proxy_ajp of Apache HTTP Server. If mod_proxy_ajp connects to a malicious AJP server this AJP server can send a malicious AJP message back to mod_proxy_ajp and cause it to write 4 attacker controlled bytes after the end of a heap based buffer. This issue affects Apache HTTP Server: through 2.4.66. Users are recommended to upgrade to version 2.4.67, which fixes the ...
CVE-2026-38626	9.8	CRIT		0.002		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-42010	9.8	CRIT		0.011	gnu:gnutls, redhat:enterprise_linux, redhat:hardened_images, redhat:openshift_container_platform	A flaw was found in gnutls. Servers configured with RSA-PSK (Rivest–Shamir–Adleman – Pre-Shared Key) wrongfully matched usernames containing a NUL character with truncated usernames. A remote attacker could exploit this by sending a specially crafted username, leading to an authentication bypass. This vulnerability allows an attacker to gain unauthorized access by circumventing the authentication process.
CVE-2026-43198	9.8	CRIT		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: tcp: fix potential race in tcp_v6_syn_recv_sock() Code in tcp_v6_syn_recv_sock() after the call to tcp_v4_syn_recv_sock() is done too late. After tcp_v4_syn_recv_sock(), the child socket is already visible from TCP ehash table and other cpus might use it. Since newinet->pinet6 is still pointing to the listener ipv6_pinfo bad things can happen ...
CVE-2026-43748	9.8	CRIT		0.005	apple:macos	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.6 and iPadOS 26.6, macOS Sequoia 15.7.8, macOS Tahoe 26.6. An app may be able to cause unexpected system termination.
CVE-2026-52630	9.8	CRIT		0.002		SQL Injection vulnerability in Woltlab WCF v.6.2.4 and before allows a remote attacker to updateUserOptions in UserEditor.class.php and the update action in UserAction.class.php
CVE-2026-53010	9.8	CRIT		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix use-after-free in smb2_open during durable reconnect In smb2_open, the call to ksmbd_put_durable_fd(fp) drops the reference to the durable file descriptor early during the durable reconnect process. If an error occurs subsequently (eg, ksmbd_iov_pin_rsp fails) or a scavenger accesses the file, it leads to a use-after-free when accessi...
CVE-2026-53952	9.8	CRIT		0.003		GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. A logic flaw in GetSimple CMS (v3.4.0a and below) and GetSimpleCMS-CE (v3.3.22 and below) allows unauthenticated attackers to create a new administrator account. The application features an automated security control designed to delete the sensitive `admin/setup.php` file post-installation. However, this ...
CVE-2026-54333	9.8	CRIT				UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, MakeTable() in uefi_firmware/compression/Tiano/Decompress.c does not validate that bit-length values read from a crafted Tiano or EFI compressed firmware bitstream remain within the expected range from 0 through 16. The normal CompressedSection.process() to efi_compressor.TianoDecompr...
CVE-2026-54334	9.8	CRIT				UEFI Firmware Parser parses BIOS, Intel ME, and UEFI firmware structures including volumes, file systems, and files. Prior to 1.14, ReadCLen() in uefi_firmware/compression/Tiano/Decompress.c reads Number from GetBits(Sd, CBIT) with CBIT = 9 and can obtain 511 entries for the 510-element Sd->mCLen heap array because its loop does not enforce Index < NC. The CharC == 2 run-length path can additionally request up to ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55209	9.8	CRIT				resdata is software for reading and writing result files from the Eclipse reservoir simulator. Prior to 6.2.9, resdata insufficiently validates numeric fields, grid dimensions, keyword sizes, and array indexes while parsing untrusted GRDECL files in lib/resdata/rd_kw_grdecl.cpp and lib/resdata/rd_grid.cpp. Malformed COORD, ZCORN, CORNUM, ACTNUM, or MAPAXES data can reach rd_grid_alloc_GRDECL_kw__ with inconsisten...
CVE-2026-57123	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to praisonaiagents 1.6.59, ToolsMCPServer.run_sse and launch_tools_mcp_server bind to 0.0.0.0 and create /sse and /messages/ routes without invoking the available SecurityConfig authentication, origin-validation, or DNS-rebinding controls. Any reachable client can list and invoke registered tools, and a browser can target a local instance through DNS rebinding, with i...
CVE-2026-57124	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 4.6.59, the default UI host applications expose POST /api/mcp/connect without mandatory authentication and accept caller-controlled command and args values that PraisonAIUI passes to StdioMCPClient to start a local process. Because the UI commands bind to 0.0.0.0 by default, a reachable unauthenticated client can execute commands as the UI service account even when...
CVE-2026-57125	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.59 and praisonaiagents 1.6.59, the unauthenticated POST /api/v1/runs Jobs API accepts attacker-controlled agent_yaml, and the approve field can mark execute_command as YAML-approved before @require_approval checks critical tools. This chain allows a remote caller to cause a configured language model agent to invoke arbitrary operating-system commands ...
CVE-2026-57127	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 4.6.58, recipe serve installs APIKeyAuthMiddleware or JWTAuthMiddleware when an operator selects api-key or JWT authentication, but each middleware forwards requests when PRAISONAI_API_KEY or PRAISONAI_JWT_SECRET and the corresponding recipe value are absent. Unauthenticated clients can then reach recipe execution, input, and output surfaces and may trigger connect...
CVE-2026-57131	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 4.6.58, praisonai.jobs.server.create_app mounts praisonai.jobs.router.create_router under /api/v1/runs without authentication or per-job authorization. Network clients can submit attacker-controlled prompts and agent configuration, list and read jobs, stream results, and cancel or delete other jobs, exposing service credentials and connected tool capabilities to un...
CVE-2026-57139	9.8	CRIT				PraisonAI is a multi-agent teams system. From 1.5.0 until 1.7.2, MCPServer.startHttp() in src/praisonai-ts/src/mcp/server.ts binds without a host restriction and forwards every HTTP POST request to handleRequest() without authentication or authorization. Any network client that can reach the port can call tools/list, tools/call, resources/read, or prompts/get, causing registered handlers to run with server-side cr...
CVE-2026-57141	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 1.7.2, the codeMode tool in src/praisonai-ts/src/tools/builtins/code-mode.ts executes model-generated JavaScript with new Function() and with(sandbox), while a regular-expression blacklist can be bypassed with Function('return this')() to recover the global object and by constructing the child_process module name dynamically. An attacker who can influence the code ...
CVE-2026-57147	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 0.1.6, praisonai_platform/services/auth_service.py assigns the public dev-secret-change-me value to JWT_SECRET when PLATFORM_JWT_SECRET is unset, and its production guard does not run when PLATFORM_ENV is also unset because that setting defaults to dev. A remote unauthenticated attacker can mint an HS256 token with an arbitrary sub and email, and the platform's Aut...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-57148	9.8	CRIT				PraisonAI is a multi-agent teams system. Prior to 0.1.6, praisonai_platform/services/auth_service.py falls back to the public dev-secret-change-me HS256 signing key when PLATFORM_JWT_SECRET is unset, while the startup and token-issuance guards are disabled because PLATFORM_ENV also defaults to dev. An unauthenticated attacker can sign a JWT containing an attacker-chosen sub value, and AuthService._verify_token() a...
CVE-2026-59178	9.8	CRIT				ESPHome Device Builder Dashboard is a dashboard for the ESPHome home management software. Prior to version 1.0.12, the dashboard reads its authentication credentials from `!\$ESPHOME_USERNAME` and `!\$ESPHOME_PASSWORD`. Earlier versions, and the legacy `esphome` dashboard, read the bare `!\$USERNAME` and `!\$PASSWORD` instead. When the env vars were renamed the bare names were dropped with no fallback, so an operator who ...
CVE-2026-62379	9.8	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.2, the pre-authentication /authservice PLL endpoint accepts a CustomCallback XML element whose className value selects an arbitrary Java class for AuthXMLUtils to load and instantiate without verifying that it implements DSAMECallbackInterface. Default configurations expose the endpoint without authentication, allowing attacker-control...
CVE-2026-64016	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix durable reconnect error path file lifetime After a durable reconnect succeeds, ksmbd_reopen_durable_fd() republishes the same ksmbd_file into the session volatile-id table. If smb2_open() then takes a later error path, cleanup first calls ksmbd_fd_put(work, fp) and then unconditionally calls ksmbd_put_durable_fd(dh_info.fp). In this ...
CVE-2026-65414	9.8	CRIT				An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7 and iPadOS 26.7, iOS 27 and iPadOS 27, macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7, tvOS 27, visionOS 27, watchOS 27. A remote attacker may be able to cause unexpected app termination or arbitrary code execution.
CVE-2026-69463	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69525	9.8	CRIT		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an unauthorized attacker to execute code over a network.
CVE-2026-71801	9.8	CRIT		0.002		An issue was discovered in s-pms SPMS-Server through v1.0. The application contains a hardcoded default access token secret within its core configuration file, which is not overridden or removed in the production environment profile. A remote, unauthenticated attacker can locally forge valid administrative session tokens to completely bypass the authentication mechanism gaining full unauthorized access to protecte...
CVE-2026-73370	9.8	CRIT				Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks performed by Reconciliation service's pull and push, being incomplete, could accept calls by administrator not provided with adequate entitlements. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to ver...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73470	9.8	CRIT				Improper Privilege Management vulnerability in Apache Syncope. Delegations can be created or updated with Roles not owned by the delegating User, or not for the same Realm subtree under the delegation management was granted for. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1...
CVE-2026-73579	9.8	CRIT				Incorrect Authorization vulnerability in Apache Syncope. Any search requests are transformed into SQL, Neo4J or Elasticsearch / Opensearch queries, depending on the actual deployment configuration. An important component of such transformation is the Realms filter, which ensures that the search results are matching the requester's permissions. For non-recursive search requests it is possible that such Realms fi...
CVE-2026-73668	9.8	CRIT				Incorrect Authorization vulnerability in Apache Syncope. An administrator with adequate entitlements in a given Realm may be able to read via REST the full Connector configuration, confidential properties included, scoped in another Realm and thus be able to effectively duplicate such Connector instance into the Realm they have administration rights for. This issue affects Apache Syncope: from 3.0.0-M0 throu...
CVE-2026-74268	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: tcp: clear sock_ops cb flags before force-closing a child socket A child socket inherits the listener's bpf_sock_ops_cb_flags via sk_clone_lock(). If its setup fails in tcp_v4_syn_recv_sock() / tcp_v6_syn_recv_sock(), the child is freed through put_and_exit, where inet_csk_prepare_forced_close() drops the socket lock and tcp_done() runs without ...
CVE-2026-74474	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: vxlan: use pskb_network_may_pull() for transmit path header pulls In vxlan_xmit(), arp_reduce(), and vxlan_mdb_entry_skb_get(), pskb_may_pull() was being called to verify the availability of network layer headers (ARP, IPv6/ND, IP/IPv6 MDB keys). However, during transmit skb->data points to the MAC header, so skb_network_offset(skb) is ETH_HLEN...
CVE-2026-75030	9.8	CRIT				Missing Authorization vulnerability in Apache Syncope. An administrator with task execution entitlements might be able to mass (de)provision group members, regardless of their group-related administration capabilities. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which ...
CVE-2026-75171	9.8	CRIT		0.002		An issue in HubCore v.14.1.1 allows a remote attacker to escalate privileges via the HUBCOREID session cookie handling component.
CVE-2026-75429	9.8	CRIT		0.006		PowerJob versions 4.x through 5.1.2 contain an unauthenticated remote code execution vulnerability in the /friend/process endpoint of the Server-Worker transport layer
CVE-2026-75800	9.8	CRIT		0.004		The Frontegg SAML SSO WordPress plugin through 1.0.1 does not verify the signature or issuer of SAML authentication responses before establishing a session, allowing unauthenticated attackers to log in as any user, including administrators, as well as to create arbitrary accounts.
CVE-2026-76440	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76440 are related to path traversal i...
CVE-2026-76441	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76441 are related to issues with impr...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-76443	9.8	CRIT				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76443 are related to issues with impr...
CVE-2026-77051	9.8	CRIT				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized entityKey and opEvent parameters. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users a...
CVE-2026-77181	9.8	CRIT				Incorrect Authorization vulnerability in Apache Syncope. An administrator with ClientApp's update entitlement is unable to perform the related operation, while ClientApp's create entitlement is checked both for create and update operations on ClientApp. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrad...
CVE-2026-78006	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the is_safe_widget_instance function. This is due to insufficient protection in is_safe_widget_instance, which can be bypassed because PHP fires magic methods during its pre-parse, combined with enable_rendering_widget_copied() forging a valid wp_hash integrity attribute before unser...
CVE-2026-78159	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_array(). This makes it possible for unaut...
CVE-2026-78330	9.8	CRIT				Incorrect privilege assignment vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can obtain admin privileges after completing a successful authentication and obtaining a valid low-privileges JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 throu...
CVE-2026-79396	9.8	CRIT		0.002		Use of hardcoded default credentials in Xiongmai IP Camera XM530 firmware HMT.CM2005-v220608.1837 and earlier stores static account credentials in unencrypted plaintext within bin/config.xml and compiled into the Sofia executable, allowing remote attackers to gain full administrative control over the camera.
CVE-2026-79577	9.8	CRIT		0.001		An issue in the /cas/login component of sso-master v1.0.0 allows attackers to authenticate into the application without a password via sending a crafted POST request.
CVE-2026-80351	9.8	CRIT		0.004	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privileges of the operator. This issue affec...
CVE-2026-80352	9.8	CRIT		0.003	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users ...
CVE-2026-80976	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: seg6: reset IP6CB after IPv6 decapsulation decap_and_validate() pulls the outer SRv6 headers and makes the inner packet the skb network header. The IPv6 control block still contains values collected while parsing the outer packet, including nhoff and extension-header flags. End.DX6 and End.DT6 route the inner IPv6 packet directly to the IPv6 in...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81002	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: xdp: fix zero-copy frame layout xdp_convert_zc_to_xdp_frame() clones an XSK packet into an order-0 page and advertises PAGE_SIZE as its frame size. It allows the copied frame to occupy the page tail needed by skb_shared_info and records zero headroom even when metadata separates the frame header from packet data. An AF_XDP zero-copy packet redi...
CVE-2026-81402	9.8	CRIT		0.004		The DS Ad Rotator WordPress plugin through 0.8 does not perform any capability check, nonce verification, or file-type validation on its image upload handler, allowing unauthenticated attackers to upload arbitrary files, including PHP, to a web-accessible directory, which can lead to remote code execution.
CVE-2026-82232	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Apache Syncope. An administrator with adequate entitlements can achieve execution of arbitrary SQL via stacked queries, leveraging unsanitized sort clauses for Task search. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are re...
CVE-2026-82431	9.8	CRIT				Description `SimpleACLAuthorizer` evaluated the user-level command set by returning early when `nimbus.users` was empty, before `nimbus.groups` was considered. An operator who restricted cluster access by group alone, leaving `nimbus.users` unset, therefore received no restriction at all: every authenticated principal was permitted every user-level operation, including `submitTopology`, `beginFileUpload` and `get...
CVE-2026-82435	9.8	CRIT				Description The worker's Netty message decoder is installed ahead of the SASL authentication handlers in the pipeline and acts on frames before any authentication has taken place. It allocated buffers sized from a length field carried in the frame, so a single frame from an unauthenticated peer able to reach a worker slot port could drive a large allocation. `storm.messaging.netty.authentication` defaults to fal...
CVE-2026-82439	9.8	CRIT				Description The DRPC server kept a map from function name to request queue and created an entry the first time a function name was seen. No code path ever removed an entry: request cleanup removed the request from its queue, and the shutdown path drained queues, but the queue object and its map entry remained for the life of the process. Function names come from the client and are not constrained to functions an...
CVE-2026-84171	9.8	CRIT		0.004		The WP images upload on piclect WordPress plugin through 1.0 does not validate the name or type of uploaded files before writing them to a publicly accessible directory, allowing unauthenticated attackers to upload arbitrary files and execute arbitrary code on the server.
CVE-2026-85507	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _output_dell_system_info_cmc_info in ipmi-oem/ipmi-oem-dell.c (cmc-info subcommand to dell get-system-info).
CVE-2026-85681	9.8	CRIT		0.003		The WP Component WordPress plugin through 2.2.4 does not have any capability or nonce checks on one of the actions it makes available to unauthenticated users, and it takes both the option name and the option value from the request, allowing unauthenticated attackers to overwrite any of the site's options. On a single site installation this leads to a full takeover, as registration can be enabled with a default ro...
CVE-2026-86460	9.8	CRIT				Cypher injection vulnerability in the Neo4j persistence layer when processing some FIQL search conditions. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to version 4.0.8 / 4.1.3, which fix this issue.
CVE-2026-86793	9.8	CRIT		0.002		SGLang allows unauthenticated pickle deserialization through /update_weights_from_tensor when no auth keys are configured, and the SafeUnpickler policy can be bypassed because builtins.import and builtins.getattr are resolvable, enabling code execution via pickle REDUCE.
CVE-2026-87544	9.8	CRIT		0.003	google:chrome	Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87595	9.8	CRIT		0.002	google:chrome	Server-side request forgery in Mobile in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-88018	9.8	CRIT		0.005	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, while Server.auth passes the access key id...
CVE-2026-8925	9.8	CRIT		0.007	haxx:curl	The curl logic that works with SASL authentication could end up cleaning up the GSASL context *twice* without clearing the pointer in between, making it `free()` the same pointer twice.
CVE-2026-89478	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: sctp: drop a chunk if its transport was removed sctp_rcv() resolves the transport once per packet and leaves it in chunk->transport. The lookup reference, or the one sctp_add_backlog() takes if the socket is owned by userspace, keeps it around until the chunk has been processed. An authenticated ASCONF DEL-IP can remove it in the meantime. sctp...
CVE-2026-89479	9.8	CRIT		0.004		In the Linux kernel, the following vulnerability has been resolved: sctp: stop processing a packet once its association is deleted sctp_endpoint_bh_rcv() looks the association up only when chunk->asoc is NULL, and caches the result in chunk->asoc and chunk->transport without taking a reference. A packet that matches no association is handed to the endpoint, so a peer can bundle COOKIE ECHO, SHUTDOWN and SHUTDOWN...
CVE-2026-89482	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: do not accept C2HData based on blk_rq_payload_bytes() alone Commit 25e5cb780e62 ("nvme-tcp: fix possible crash in write_zeroes processing") established that blk_rq_payload_bytes() must not be read without first checking blk_rq_nr_phys_segments(), and recorded the result in nvme_tcp_setup_cmd_pdu() as req->data_len. The receive side was...
CVE-2026-89485	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: lockd: pin next file across nlm_inspect_file lock-drop nlm_traverse_files() pins the current file with f_count++ across a mutex_unlock for nlm_inspect_file(), but nothing pins the saved next pointer. A concurrent nlm_release_file() can kfree the next file during the unlock window, and the iterator dereferences freed memory on the next loop step...
CVE-2026-89494	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate lengths in dlm_mig_lockres_handler A node receiving a DLM_MIG_LOCKRES message trusts several fields of the peer-supplied dlm_migratable_lockres without validation. num_locks and lockname_len are bounded only on the sending side, and the message is never checked to actually carry num_locks migratable_lock entries. As a result dl...
CVE-2026-89495	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ocfs2: bound namelen in dlm_migrate_request_handler Patch series "ocfs2/dlm: bound peer-controlled lengths in the o2dlm". The o2dlm receive handlers trust u8 length and count fields from the wire without bounding them, so a node in a DLM domain can corrupt or panic any other node with a malformed message. Three defects: - dlm_migrate_req...
CVE-2026-89533	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix offset arithmetic in read_chunk_range svc_rdma_read_chunk_range() walks a Read chunk's segment list to build a sub-range starting at byte offset and spanning length bytes for a Position-Zero or Call chunk. Two arithmetic defects in the per-segment loop produce wrong DMA lengths and a u32 underflow: pcl_for_each_segment(segment,...
CVE-2026-89536	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: wait for in-flight client TLS handshake callback xs_tls_handshake_sync() gives xs_tls_handshake_done() a reference to the lower transport before submitting the handshake request. On timeout or signal, the synchronous waiter drops that reference after calling tls_handshake_cancel(). handshake_req_cancel() returns false when handshake_com...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89538	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Reject krb5 v2 wrap tokens with oversized ec field gss_krb5_unwrap_v2() sets buf->len to a logical length, which can be much smaller than head[0].iov_len (the allocated receive-page capacity). It then calls xdr_buf_trim() with a trim length derived from the 16-bit "extra count" (ec) field in the Kerberos v2 token header. The ec field i...
CVE-2026-89541	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_unwrap_resp_priv length checks gss_unwrap_resp_priv() validates the RPCSEC_GSS opaque length with offset = (u8 *) (p) - (u8 *) head->iov_base; if (offset + opaque_len > rcv_buf->len) goto unwrap_failed; maj_stat = gss_unwrap(ctx->gc_gss_ctx, offset, offset + opaque_len, rcv_buf)...
CVE-2026-89542	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: harden gss_krb5_unwrap_v2 against short tokens gss_krb5_unwrap_v2() reads the EC and RRC header fields at ptr+4 and ptr+6 before validating that the token is at least GSS_KRB5_TOK_HDR_LEN (16) bytes long, and its rotate_left() helper passes buf->len - base to xdr_buf_subsegment() without verifying that base <= buf->len. When a caller han...
CVE-2026-89550	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: svcauth_gss: enforce krb5 token minimum length svcauth_gss_unwrap_priv() validates only an upper bound on the wire-supplied opaque length before handing the buffer to gss_unwrap(): if (len > xdr_stream_remaining(xdr)) goto unwrap_failed; offset = xdr_stream_pos(xdr); ... maj_stat = gss_unwrap(ctx, offset, off...
CVE-2026-89551	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: xdr_buf_trim: clamp buf->len to avoid underflow xdr_buf_trim() trims `len` bytes from the tail of an xdr_buf by walking the tail, pages, and head iovecs. Each per-section step uses min_t() so it never removes more bytes than that section holds, but the final accounting at the fix_len label subtracts the total bytes actually consumed fro...
CVE-2026-89555	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: mpls: reload header after pskb_may_pull() mpls_select_multipath() calls mpls_multipath_hash() to choose a nexthop when an MPLS route has multiple nexthops. While walking the MPLS label stack, the hash routine caches hdr for the current label. After finding the bottom-of-stack label, it calls pskb_may_pull() before reading the inner IP header. ...
CVE-2026-89636	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: smb: client: clear ce->tgthint in free_tgts() When free_tgts() frees all structures in ce->tlist, ce->tgthint is left pointing to one of the freed cache_dfs_tgt structures. If ce->tgthint is not reset before it is used later, it results in a use-after-free. Set ce->tgthint to NULL in free_tgts() after the elements are freed to reflect that no ...
CVE-2026-89643	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: audit: avoid dropping live tree ref on fsnotify rule autoremove audit_del_rule() is used for both netlink deletion templates and internal fsnotify autoremove. The former passes a parsed template which owns a temporary tree reference; the latter passes the installed entry itself. The unconditional audit_put_tree() at the end of audit_del_rule()...
CVE-2026-89652	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound copied dentry name length in NFS export get_name ceph_get_name() copies the MDS-supplied name into the caller's NAME_MAX-sized buffer with memcpy(name, rinfo->dname, rinfo->dname_len) and then writes name[rinfo->dname_len] = 0, without checking dname_len against NAME_MAX. A malicious or buggy MDS that returns a LOOKUPNAME reply with ...
CVE-2026-89653	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: reject export_targets ranks >= CEPH_MAX_MDS in mdsmmap decode MDSMap export_targets entries are monitor controlled. check_new_map() uses each entry as a bit number in a fixed stack bitmap, so a rank outside the protocol namespace can make set_bit() write past the end of the array. Reject ranks outside CEPH_MAX_MDS while decoding the map. D...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89655	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ceph: fix UAF in __kick_flushing_caps() on cf entry freed during unlock list_for_each_entry() iterates ci->i_cap_flush_list but drops i_ceph_lock to send cap messages. During the unlock window, handle_cap_flush_ack() can acquire i_ceph_lock, detach cf entries with tid <= flush_tid from the list, release i_ceph_lock, and free them via ceph_free_...
CVE-2026-89656	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: libceph: reject buckets with mismatched CRUSH ids crush_decode() stores bucket data by array slot, and the mapper later derives the per-bucket workspace index from the decoded bucket id. A malformed map can therefore make one bucket reuse another bucket's workspace by encoding an id different from -1 - slot. For uniform buckets, the second repl...
CVE-2026-89662	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: NFSD: Prevent lock owner use-after-free during client teardown __destroy_client() releases a client's open owners, but a lock owner whose only reference is a blocked lock (nbl) stays on cl_ownerstr_hashtbl. client_has_state() does not count a bare owner, so DESTROY_CLIENTID can reach __destroy_client() with such owners present. __destroy_clien...
CVE-2026-89669	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: initialize copy-notify stateid before publishing it nfsd4_copy_notify() finished initializing the cpmf state after nfs4_alloc_init_cpmf_state() had already linked it into the s2s_cp_stateids IDR and the parent's sc_cp_list, with cs_count == 1 (the membership reference) and none held for the caller. A racing OFFLOAD_CANCEL (crafted cl_id ...
CVE-2026-89674	9.8	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR length calculation in nfsd4_ff_encode_layoutget The XDR buffer size calculation in nfsd4_ff_encode_layoutget() has multiple errors that can result in either an out-of-bounds write or leaking uninitialized kernel memory to the client: - fh_len doesn't account for XDR padding on the file handle data - uid and gid lengths use "8 + ...
CVE-2026-89712	9.8	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: NFSD: restart ssc_expire_umount walk after dropping nfsd_ssc_lock nfsd4_ssc_expire_umount() walks nn->nfsd_ssc_mount_list with list_for_each_entry_safe(ni, tmp, ...). For each expired entry it sets nsui_busy = true, drops nfsd_ssc_lock to run mntput() on the source vfsmount, then reacquires the lock to list_del + kfree the entry and continue it...
CVE-2026-9079	9.8	CRIT		0.011	haxx:curl	libcurl had a flaw that when instructed to clear proxy authentication credentials which made it not do so, leaving the old credentials around to get used for subsequent transfers that should not know nor use them.
CVE-2026-90898	9.8	CRIT				Bifrost registers MCP clients through its management API. A stdio client is a command plus args. Bifrost starts that program in the gateway the moment the client is added. No MCP handshake required. The default is governance.auth_config.is_enabled=false. Auth off means every caller is a local admin. One unauthenticated POST /api/mcp/client is enough to run a program as the Bifrost process user (appuser on the o...
CVE-2026-12944	9.6	CRIT				IBM Langflow OSS 1.0.0 through 1.10.0 can allow attackers to execute arbitrary Python code with root privileges (UID=0) on the Langflow server by submitting components containing socket or urllib imports. This enables: (1) AWS credential theft via IMDSv1 SSRF with full IAM role permissions, (2) arbitrary file exfiltration from the container filesystem, and (3) lateral movement to internal services (PostgreSQL, Red...
CVE-2026-39821	9.6	CRIT		0.007	golang:net	The ToASCII and ToUnicode functions incorrectly accept Punycode-encoded labels that decode to an ASCII-only label. For example, ToUnicode("xn--example-.com") incorrectly returns the name "example.com" rather than an error. This behavior can lead to privilege escalation in programs using the idna package. For example, a program which performs privilege checks on the ASCII hostname may reject "example.com" but permi...
CVE-2026-77005	9.6	CRIT		0.003		The CODE MONKEYS PROPOSALS WordPress plugin through 1.0.1 does not validate a user-supplied file path before deleting a file, and does not check the capability of the user making the request, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77006	9.6	CRIT		0.002		The WebTotem Backups WordPress plugin through 1.0.1 does not validate a user-supplied file path, does not check the capability of the user making the request, and discards the result of its own CSRF check, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-21391	9.5	CRIT				An improper validation vulnerability exists within PingAM where a well-crafted request allows arbitrary or protected ID Token claims to be set or overridden. In certain configurations this could allow an attacker to bypass authentication controls via spoofing leading to privilege escalation or impersonation.
CVE-2026-70470	9.5	CRIT		0.008	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, Flowise validatePythonCodeForDataFrame in packages/components/src/pythonCodeValidator.ts can be bypassed with Unicode homoglyph identifiers, allowing arbitrary Python execution inside Pyodide and full OS command execution on the Flowise host via Pyodide js module interop. The validator gates pyodide.runPythonAs...
CVE-2026-16242	9.4	CRIT		0.008		A flaw was found in the Konnectivity proxy-server configuration for hosted control planes. The agent-facing listener was started without --cluster-ca-cert (and without token-based agent authentication), so client certificates were not validated. A remote attacker who can reach the Konnectivity cluster endpoint could connect as an unauthenticated agent, join the routing pool, and potentially proxy, inspect, modify,...
CVE-2026-43114	9.4	CRIT		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_set_pipapo_avx2: don't return non-matching entry on expiry New test case fails unexpectedly when avx2 matching functions are used. The test first loads a ranomly generated pipapo set with 'ipv4 . port' key, i.e. nft -f foo. This works. Then, it reloads the set after a flush: (echo flush set t s; cat foo) nft -f - This is ex...
CVE-2026-57140	9.4	CRIT				PraisonAI is a multi-agent teams system. From 1.6.0 until 1.7.2, AgentOS in src/praisonai-ts/src/os/agentos.ts uses the 0.0.0.0 default from src/praisonai-ts/src/os/config.ts and registers GET /api/agents and POST /api/chat without authentication middleware. A remote caller who can reach the service can obtain agent names, roles, and instruction prefixes and can invoke a selected agent, potentially reaching its to...
CVE-2026-69254	9.4	CRIT		0.004	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, executeJavaScriptCode() accepted caller-provided nodeVMOptions and merged them over the default NodeVM security settings in packages/components/src/utlis.ts. An authenticated attacker reaching packages/server/src/routes/node-custom-functions/index.ts could run a custom function that imported flowise-components/...
CVE-2026-69256	9.4	CRIT		0.004	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the CSVAgent node allowed users to provide Python code that is executed through pyodide; although a denylist blocked dangerous Python constructs, pandas.read_pickle() could deserialize a pickled payload and achieve code execution without matching the denied words. The affected file is flowise-components/nodes/a...
CVE-2026-69259	9.4	CRIT		0.004	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the SQLite Record Manager node in packages/components/nodes/recordmanager/SQLiteRecordManager/SQLiteRecordManager.ts accepted user-controlled additionalConfig and spread it after the intended database setting, allowing additionalConfig.database to overwrite the SQLite database path. An authenticated attacker us...
CVE-2026-69264	9.4	CRIT		0.006	flowiseai:flowise	Prior to 3.1.3, Flowise CSVAgent interpolates an attacker-controlled segment of the csvFile data URI directly into a Python source-code template that is then executed by Pyodide. Because Pyodide is loaded with the default js bridge to globalThis, which on Node.js exposes eval and dynamic import, the attacker can break out of the Python string literal, hand a JavaScript string to js.eval, dynamically import Node bu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85192	9.4	CRIT		0.005		Joomla Extension - regularlabs.com - Authenticated, privileged remote code execution in Conditional Content extension for Joomla < 8.0.0 - Conditional Content Pro accepts inline PHP Condition Rules in article syntax. In affected versions, the PHP is passed to the Conditions evaluator without checking who authored the article. Joomla's normal Author text filter preserves the syntax, so publishing the article causes...
CVE-2026-90680	9.4	CRIT		0.005		A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.
CVE-2026-90692	9.4	CRIT		0.005		A vulnerability was detected in D-Link DIR-878 120B05. This affects the function SetDynamicDNSIPv6Settings of the component Dynamic DNS IPv6 Settings. The manipulation of the argument IPv6Address/Hostname results in stack-based buffer overflow. The attack may be launched remotely.
CVE-2026-90693	9.4	CRIT		0.005		A flaw has been found in D-Link DIR-878 120B05. This impacts the function SetWan3Settings of the component WAN Settings. This manipulation of the argument Primary/Secondary causes stack-based buffer overflow. Remote exploitation of the attack is possible.
CVE-2026-90937	9.4	CRIT				froxlol versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service, or hijacking of HTTP responses across ...
CVE-2026-27446	9.3	CRIT		0.1	apache:artemis	Missing Authentication for Critical Function (CWE-306) vulnerability in Apache Artemis, Apache ActiveMQ Artemis. An unauthenticated remote attacker can use the Core protocol to force a target broker to establish an outbound Core federation connection to an attacker-controlled rogue broker. This could potentially result in message injection into any queue and/or message exfiltration from any queue via the rogue bro...
CVE-2026-45052	9.3	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, the Liberty Web Services SOAP receiver permits unauthenticated remote requests to write persistent entries through SOAPReceiver and DiscoveryService into a user's Liberty Discovery store and the shared root-realm Discovery branch. The server-side handlers bypass requester LDAP and identity ACLs, and the global path uses an internal ...
CVE-2026-46619	9.3	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, MSISDNValidation in the MSISDN authentication module concatenates the request-supplied MSISDN value into an LDAP search filter without escaping, while the default empty trusted-gateway list allows all traffic. In a realm where an MSISDN module is enabled in a reachable authentication chain, an unauthenticated remote attacker can inj...
CVE-2026-62647	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A random number generator is used to generate security-relevant values (such as session identifiers used for authentication purposes) that is not initialized with a True Random Number Generator (TRNG), resulting in a predictable sequence of generated values. This could allow an unauthenticated remote attacker to more easily predict the ge...
CVE-2026-67399	9.3	CRIT				Deserialization of untrusted data in WHMCS 9.0.0 before 9.0.8 and 8.0.0 before 8.13.7 allows remote attackers to execute arbitrary code.
CVE-2026-72709	9.3	CRIT		0.003		SPIP before version 4.4.18 contains a missing authorization vulnerability in sensitive actions under ecrire/action/ that allows unauthenticated attackers to invoke privileged actions by supplying only a valid CSRF nonce without any server-side permission check. Attackers can bypass template-level authorization guards through direct HTTP requests to invoke actions such as editer_auteur, enabling arbitrary account p...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72710	9.3	CRIT		0.006		SPIP before 4.4.18 contains a mass assignment vulnerability in the <code>editor_objet</code> action that allows unauthenticated attackers to write arbitrary rows to any SQL table lacking a <code>champs_editables</code> allowlist by supplying an attacker-controlled <code>arg</code> parameter resolving to internal database tables. Attackers can insert a malicious row into the <code>spip_jobs</code> queue with a controlled PHP function and arguments, which is then dyn...
CVE-2026-80671	9.3	CRIT		0.002		In the Linux kernel, the following vulnerability has been resolved: <code>perf sched</code> : Fix <code>register_pid()</code> overflow, <code>strncpy</code> , and <code>BUG_ON register_pid()</code> has several issues when processing untrusted <code>perf.data</code> : 1. Integer overflow: <code>(pid + 1) * sizeof(struct task_desc *)</code> can wrap to a small value on 32-bit systems when <code>pid</code> is large (e.g. <code>0x40000000</code>), causing <code>realloc</code> to return a tiny buffer followed by out-of-bounds...
CVE-2026-85394	9.3	CRIT		0.002		<code>python-jose</code> through 3.5.0 fails to properly validate asymmetric keys in HMAC initialization, accepting DER-encoded public keys that lack PEM armor or SSH prefixes. Attackers holding the service's public key can forge HS256 tokens that pass verification when algorithms are not explicitly restricted. This is an incomplete fix for CVE-2024-33663.
CVE-2026-85428	9.3	CRIT		0.005		MOOS core-moos through 10.4.0 contains an authentication bypass vulnerability in the optional MOOSDB HTTP server that allows unauthenticated clients to write variables. Attackers can send HTTP requests with variable names and values to the MOOSDB HTTP server port to modify MOOS variables including actuator and override commands without authentication.
CVE-2026-85433	9.3	CRIT		0.003		MOOS essential-moos pShare through 10.0.1 fails to properly authorize PSHARE_CMD messages, allowing any publisher to reconfigure network routes and listeners at runtime. Attackers can send crafted PSHARE_CMD messages with <code>cmd=output</code> or <code>cmd=input</code> parameters to open new listeners on arbitrary addresses and redirect or duplicate bus traffic to attacker-controlled destinations.
CVE-2026-85438	9.3	CRIT		0.005		MOOS-lvp through 24.8.1 contains a buffer overflow vulnerability in <code>StringToIvpFunction()</code> where dimension, piece, and degree counts from encoded BHV_IPF payloads are used as allocation sizes and loop bounds without validation. Attackers can supply crafted payloads with mismatched dimension values to write attacker-controlled doubles past the end of the <code>IvpBox</code> weight array, causing memory corruption and potential c...
CVE-2026-85661	9.3	CRIT		0.004		<code>excel-mcp-server</code> 0.1.8 fails to enforce path confinement in <code>stdio</code> mode when <code>EXCEL_FILES_PATH</code> is unset, allowing attackers to read and write arbitrary files. Attackers can supply unchecked file paths to read and write tools to access any file accessible to the process.
CVE-2026-85688	9.3	CRIT		0.004		TEN Framework 0.11.71 contains unauthenticated arbitrary file read and write vulnerabilities in the TMAN Designer file-content API endpoints. Attackers can submit POST and PUT requests to the <code>/api/designer/v1/file-content</code> endpoints to read arbitrary files or write malicious content to system paths, enabling code execution through <code>authorized_keys</code> , cron files, or executable graph files.
CVE-2026-86543	9.3	CRIT		0.004		known versions before 0.30.0 serve the management API without authentication on all network interfaces by default, with no password required on fresh installations. Attackers can access the unauthenticated <code>/api/tunnel/start</code> endpoint to provision a public tunnel and republish the API at a publicly accessible address.
CVE-2026-87929	9.3	CRIT		0.003		MaxSite CMS through 109.6 ships with a hardcoded session encryption key in <code>application/config/config.php</code> that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious <code>ci_session</code> cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication checks in <code>is_login()</code> an...
CVE-2026-88877	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions <code>>= v3.7.0</code> and <code><= v3.7.11</code> , the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the <code>nginx.ingress.kubernetes.io/from-to-www-redirect</code> annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only the <code>RedirectRegex</code> middleware, and still...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89448	9.3	CRIT		0.001		In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Force requesting ACS when tboot is enabled Currently the conditions of requesting ACS in detect_intel_iommu() don't include tboot, leading to a possible misconfiguration with ACS disabled (e.g. due to user opts) while iommu is later forced on by tboot_force_iommu(). Fix it by checking tboot in detect_intel_iommu().
CVE-2026-90558	9.3	CRIT		0.005		sngrep through 1.8.4 contains stack buffer overflow vulnerabilities in SIP attribute formatting routines when header values exceed the 255-byte buffer limit. Attackers can craft malicious SIP packets with oversized Call-ID, X-Call-ID, or other header fields to overflow stack buffers and cause crashes or execute arbitrary code during packet parsing and rendering.
CVE-2026-90919	9.3	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the Config Server's unauthenticated /visual_register WebSocket endpoint that passes the first client frame directly to pickle.loads(). Attackers can reach the Config Server port and send a malicious serialized payload with a __reduce__ method to execute arbitrary code with Config Server process privileges.
CVE-2026-90942	9.3	CRIT				Casdoor through 4.4.0 fails to properly mask the instance-wide built-in certificate private key in /api/get-certs and /api/get-cert endpoints, allowing organization administrators to retrieve it. Attackers can use the exposed private key to forge JWT tokens for any user in any organization, including global administrators.
CVE-2026-90943	9.3	CRIT				parallax filament-comments through 3.0.0 contains a stored cross-site scripting vulnerability in comment body rendering that allows authenticated panel users to inject malicious scripts. Attackers can store XSS payloads in comment bodies that execute in the browsers of other users viewing those comments, including administrators, enabling session token theft and unauthorized actions.
CVE-2026-90945	9.3	CRIT				Crawlab through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.
CVE-2026-90961	9.3	CRIT				The LdapAuth and LinOTPAuth authentication plugins in MISP contain an authentication bypass vulnerability. Both LdapAuthenticate and LinOTPAuthenticate replace CakePHP's FormAuthenticate class but fail to replicate its _checkFields() input validation guard. As a result, the email and password fields extracted from the login request are passed to downstream authentication logic without verifying that they are non-e...
CVE-2026-12258	9.2	CRIT				Inadequate access control in Hiperdino's REST v1.0 API. The public endpoint 'customer/check' could allow an authenticated attacker to enter a telephone number or an email address. When the value entered belongs to a registered customer, the service returns the associated information (email address and telephone number). No authentication is required beyond a static bearer token, and there is no rate limiting or ge...
CVE-2026-42055	9.2	CRIT		0.065	f5:dos, f5:nginx_gateway_fabric, f5:nginx_ingress_controller, f5:nginx_instance_manager, f5:nginx_open_source, f5:nginx_	NGINX Plus and NGINX Open Source have a vulnerability in the ngx_http_proxy_v2_module and ngx_http_grpc_module modules. This vulnerability exists when the proxy_http_version to 2 or grpc_pass directives are used to proxy HTTP/2 traffic, the ignore_invalid_headers directive is set to off, and the large_client_header_buffers directive size is larger than 2 megabytes. A remote, unauthenticated attacker, along with co...
CVE-2026-45051	9.2	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, WebAuthnAuthentication loads a serialized AuthenticatorImpl object graph from the configured userAttribute through loadAuthenticators without an ObjectInputFilter. Exploitation requires the WebAuthn flow to be reachable and an attacker to have previously written controlled data to that attribute through delegated administration, pro...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-57578	9.2	CRIT				DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, AuthorizeActionFilter performs no authorization because its explicit ICommandActionFilter.OnCommandExecutingAsync, IViewModelActionFilter.OnViewModelCreatedAsync, and IPresenterActionFilter.OnPresenterExecutingAsync implementations return completed tasks instead of invoking the corresponding checks. Ap...
CVE-2026-62263	9.2	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.2, WebAuthnAuthentication.deserialize applies an ObjectInputFilter that allows every serialized object at depth greater than 1 and therefore constrains only an AuthenticatorImpl root object. A pre-authentication attacker can supply a userHandle whose serialized graph has a valid AuthenticatorImpl root and a nested gadget class, causing...
CVE-2026-69255	9.2	CRIT		0.006	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the CSVAgent in packages/components/nodes/agents/CSVAgent/CSVAgent.ts extracted attacker-controlled CSV data with file.split(',').pop() and interpolated it directly into executable Python as base64_string = "\${base64String}" before calling Pyodide. The validatePythonCodeForDataFrame() denylist only checked late...
CVE-2026-85620	9.2	CRIT		0.004		Postgres MCP Pro 0.3.0 contains a restricted-mode bypass vulnerability where function-name validation is not applied to RangeFunction nodes in FROM clauses. Attackers can execute file-reading functions like pg_read_file through FROM-clause syntax to read arbitrary files despite restricted-mode protections.
CVE-2026-85625	9.2	CRIT		0.005		sift (sift.js) 17.1.3 enumerates query keys with for...in, which walks the object prototype chain, and dispatches any matched operator key including \$where. The \$where operation compiles a string value into a function using new Function unless CSP_ENABLED is set (not set by default). As a result, if a prototype-pollution primitive elsewhere in the process sets Object.prototype.\$where to a malicious string, even be...
CVE-2026-90456	9.2	CRIT		0.003		An example environment-configuration file for a bundled inventory-management component ships with a fixed, publicly-known administrative password. A deployment that copies this example file into active configuration without running the setup routine that regenerates credentials will expose that component's administrative interface to anyone aware of the default value.
CVE-2026-9277	9.2	CRIT		0.008		shell-quote's `quote()` function did not validate object-token inputs against the operator model used by `parse()`. The `op` field was backslash-escaped character by character using `/(.)g`, which in JavaScript does not match line terminators (\n, \r, U+2028, U+2029). A line terminator in `op` therefore passed through unescaped into the output; POSIX shells treat a literal newline as a command separator, so any...
CVE-2026-9323	9.2	CRIT		0.004		The urwid web display backend (urwid/display/web.py) generates web session identifiers (urwid_id) in Screen.start() by concatenating two random.randrange(10**9) calls that use Python's Mersenne Twister PRNG, which is not cryptographically secure. Each call consumes approximately 30 bits of PRNG state, and the Mersenne Twister internal state is approximately 19,937 bits, so an attacker who observes approximately 33...
CVE-2026-11564	9.1	CRIT		0.004	haxx:curl	libcurl keeps previously used connections in a connection pool for subsequent transfers to reuse if one of them matches the setup. An easy handle that first uses default native CA trust can continue trusting the native platform store after the application switches that same handle to custom CA material for a later transfer.
CVE-2026-18924	9.1	CRIT		0.009	haxx:curl	A flaw in libcurl's handling of HTTP/2 Server Push streams, when the parent handle is set to share connections with other handles, can lead to use-after-free in the cleanup process.
CVE-2026-33186	9.1	CRIT		0.016	grpc:grpc	gRPC-Go is the Go language implementation of gRPC. Versions prior to 1.79.3 have an authorization bypass resulting from improper input validation of the HTTP/2 `:path` pseudo-header. The gRPC-Go server was too lenient in its routing logic, accepting requests where the `:path` omitted the mandatory leading slash (e.g., `Service/Method` instead of `/Service/Method`). While the server successfully routed these reques...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-39830	9.1	CRIT		0.006	golang:crypto	A malicious SSH peer could send unsolicited global request responses to fill an internal buffer, blocking the connection's read loop. The blocked goroutine could not be released by calling Close(), resulting in a resource leak per connection. Unsolicited global responses are now discarded.
CVE-2026-48717	9.1	CRIT				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, AuthorizationCodeGrantTypeHandler requires a code_verifier only when the realm-wide codeVerifierEnforced setting is enabled, even when an authorization code stores a code_challenge. Because that setting is disabled by default, an attacker who intercepts a PKCE-protected authorization code can omit code_verifier and redeem the code, ...
CVE-2026-50006	9.1	CRIT				Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server forwards unauthenticated SQL from its MySQL-compatible server port to SQLite without restricting ATTACH DATABASE filesystem targets. A remote attacker can select any path writable by the Anyquery server process, cause SQLite to create a database file there, and place attacker-controlled table content in that file. This permits ...
CVE-2026-52824	9.1	CRIT				Kimai is an open-source time tracking application. Prior to 2.58.0, the official Docker image sets APP_SECRET to the public value change_this_to_something_unique in Dockerfile, and .docker/entrypoint.sh neither replaces nor rejects that value before Symfony uses it as kernel.secret. An unauthenticated attacker who reaches a deployment that did not override APP_SECRET, knows a username, correctly guesses the accoun...
CVE-2026-53713	9.1	CRIT				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, to_absolute_normalized_path in internal/gatewayapi/luavalidator/security.lua does not collapse redundant separators before is_critical_path evaluates Lua submitted through EnvoyExtensionPolicy during default Strict validation. Linux resolves a double-slash absolute pat...
CVE-2026-57145	9.1	CRIT				PraisonAI is a multi-agent teams system. Prior to 4.6.62, src/praisonai/praisonai/tools/multiedit.py passes the LLM-controlled filepath parameter directly to open for reading and writing without traversal rejection, symlink resolution, a workspace boundary, or protected-path checks. Prompt-influenced agents can read files through edit and diff behavior or overwrite files accessible to the process, exposing secrets...
CVE-2026-61534	9.1	CRIT				Yayson is a library for serializing and reading JSON API data in JavaScript. Prior to 4.3.0, Store and LegacyStore use attacker-controlled JSON:API type, id, and relationship names as keys in plain-object lookup tables in src/yayson/store.ts and src/yayson/legacy-store.ts. A document whose type is __proto__ causes model-cache writes to modify Object.prototype, with the attacker controlling the polluted property na...
CVE-2026-68006	9.1	CRIT		0.002		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file
CVE-2026-71640	9.1	CRIT		0.002		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline
CVE-2026-78299	9.1	CRIT				In Eclipse Embedded CDT versions 6.0 to 6.7 if the CMSIS-Pack archive extracts a compromised CMSIS pack the archive extraction can extract files to locations outside of the pack, allowing writing of arbitrary files to other locations on disk.
CVE-2026-82441	9.1	CRIT				Description A submitted topology carries two lists of blobstore keys, `dependency_jars` and `dependency_artifacts`, which the client fills in after uploading the corresponding blobs. Nimbus performed no validation of their contents on the submission path, yet acts on them in two places. During cleanup of a finished topology, Nimbus deletes the keys named in those lists, and the deletion is performed as the Nimbu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87785	9.1	CRIT				Authentication bypass by spoofing vulnerability in Apache Syncope. When the configured JWKS settings for internal JWT authentication are disclosed (at least protocol and key), an attacker can spoof another user's privileges after completing a successful authentication and obtaining a valid JWT. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4...
CVE-2026-87802	9.1	CRIT				Improper verification of cryptographic signature vulnerability in Apache Syncope. When SRA is configured for OAuth 2.0 without JWKS set URI assigned, an attacker can forge arbitrary JWTs to impersonate any user identity and permissions, gaining full access to services proxied by SRA. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 through 4.0.7, from 4.1.0-M0 through 4.1.2. Us...
CVE-2026-88007	9.1	CRIT		0.004	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backend keep-alive, an unr...
CVE-2026-8924	9.1	CRIT		0.006	haxx:curl	A flaw in curl's cookie parsing logic allows a malicious HTTP server to set "super cookies" that bypass the Public Suffix List check. This enables an attacker-controlled origin to inject cookies that curl subsequently scopes and transmits to unrelated third-party domains.
CVE-2026-8926	9.1	CRIT		0.004	haxx:curl	When asking curl to use a `.netrc` file to find credentials and at the same time specifying a URL with a username (without a password), like `https://user@example.com/`, curl could wrongly get and use the password for *another* user set in the `.netrc` file for that host if such a one exists and there is no match for the specified user.
CVE-2026-8927	9.1	CRIT		0.005	haxx:curl	When reusing a libcurl handle for sequential transfers driven by environment-variable proxy configuration, libcurl fails to clear the proxy authentication state between requests. Specifically, if the initial transfer authenticates against `proxyA` using Digest auth, a subsequent transfer routed through `proxyB` erroneously leaks the `Proxy-Authorization:` header intended solely for `proxyA`.
CVE-2026-89532	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix pcl_for_each_segment for empty chunks When a parsed chunk list contains a chunk whose ch_segcount is zero, pcl_for_each_segment computes its inclusive upper bound as &chunk->ch_segments[ch_segcount - 1]. ch_segcount is u32, so the subtraction wraps to 0xFFFFFFFF and the bound lands far past the ch_segments flex array. The loop body ...
CVE-2026-89634	9.1	CRIT		0.007		In the Linux kernel, the following vulnerability has been resolved: smb: client: fix ALIGN() overflow in symlink_data() error context loop The check added by commit 7d9a7f1f96cd ("smb/client: fix possible infinite loop and oob read in symlink_data()") compared the post-ALIGN length against the remaining buffer, but ALIGN() itself can overflow: for ErrorDataLength near UINT32_MAX (e.g. 0xFFFFFFFF9), ALIGN(x, 8) wr...
CVE-2026-89649	9.1	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: ceph: bound xattr value length in __build_xattrs() __build_xattrs() decodes the MDS-supplied xattr blob one attribute at a time. For each attribute it reads a 32-bit name length, advances past the name bytes, reads a 32-bit value length, records the value pointer, and advances past the value bytes. The two length fields are read with ceph_decode...
CVE-2026-89650	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: ceph: bound num_export_targets array for mds info v2/v3 ceph_mdsmmap_decode() in fs/ceph/mdsmmap.c reads num_export_targets from each per-mds info record and advances the decode cursor by num_export_targets * sizeof(u32) without first checking that many bytes remain. The only upper-bound check that catches a runaway cursor (*p > info_end) is gated...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89671	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs3 setacl by argp->mask nfsd3_proc_setacl() calls set_posix_acl() unconditionally for both ACL_TYPE_ACCESS and ACL_TYPE_DEFAULT, passing argp->acl_access and argp->acl_default verbatim. The NFSv3 ACL decoder only populates those pointers when the corresponding mask bit is set: nfs3svc_decode_setaclargs() if (args->mask & ...
CVE-2026-89672	9.1	CRIT		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: gate nfs2 setacl by argp->mask The NFSACL v2 SETACL path shares the decoder convention used by its v3 sibling: nfsaclsvc_decode_setaclargs() fills in argp->acl_access only when NFS_ACL is set in the request mask and argp->acl_default only when NFS_DFACL is set, leaving the other pointer NULL because the argument buffer is zeroed up to pc_a...
CVE-2026-89697	9.1	CRIT		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: add fh_want_write() for early-verified SETATTR in nfsd_proc_setattr() The BOTH_TIME_SET branch calls fh_verify() early so setattr_prepare() can inspect the dentry. This causes nfsd_setattr() to skip fh_want_write(), so notify_change() runs without a mount write reference. Add the missing fh_want_write() call after the early fh_verify().
CVE-2026-90711	9.1	CRIT				proxy-addr is a Node.js module that determines a request's client address behind trusted reverse proxies, and it backs Express req.ip and req.ips. In versions 1.1.0 through 2.0.7, a trust subnet written in IPv4-mapped IPv6 notation with an IPv4-sized prefix, such as ::ffff:10.0.0.0/8 instead of the correct ::ffff:10.0.0.0/104, is accepted without error but trusts every IPv4 address on the internet rather than the ...
CVE-2024-21400	9.0	CRIT		0.022	microsoft:conform	Microsoft Azure Kubernetes Service Confidential Container Elevation of Privilege Vulnerability
CVE-2026-69251	9.0	CRIT		0.017	flowiseai:flowise	Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, Flowise record manager and agent memory nodes allowed users to set arbitrary TypeORM DataSource options through the additionalConfig input in packages/components/nodes/recordmanager/MySQLRecordManager/MySQLRecordManager.ts, packages/components/nodes/recordmanager/PostgresRecordManager/PostgresRecordManager.ts, ...
CVE-2026-69253	9.0	CRIT		0.003	flowiseai:flowise	Flowise is a drag-and-drop user interface for building customized large language model (LLM) flows. Prior to version 3.1.3, several custom-tool components — AgentAsTool, ChatflowTool, and ExecuteFlow — ran code in the in-process vm2 sandbox. To build that code, they inserted a user-controlled baseUrl value straight into the JavaScript source, for example const url = "\${baseUrl}/..."; . The only check on base...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-27830	8.9	HIGH		0.005		c3p0, a JDBC Connection pooling library, is vulnerable to attack via maliciously crafted Java-serialized objects and `javax.naming.Reference` instances. Several c3p0 `ConnectionPoolDataSource` implementations have a property called `userOverridesAsString` which conceptually represents a `Map<String,Map<String,String>>`. Prior to v0.12.0, that property was maintained as a hex-encoded serialized object. Any attacker...
CVE-2026-13293	8.8	HIGH				IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 could allow a remote authenticated attacker to execute arbitrary code on the system due to the deserialization of untrusted data.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-16428	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary code due to improper configuration of the XSLT transformation engine.
CVE-2026-16466	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary commands due to os command injection.
CVE-2026-16673	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to execute arbitrary OS commands due to improper neutralization of special characters in the PxPeek name property.
CVE-2026-48054	8.8	HIGH		0.004		OpenZeppelin Contracts Wizard is a web application to interactively build a contract out of components from OpenZeppelin Contracts. Versions prior to 0.10.9 generate a Hardhat test file (`test/test.ts`) by interpolating user-supplied `opts.name` (ERC20/ERC721) and `opts.uri` (ERC1155) directly into TypeScript string literals at `zip-hardhat.ts:48` and `:50` without any JavaScript string escaping. No authentication...
CVE-2026-69461	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69518	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop allows an unauthorized attacker to execute code over a network.
CVE-2026-72524	8.8	HIGH				Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access or modify data they are not authorized to. This issue affects Apache Doris: from 3.1.0 through 3.1.*, from 4.0.0 through 4.0.7, and from 4.1.0 through 4.1.3. Users are recommended to upgrade to a fixed release (4.0.8 or 4.1.4), which fixes the issue.
CVE-2026-75624	8.8	HIGH		0.004		IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.27 could allow a remote authenticated attacker to bypass security restrictions due to incorrect authorization.
CVE-2026-80914	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: ISO: fix use-after-free of listener socket in iso_conn_ready iso_conn_ready() looks up the BIS listener socket with iso_get_sock(), which takes a reference, and then, without re-checking its state, creates a child socket from it: parent = iso_get_sock(hdev, ...); if (!parent) return; lock_sock(parent); sk = i...
CVE-2026-80935	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: bound the device EEPROM address before the EFUSE copy mt7996_mcu_get_eeprom() derives the destination of the EFUSE/EXT block copy from the address reported by the MCU response (event->addr, a device-controlled __le32) and clamps only the copy length, never the destination offset into dev->mt76.eeprom.data. A malicious or malf...
CVE-2026-80989	8.8	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: net: thunderbolt: Mark the connection down when bringing it up fails Every failure path in tbnet_connected_work() undoes its own work and returns without clearing login_sent, so the connection still looks established. The next tbnet_tear_down() therefore takes its main branch and repeats a teardown that already happened: it stops rings that are ...
CVE-2026-82097	8.8	HIGH		0.004		IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to a Server-Side Request Forgery (SSRF) vulnerability.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82428	8.8	HIGH				Description Dependency artifacts uploaded with `storm jar --artifacts` were stored under a blob key derived only from the Maven coordinate, for example `dep---.jar`. The key was therefore identical for every user of the cluster and predictable in advance. When the blob already existed, the uploader caught `KeyAlreadyExistsException` and silently reused it, with no check that the existing blob's content or owner m...
CVE-2026-84889	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.10.3 could allow a remote authenticated attacker to execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-89493	8.8	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate rl_used against rl_count in refcount block validator ocfs2_find_refcount_rec_in_rl() walks the on-disk refcount record array with: for (; i < le16_to_cpu(rb->rf_records.rl_used); i++) { rec = &rb->rf_records.rl_recs[i]; ... rl_recs[] lives in a single metadata block (4096 bytes on the common configuration), so its real cap...
CVE-2026-89569	8.8	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: RFCOMM: serialize security confirmation handling rfcomm_security_cfm() looks up a session on session_list and then walks its DLC list without holding rfcomm_mutex. Since RFCOMM session teardown uses rfcomm_mutex, krfcommd can close and free the same session and DLCs concurrently: hci_rx_work krfcommd -----...
CVE-2026-89626	8.8	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: HID: sensor: custom: Fix field sysfs group cleanup on failure hid_sensor_custom_add_attributes() creates one sysfs group for each custom sensor field. If sysfs_create_group() fails after some groups have already been created, the function returns the error without removing the previously created groups. Add a local unwind path to remove the gro...
CVE-2026-89663	8.8	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: revoke copy-notify stateids before dropping their reference Copy-notify stateids live in the s2s_cp_stateids IDR and on their parent stdid's sc_cp_list, pinned by a single membership reference. _free_cpntf_state_locked() only unlinks an entry once its refcount reaches zero, so any revoke path that runs while a concurrent find_cpntf_state()/...
CVE-2026-89725	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: media: cec: stm32: prevent out-of-bounds write on RX overflow stm32_rx_done() appends each received CEC byte to rx_msg.msg[] using rx_msg.len as the write index, incrementing it on every RXBR (receive-byte-ready) interrupt without checking it against the buffer size: cec->rx_msg.msg[cec->rx_msg.len++] = val & 0xFF; rx_msg.msg[] is a fixed CEC...
CVE-2026-89729	8.8	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: HID: sensor-hub: Fix out-of-bounds write in sensor_hub_get_feature sensor_hub_get_feature() clamps its return value to the caller's buffer size, but the copy loop still copies field->report_size / 8 bytes for each report value. A malicious HID descriptor can advertise a large feature field size while an IIO caller supplies a small stack buffer, ...
CVE-2026-90938	8.8	HIGH				LangBot's plugin runtime (pip package langbot_plugin) through 0.4.17 starts a debug WebSocket server on 0.0.0.0:5401 (/plugin/ws) whose authentication is gated on plugin_debug_key, which defaults to an empty string and is never set by the upstream repository, Docker image, or docker-compose (which additionally publishes port 5401 to the host); the key check is therefore skipped entirely. Any remote attacker able t...
CVE-2026-68489	8.7	HIGH				Static Code Injection in Plesk extensions "Ruby" before 1.6.6 and "Node.js Toolkit" before 2.5.0 allows remote authenticated users to execute arbitrary code as root via custom environment variables.
CVE-2026-72708	8.7	HIGH		0.003		SPIP before 4.4.18 contains an unauthenticated blind SQL injection vulnerability in the SQL escaping layer that allows unauthenticated attackers to inject arbitrary SQL by supplying a crafted annee parameter value matching a word character followed by an open parenthesis, which bypasses escaping for date-type columns across MySQL, SQLite, and PostgreSQL backends. Attackers can exploit the always-present sitemap.xml...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82028	8.7	HIGH				Magistrala before 1.0.0 contains a SQL injection vulnerability in the timescale-reader and postgres-reader HTTP API services that allows authenticated attackers to inject arbitrary SQL by supplying a malicious format query parameter that is interpolated directly into the FROM clause without parameterization or identifier quoting. Attackers with a self-registered account can substitute arbitrary subqueries to achie...
CVE-2026-90559	8.7	HIGH		0.004		snappy-java through 1.1.10.8 contains an out-of-bounds write vulnerability in Snappy.uncompress(ByteBuffer, ByteBuffer) because destination buffer capacity is never validated against decompressed size. Attackers can supply valid compressed data that decompresses larger than the destination buffer, causing writes past buffer boundaries and JVM termination.
CVE-2026-90946	8.7	HIGH				DeepWiki-Open through commit d92819a contains an arbitrary file read vulnerability in the unauthenticated /ws/chat WebSocket endpoint that accepts repo_url as a filesystem path with no containment. Attackers can supply arbitrary directory paths to read all files with supported extensions including Python, JavaScript, YAML, and JSON files containing hardcoded secrets and credentials.
CVE-2026-91771	8.7	HIGH				Weights & Biases wandb before 0.29.0 fails to validate the file name from server responses in the File.download function, allowing path traversal attacks. Attackers controlling the backend can supply file names with directory traversal sequences to write files outside the intended download directory, potentially enabling code execution through modification of shell startup files or Python import paths.
CVE-2026-54628	8.6	HIGH				Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes URL-capable SQLite virtual table modules such as json_reader and log_reader through its unauthenticated MySQL-compatible server port without restricting outbound destinations. A remote attacker can provide a loopback, private-network, or link-local cloud metadata URL, causing go-getter in the Anyquery server process to ...
CVE-2026-57122	8.6	HIGH				PraisonAI is a multi-agent teams system. Prior to 4.6.59, the WhatsApp and Linear bot webhook handlers verify HMAC signatures only when WHATSAPP_APP_SECRET or LINEAR_WEBHOOK_SECRET is configured and otherwise parse and dispatch unsigned request bodies. A remote unauthenticated client that reaches the webhook route can forge messages, comments, or agent-session events, impersonate platform users, influence agent pr...
CVE-2026-86830	8.6	HIGH				Incorrect privilege assignment in Temporary Elevated Access Management (TEAM) for AWS IAM Identity Center solution before version 1.5.1 might allow an authenticated remote user with application-level access to read, approve, modify, or revoke arbitrary access requests, thereby obtaining unintended temporary elevated access to the AWS accounts accessed using the TEAM deployment. This issue has been addressed in ...
CVE-2026-90493	8.5	HIGH		0.001		A vulnerability was detected in Tonic Internet Download Manager up to 6.42 Build 63 on Windows. The impacted element is an unknown function of the file idmwfp.sys of the component Kernel Driver. The manipulation results in improper access controls. Attacking locally is a requirement. Internet Download Manager for Windows up to and including 6.42 Build 63 installs idmwfp.sys, a Windows kernel driver that exposes th...
CVE-2024-58383	8.4	HIGH				Froxlор before 2.2.0 (affected up to and including 2.2.0-rc3) generates /etc/pure-ftpd/db/mysql.conf with mode 0644 via the XML configuration templates in lib/configfiles/, even though the file contains the Froxlор SQL user's password. On systems where the parent directories are world readable (the default on Debian 12), any unprivileged local user able to execute commands or code on the host — including virtual u...
CVE-2026-53091	8.4	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: pull headers in qdisc_pkt_len_segs_init() Most ndo_start_xmit() methods expects headers of gso packets to be already in skb->head. net/core/tso.c users are particularly at risk, because tso_build_hdr() does a memcpy(hdr, skb->data, hdr_len); qdisc_pkt_len_segs_init() already does a dissection of gso packets. Use pskb_may_pull() instead o...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54447	8.4	HIGH				garminconnect is a Python 3 API wrapper for Garmin Connect that retrieves statistics and manages activities. Prior to 0.3.5, garminconnect/client.py Client.dump creates the OAuth token directory and garmin_tokens.json without explicit owner-only modes, so a permissive umask such as 022 can leave the directory mode at 0755 and the token file mode at 0644. garmin_tokens.json contains di_refresh_token, and another un...
CVE-2026-60163	8.4	HIGH		0.003	oracle:mysql_cluster, oracle:mysql_server	Vulnerability in the MySQL Server, MySQL Cluster product of Oracle MySQL (component: Server: Group Replication Plugin). Supported versions that are affected are MySQL Server: 8.4.0-8.4.10, 9.7.0-9.7.1; MySQL Cluster: 8.0.0-8.0.47, 8.4.0-8.4.10 and 9.7.0-9.7.1. Easily exploitable vulnerability allows unauthenticated attacker with logon to the infrastructure where MySQL Server, MySQL Cluster executes to compromise...
CVE-2026-68955	8.4	HIGH		0.002		The installer for Rakuten Kobo Desktop Application (Windows version) insecurely loads Dynamic Link Libraries. If there is a crafted DLL at the same directory when invoking the affected installer, arbitrary code may be executed with the privileges of the user who performed the installation.
CVE-2026-69479	8.4	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-77827	8.4	HIGH		0.002		Maono Link 3.8.13 MaonoAiServices Windows service allows local privilege escalation for a standard user account via improper write privileges in 'C:\ProgramData\Maono'. Fixed in 4.0.80.
CVE-2026-80932	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: vsock/virtio: flush works in dependency order virtio_vsock_remove() stops the virtqueues and then flushes each work item before freeing the enclosing virtio_vsock. The current order does not account for dependencies between those items: tx_work may queue send_pkt_work, and send_pkt_work may queue rx_work. In particular, send_pkt_work can set r...
CVE-2026-80967	8.4	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: pcxhr: initialize mutexes before requesting threaded IRQ pcxhr_probe() requests pcxhr_threaded_irq() before initializing mgr->lock, even though the threaded handler takes that mutex. Initialize the manager locks before request_threaded_irq() so an early interrupt cannot run against uninitialized mutex state during probe.
CVE-2026-81012	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix off-by-one write in hp_get_string_from_buffer() hp_get_string_from_buffer() clamps the converted string length against the destination buffer size with "size > dst_size", so when the converted length is exactly equal to dst_size, conv_dst_size is left at dst_size and the unconditional NUL terminator write dst[conv...
CVE-2026-81017	8.4	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: platform/chrome: sensorhub: Bound the EC-reported sensor number Each EC FIFO event carries an 8-bit sensor number (in->sensor_num). cros_ec_sensorhub_ring_handler() validates the FIFO event count, the per-read count and the ring bound, but not the sensor number, which cros_ec_sensor_ring_process_event() then uses unchecked to index sensorhub->ba...
CVE-2026-82049	8.4	HIGH				In CPython 3.13 and earlier, the tarfile module's data and tar extraction filters are vulnerable to crafted archives containing a hard link to a symbolic link. Such archives may cause extraction to modify the permissions or modification time of a file outside the destination directory, or expose the contents of that file within the extracted tree.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89465	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: power: supply: rt9455: quiesce delayed work before teardown The threaded IRQ handler can queue pwr_rdy_work, max_charging_time_work and batt_presence_work. pwr_rdy_work and batt_presence_work can also queue max_charging_time_work, while batt_presence_work can requeue itself. rt9455_remove() cancels max_charging_time_work before batt_presence_w...
CVE-2026-89469	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: power: supply: lp8727: fix use-after-free in lp8727_release_irq() lp8727_isr_func(), the threaded IRQ handler, is the only caller that arms pchg->work via schedule_delayed_work(). lp8727_release_irq() currently cancels the work before freeing the IRQ, so an IRQ delivered in between can re-arm the work through the threaded handler. After .remov...
CVE-2026-89470	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: power: supply: cros_usbpd: Limit port counts to EC_USB_PD_MAX_PORTS Currently the cros_usbpd-charger driver probe iterates based on raw charger port count returned by the embedded controller. The only check is against the number of USB PD ports which the embedded controller also defines. A malicious embedded controller could return an inaccurate...
CVE-2026-89471	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: power: supply: cros_usbpd-charger: bound the EC-reported port count cros_usbpd_charger_probe() reads two port counts from the EC and uses one of them, num_charger_ports, as the loop bound when populating a fixed-size array: struct port_data *ports[EC_USB_PD_MAX_PORTS]; /* 8 entries */ ... for (i = 0; i < charger->num_charger_ports; i++) ch...
CVE-2026-89504	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: regulator: as3722_get_regulator_dt_data: fix premature of_node_put leaving dangling of_node pointer In as3722_get_regulator_dt_data(), of_get_child_by_name() acquires a reference on np, which is then assigned to pdev->dev.of_node. The function immediately calls of_node_put(np), releasing the reference and leaving pdev->dev.of_node as a dangling ...
CVE-2026-89560	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: landlock: Require LANDLOCK_ACCESS_FS_MAKE_REG for whiteout creation Whiteout objects are used in the upper layer of an OverlayFS to indicate that the file with this name does not exist in the unified view, even if it is present in one of the lower layer file systems. For the userspace implementations of OverlayFS (fuse-overlayfs), whiteout obje...
CVE-2026-89599	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: fbdev: omapfb: panel-dsi-cm: initialize lock before registering display dsicm_probe() registers the display before initializing ddata->lock. Once omapdss_register_display() publishes the display, another consumer can reach a dsicm callback that takes this mutex while it is still uninitialized. Initialize the mutex before registering the display...
CVE-2026-89603	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: entry: Fix seccomp bypass after ptrace with TSYNC Sashiko review pointed out the following issue. If a thread is stopped in syscall_trace_enter() for ptrace, another thread can install a seccomp filter with SECCOMP_FILTER_FLAG_TSYNC (e.g., via seccomp_attach_filter()). This will successfully set SYSCALL_WORK_SECCOMP on the stopped thread, but S...
CVE-2026-89615	8.4	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: bound page_lcn[] index by the log record The copy_lcn loop and the redo shorten loop index page_lcn[] at j + i, where i runs up to the log record's lcn_follow. That count is checked only against the record's own length, not the target entry, so check_dp_table() (which validates the entry's lcn_follow) does not cover it: the copy_l...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89744	8.4	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: device property: fix infinite loop in fwnode_for_each_child_node() When iterate over children of a fwnode that has a secondary fwnode, fwnode_get_next_child_node() can enter an infinite loop if the secondary fwnode has more than one child. Parent Child (Primary fwnode) FWa: {FWa1, FWa2, FWa3} (Seconda...
CVE-2026-55451	8.3	HIGH				gettext-converter provides gettext resource conversion utilities for JavaScript. Prior to 1.3.3, js2i18next() in lib/js2i18next.js splits nested translation keys using options.keyseparator, whose default value consists of two number signs, and uses each segment as a dynamic object key without rejecting __proto__, constructor, or prototype. When an application converts untrusted PO or i18next translation data, a __...
CVE-2026-90772	8.3	HIGH		0.002		Amundsen frontend through 4.3.0 renders table, dashboard, and feature descriptions with dangerouslySetInnerHTML without HTML sanitization in ResourceListItem components. Attackers can inject malicious markup like img elements with onerror handlers into descriptions via the metadata service or Elasticsearch, executing JavaScript in every user's browser that views search results.
CVE-2026-17467	8.2	HIGH				IBM Cloud Pak for Data System (Yosemite 1.0) 3.0.5.2 could allow a remote attacker to obtain sensitive information due to the use of weak or deprecated cryptographic protocols.
CVE-2026-34151	8.2	HIGH				XWiki Platform is a generic wiki platform. Prior to 17.10.5 and 18.2.0, the /skin/ action in com.xpn.xwiki.web.SkinAction can resolve double-encoded parent-directory segments outside the intended skin or web-application resource prefix when Jetty 12 or later decodes the request path. The affected lookup is replaced with Environment.getResourceAsStream(String, String), which constrains a resource to its expected pr...
CVE-2026-57577	8.2	HIGH				DotVVM is an open source MVVM framework for web applications. Prior to 4.2.11, 4.3.15, and 5.0.0-preview09-final, a route containing multiple unconstrained parameters in one path segment can cause excessive regular-expression backtracking in DotvvmRoute.IsMatch when a remote requester supplies a long near-match path. DotvvmRouteParser.RouteRegex previously had no matching timeout. Patched runtimes retry with the
CVE-2026-85921	8.2	HIGH				Double free in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-89554	8.2	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: mptcp: fix uninitialized local_id in syncookie MP_JOIN reconstruction mptcp_token_join_cookie_init_state() restores remote_nonce, local_nonce, backup, join_id, token and msk from the saved cookie entry when rebuilding the request socket for a MP_JOIN 4th-ACK handled under SYN cookies, but it does not restore local_id, even though the SYN path sa...
CVE-2026-89586	8.2	HIGH		0.005		In the Linux kernel, the following vulnerability has been resolved: ata: libata-scsi: fix DSM TRIM for sector sizes larger than 2048 bytes ata_scsi_write_same_xlat() translates a SCSI WRITE SAME command with the UNMAP bit set into an ATA DATA SET MANAGEMENT TRIM command. The TRIM descriptor is built by ata_format_dsm_trim_descr() into the 2048-byte ata_scsi_rbuf staging buffer, and the number of bytes copied is...
CVE-2026-89665	8.2	HIGH		0.005		In the Linux kernel, the following vulnerability has been resolved: nfsd: reject out-of-range useconds in NFSv2 SETATTR/CREATE The NFSv2 sattr decoder converts the wire useconds to nanoseconds in svcxdr_decode_sattr(): iap->ia_atime.tv_nsec = tmp2 * NSEC_PER_USEC; tmp2 is a u32 and NSEC_PER_USEC is 1000, so the product is computed in unsigned long. On ILP32 that is 32 bits, and an out-of-range useconds value ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89711	8.2	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: NFSD: remove flawed WARN_ON_ONCE from nfsd_mode_check The header for commit e75b23f9e323 ("nfsd: check d_can_lookup in fh_verify of directories") details the assumption that justified adding the WARN_ON_ONCE to nfsd_mode_check(), that assumption is invalid (in the case of NFS reexport). When NFSD exports an NFS filesystem it is very possible fo...
CVE-2026-16335	8.1	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage could allow a remote authenticated attacker to read, write, or delete arbitrary files due to a path traversal vulnerability.
CVE-2026-37008	8.1	HIGH		0.001		CrewAI before fb2323b offers a Python blocklist approach that operates at the wrong level of abstraction, a different vulnerability than CVE-2026-2275. Import-time blocking of module names does not address the availability of Python's complete object graph. For example, calling ctypes.CDLL(None) loads the C library without relying in any import statements. In other words, a within-process sandbox cannot merely acc...
CVE-2026-53178	8.1	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: rtw_mlme: add bounds checks before ie_length subtraction Add guards to ensure ie_length is large enough before subtracting fixed IE offsets to prevent unsigned integer underflow.
CVE-2026-80354	8.1	HIGH		0.002	apache:camel	Authorization bypass through User-Controlled key vulnerability in Apache Camel K. An authorization vulnerability in custom resource resolution allows a tenant to reference secrets by name in the operator namespace, potentially exposing secrets belonging to other tenants or operator components. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users are recommended to u...
CVE-2026-81003	8.1	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: net/iucv: filter frames in afiucv_hs_rcv() by ingress device afiucv_hs_rcv() selects a socket from iucv_sk_list by matching four 8-byte name fields in the transport header alone. No check is made against the net_device the frame arrived on. This can cause a frame arriving on any netdev to be delivered to an AF_IUCV socket. Three problems follow...
CVE-2026-82432	8.1	HIGH				Description Nimbus validated `topology.blobstore.map` against the calling subject at submission time only. The rebalance operation accepts configuration overrides and stripped a small set of keys from them, but never re-ran that validation, so a caller authorised to rebalance a topology could introduce a blobstore map entry naming a blob whose ACL does not grant them access. Supervisors localise whatever key the ...
CVE-2026-82438	8.1	HIGH				Description Three separate mechanisms allowed a web page on an unrelated origin to read responses that Storm's HTTP components served to an authenticated user. The Logviewer reflected the request's `Origin` header back in `Access-Control-Allow-Origin` while also sending `Access-Control-Allow-Credentials: true`. The published security model documents a permissive `Access-Control-Allow-Origin: *` posture as accept...
CVE-2026-87016	8.1	HIGH		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.6.41 until 0.11.1, get_user_by_oauth_sub and get_user_by_scim_external_id in backend/open_webui/models/users.py used JSON contains matching that compiled to SQL LIKE substring matching on SQLite. An OAuth subject containing percent or underscore wildcard characters could resolve to a different stored identity, potentially ...
CVE-2026-87958	8.1	HIGH		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-89524	8.1	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: wifi: ath6kl: clamp assoc request/response lengths before subtracting IE offsets ath6kl_cfg80211_connect_event() subtracts fixed IE offsets from assoc_req_len (== 4) and assoc_resp_len (== 6), both u8, with no lower bound. The aggregate check recently added to ath6kl_wmi_connect_event_rx() bounds the declared lengths from above (their sum must f...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89547	8.1	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Check svc pool percpu counter allocation __svc_create() initializes three per-pool percpu_counter stats and ignores every return value. On SMP, percpu_counter_init() fails when __alloc_percpu_gfp() cannot satisfy the allocation, leaving the failed counter with fbc->counters == NULL and its embedded raw_spinlock_t, list_head, and count ne...
CVE-2026-89583	8.1	HIGH		0.003		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: eir: Fix OOB read in eir_get_service_data() eir_get_service_data() walks the advertising data for a Service Data field with a matching UUID. On a mismatch it advances: eir += dlen; eir_len -= dlen; eir_get_data() reports dlen as the field's data length, but the field spans dlen + 2 bytes once its length and type bytes count...
CVE-2026-90651	8.1	HIGH		0.002		Socket Firewall (socketdev/socket-registry-firewall) in registry mode before 2.0.0 does not verify upstream TLS certificates by default. When the api_ssl_verify and upstream_ssl_verify configuration keys are omitted from socket.yml, the generated configuration sets SOCKET_API_SSL_VERIFY='false' and UPSTREAM_SSL_VERIFY='false', and the OpenResty/Lua HTTP client used for outbound requests accepts any certificate, in...
CVE-2026-68834	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68838	8.0	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69332	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69505	8.0	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69826	8.0	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-83948	8.0	HIGH		0.004	microsoft:vm_repair	Improper neutralization of special elements used in a command ('command injection') in Microsoft Azure CLI allows an authorized attacker to execute code over a network.
CVE-2026-87888	8.0	HIGH		0.002		The YayPricing WordPress plugin before 3.5.7 does not perform an authorization check on a REST route that saves its pricing rules, allowing users with the subscriber role and above to store JavaScript that executes in the browser of an administrator who opens the YayPricing WordPress plugin before 3.5.7's settings page.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2024-35887	7.8	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ax25: fix use-after-free bugs caused by ax25_ds_del_timer When the ax25 device is detaching, the ax25_dev_device_down() calls ax25_ds_del_timer() to cleanup the slave_timer. When the timer handler is running, the ax25_ds_del_timer() that calls del_timer() in it will return directly. As a result, the use-after-free bugs could happen, one of the s...
CVE-2024-50029	7.8	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_conn: Fix UAF in hci_enhanced_setup_sync This checks if the ACL connection remains valid as it could be destroyed while hci_enhanced_setup_sync is pending on cmd_sync leading to the following trace: BUG: KASAN: slab-use-after-free in hci_enhanced_setup_sync+0x91b/0xa60 Read of size 1 at addr ffff888002328ffd by task kworker/u5:2/...
CVE-2025-39862	7.8	HIGH		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: fix list corruption after hardware restart Since stations are recreated from scratch, all lists that wcid's are added to must be cleared before calling ieee80211_restart_hw. Set wcid->sta = 0 for each wcid entry in order to ensure that they are not added again before they are ready.
CVE-2025-40123	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: bpf: Enforce expected_attach_type for tailcall compatibility Yinhao et al. recently reported: Our fuzzer tool discovered an uninitialized pointer issue in the bpf_prog_test_run_xdp() function within the Linux kernel's BPF subsystem. This leads to a NULL pointer dereference when a BPF program attempts to dereference the txq member of struc...
CVE-2026-17133	7.8	HIGH				IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-17156	7.8	HIGH				IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to insecure deserialization.
CVE-2026-17416	7.8	HIGH				IBM App Connect Enterprise 13.0.1.0 through 13.0.8.0, and 12.0.1.0 through 12.0.12.27 could allow a local attacker to execute arbitrary code due to insecure deserialization.
CVE-2026-23447	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: usb: cdc_ncm: add ndpoffset to NDP32 nframes bounds check The same bounds-check bug fixed for NDP16 in the previous patch also exists in cdc_ncm_rx_verify_ndp32(). The DPE array size is validated against the total skb length without accounting for ndpoffset, allowing out-of-bounds reads when the NDP32 is placed near the end of the NTB. Add...
CVE-2026-23448	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: usb: cdc_ncm: add ndpoffset to NDP16 nframes bounds check cdc_ncm_rx_verify_ndp16() validates that the NDP header and its DPE entries fit within the skb. The first check correctly accounts for ndpoffset: if ((ndpoffset + sizeof(struct usb_cdc_ncm_ndp16)) > skb_in->len) but the second check omits it: if (sizeof(struct usb_cdc_ncm_ndp...
CVE-2026-43502	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net/rds: handle zerocopy send cleanup before the message is queued A zerocopy send can fail after user pages have been pinned but before the message is attached to the sending socket. The purge path currently infers zerocopy state from rm->m_rs, so an unqueued message can be cleaned up as if it owned normal payload pages. However, zerocopy owne...
CVE-2026-46090	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ALSA: aloop: Fix peer runtime UAF during format-change stop loopback_check_format() may stop the capture side when playback starts with parameters that no longer match a running capture stream. Commit 826af7fa62e3 ("ALSA: aloop: Fix racy access at PCM trigger") moved the peer lookup under cable->lock, but the actual snd_pcm_stop() still runs aft...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53078	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bpf: Fix same-register dst/src OOB read and pointer leak in sock_ops When a BPF sock_ops program accesses ctx fields with dst_reg == src_reg, the SOCKOPS_GET_SK() and SOCKOPS_GET_FIELD() macros fail to zero the destination register in the !fullsock / !locked_tcp_sock path. Both macros borrow a temporary register to check is_fullsock / is_lock...
CVE-2026-53098	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: fix use-after-free bugs in mt7915_mac_dump_work() When the mt7915 pci chip is detaching, the mt7915_crash_data is released in mt7915_coredump_unregister(). However, the work item dump_work may still be running or pending, leading to UAF bugs when the already freed crash_data is dereferenced again in mt7915_mac_dump_work(). T...
CVE-2026-53250	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: xsk: cache csum_start/csum_offset to fix TOCTOU in xsk_skb_metadata() The TX metadata area resides in the UMEM buffer which is memory-mapped and concurrently writable by userspace. In xsk_skb_metadata(), csum_start and csum_offset are read from shared memory for bounds validation, then read again for skb assignment. A malicious userspace applica...
CVE-2026-58611	7.8	HIGH		0.002	microsoft:xbox_gaming_services	Improper authorization in Xbox Gaming Services allows an authorized attacker to elevate privileges locally.
CVE-2026-62721	7.8	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Insufficient granularity of access control in User-Mode Power Service (UMPS) allows an authorized attacker to elevate privileges locally.
CVE-2026-64031	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: erofs: fix managed cache race for unaligned extents After unaligned compressed extents were introduced, the following race could occur: [Thread 1] [Thread 2] (z_erofs_fill_bio_vec) <handle a Z_EROFS_PREALLOCATED_FOLIO folio> ... filemap_add_folio (1) (z_erofs_bind_ca...
CVE-2026-64058	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfs: Fix netfs_read_folio() to wait on writeback Fix netfs_read_folio() to wait for an ongoing writeback to complete so that it can trust the dirty flag and whatever is attached to folio->private (folio->private may get cleaned up by the collector before it clears the writeback flag).
CVE-2026-68832	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68841	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68875	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69265	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69293	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69312	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69421	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer underflow (wrap or wraparound) in Windows Kernel Mode Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69475	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Untrusted pointer dereference in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69532	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69738	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72255	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_queue: pin bridge device while NFQUEUE holds fake dst The br_netfilter fake rtable is embedded in struct net_bridge and is attached to bridged packets with skb_dst_set_noref(). If such a packet is queued to NFQUEUE, __nf_queue() upgrades that fake dst with skb_dst_force(). At that point the queued skb can hold a real dst reference...
CVE-2026-72991	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-74334	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: RDMA/nldev: Fix locking when accessing mr->pd Sashiko points out that, due to rereg_mr, the PD is actually variable and all the touches in nldev are racy. Use mr->device instead of mr->pd->device. Getting the PD restrack ID is more tricky. To avoid disturbing all the happy paths, add an rdma_restrack_sync() operation which is sort of like flus...
CVE-2026-74371	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: bpf: fix BPF_PROG_QUERY OOB write and cgroup backward compat BPF_PROG_QUERY writes back the 'query.revision' field unconditionally to userspace. If userspace passes a smaller 'bpf_attr' structure (e.g. 40 bytes, which was the layout before the addition of 'query.revision'), the kernel performs an out-of-bounds write. Fix this by propagating the...
CVE-2026-74378	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: RDMA/rxe: Fix TOCTOU heap overflow in get_srq_wqe get_srq_wqe() reads wqe->dma.num_sge from the shared receive queue buffer, which is mapped into userspace. It validates num_sge against max_sge, but then re-reads the same field to calculate the memcpy size. A concurrent userspace thread can modify num_sge between validation and use, causing a he...
CVE-2026-74565	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_tables: make nft_object rhhtable per table The nft_object rhhtable is global, this allows for accessing objects that are being dismantled from lookup path by other existing netns. Given the nft_obj_destroy() releases the object immediately, this might lead to use-after-free of these objects that are being released. Make the existin...
CVE-2026-75631	7.8	HIGH		0.002	adobe:photoshop, apple:macos, microsoft:windows	Photoshop Desktop is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80928	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: smack: fix cred UAF in smack_file_send_sigiotask() When inspecting the credentials of another task, objective credentials (->real_cred, accessed with __task_cred()) must always be used. Accessing ->cred on a non-current task is forbidden unless that task is being created or destroyed; a task is allowed to change its own ->cred pointer with no s...
CVE-2026-80931	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: w1: ds28e17: reject an oversize length on an I2C block read w1_f19_i2c_master_transfer() is the master_xfer for the DS28E17 1-Wire to I2C bridge. On an I2C_M_RECV_LEN read, it takes the length from the device. The downstream slave puts a length byte in buf[0]. The driver then reads that many bytes into buf[1] with w1_f19_i2c_read(). buf[0] is c...
CVE-2026-80933	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: validate default EEPROM firmware size The default EEPROM firmware is parsed and copied as a full EEPROM without checking its length. A truncated file can make the driver read beyond the firmware buffer during variant validation or the fallback copy. Reject files shorter than MT7996_EEPROM_SIZE before parsing or copying the f...
CVE-2026-80944	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: wifi: mwifiex: Detach sync cmd buffer on interrupted wait mwifiex synchronous commands keep the caller-provided data buffer in cmd_node->data_buf. Several callers pass stack-allocated objects there. If wait_event_interruptible_timeout() is interrupted, the caller can return and release that stack object while the firmware command is still the c...
CVE-2026-80952	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: i3c: master: Fix info leak and UAF in device unregister path i3c_master_unregister_i3c_devs() clears i3cdev->dev->desc before calling device_unregister(). During device_unregister(), device_del() emits a KOBJ_REMOVE uevent and unbinds the driver while the device descriptor is still expected to be valid. As a result, i3c_device_uevent() and a r...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80971	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: bcd2000: clear the URB pointers on disconnect bcd2000_free_usb_related_resources() frees both URBs and leaves the pointers behind: usb_kill_urb(bcd2k->midi_out_urb); usb_kill_urb(bcd2k->midi_in_urb); usb_free_urb(bcd2k->midi_out_urb); usb_free_urb(bcd2k->midi_in_urb); The rawmidi device outlives that call. A substream that is still...
CVE-2026-80977	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: net: skbuff: don't touch shared zerocopy state in skb_tx_error() skb_tx_error() completes the zerocopy uarg and clears SKBFL_ALL_ZEROCOPY, and skb_zcopy_downgrade_managed() clears SKBFL_MANAGED_FRAG_REFS. Both live in skb_shinfo(), which every clone shares, while the caller only owns the reference it is about to drop. Through a clone it tells th...
CVE-2026-80978	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: net: cap advertised IP tunnel headroom IP tunnel devices derive their advertised needed_headroom from lower output devices. A stack of user-created devices can make the derived value larger than the 16-bit skb header offsets can represent. Once IP output reserves it, skb head expansion can wrap those offsets. The runtime transmit path already c...
CVE-2026-80979	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: net/smc: unregister the connection before draining the rx tasklet smc_conn_free() calls smc_ism_unset_conn() only while the link group is still on its device list, and never sets conn->killed. smc_lgr_terminate_sched() unlinks the group immediately and defers killing its connections to a work item, so a connection freed in that window keeps its ...
CVE-2026-80982	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: net/smc: fix use-after-free in smc_rx_pipe_buf_release() smc_rx_splice() hands RMB pages to a pipe and takes a socket reference per entry so the smc_sock stays alive until the reader finishes. The connection does not: a concurrent close runs smc_conn_free(), which releases the receive buffer back to the link group pool. smc_rx_pipe_buf_release(...
CVE-2026-80992	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: net: ravb: avoid dereferencing an invalid PTP clock The PTP clock is unavailable before the first open, so querying its index can dereference a NULL pointer. Registration failures can also leave an error pointer in priv->ptp.clock. Cache the PHC index separately and report -1 while no clock is registered. Normalize registration errors to NULL a...
CVE-2026-80994	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: net: openvswitch: fix flow mask use-after-free on flow deletion The commit in the Fixes tag below made so flow->mask free is scheduled via RCU right after it is removed from the flow table. The pointer stays in the flow structure and it can be accessible while in the same RCU critical section. This is done to avoid requiring ovs_mutex for the ...
CVE-2026-81000	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: net: tun: bound receive headroom tun_get_user() uses tun->align both as skb headroom and when choosing how much packet data to keep linear. OVS can propagate an oversized headroom request from another port to TUN or TAP. When align is larger than the usable space in a one-page skb head, SKB_MAX_HEAD(align) underflows and the result becomes nega...
CVE-2026-81001	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: slip: fix use-after-free in sl_sync() slip_devs[] stores bare net_device pointers and takes no reference on them. sl_sync() and sl_alloc() walk that table from slip_open() under rtnl_lock(), while an entry is dropped by sl_free_netdev(), which sl_setup() installs as dev->priv_destructor. priv_destructor is called from netdev_run_todo(), which ...
CVE-2026-81008	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: interconnect: Fix use after free in icc_get() and of_icc_get_by_index() In of_icc_get_by_index() and icc_get(), if the dynamic allocation for path->name fails via kasprintf(), the error handling path directly calls kfree(path) to free the path object and returns an error. However, prior to this point, path_find() calls path_init(), which ahead...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81010	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: io_uring/waitid: honor task_work cancellation io_waitid_cb() may run through the fallback task_work path when task_work_add() can no longer queue work to the originating task. The fallback runs from a kworker and io_uring marks such task work as canceled through tw.cancel. io_waitid_cb() currently ignores tw.cancel and calls __do_waitid(). waitid...
CVE-2026-82427	7.8	HIGH				Description A topology's `topology.blobstore.map` lets the submitter choose a local name for each blob that the supervisor localises. That name was used to build a path under the topology's working directory without normalisation, in both `AsyncLocalizer` and `Container.createBlobstoreLinks`, and the symlink helper force-deletes whatever already exists at the target before creating the link. A submitter could th...
CVE-2026-82429	7.8	HIGH				Description The setuid-root `worker-launcher` binary adjusts ownership and permissions of worker directories by walking the tree with FTS and calling `lchown` and `chmod` on each entry's full pathname while running with an effective uid of 0. Both syscalls re-resolve the path at the time of the call, after FTS has classified the entry, and the trees being walked are owned and writable by the untrusted topology us...
CVE-2026-82430	7.8	HIGH				Description When launching a Docker or OCI worker, the setuid-root `worker-launcher` first changes ownership of the entire worker directory to the untrusted topology user, and only afterwards reads and acts on the command file that the supervisor wrote into that same directory. The file is opened without `O_NOFOLLOW` and without re-verifying its owner, so between the ownership change and the read the tenant can r...
CVE-2026-85892	7.8	HIGH				Concurrent execution using shared resource with improper synchronization ('race condition') in Microsoft Edge (Chromium-based) allows an authorized attacker to elevate privileges locally.
CVE-2026-89440	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: mmc: via-sdmmc: stop card-detect handling on probe failure request_irq() registers the SD card-detect interrupt and the probe enables it before mmc_add_host() runs. If mmc_add_host() fails, the error path only unmaps the registers and returns: the interrupt stays registered, so the handler keeps running against the host once it is freed. via_sdc...
CVE-2026-89442	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate socket ID in clos_assoc ioctl isst_if_clos_assoc() validates the user-supplied socket_id with 'socket_id > topology_max_packages()', but isst_common.sst_inst[] is allocated with topology_max_packages() entries, so the valid index range is [0, topology_max_packages()). The '>' comparison lets socket_id == topology_ma...
CVE-2026-89487	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: openvswitch: only skb_tx_error() a packet we are about to drop queue_userspace_packet() borrows the packet skb -- it only copies it into a private netlink message (user_skb) and does not own it; on return do_execute_actions() keeps forwarding it through the flow's remaining actions. Its error path nevertheless calls skb_tx_error(skb), which via ...
CVE-2026-89488	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: openvswitch: Fix CT limit teardown use-after-free Packet processing uses CT limit state under RCU, while netns teardown frees that state under ovs_mutex. The CT limit pointer was neither removed from readers nor protected by a grace period, allowing packet processing to dereference the freed state. An unprivileged user can trigger this bug from...
CVE-2026-89489	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: openrisc: fix arbitrary kernel memory access via or1k_atomic syscall sys_or1k_atomic() (syscall 244 in the "or1k" ABI) takes two user pointers, v1 and v2, and swaps the words they point to in hand-written assembly. l.lwz r29,0(r4) l.lwz r27,0(r5) l.sw 0(r4),r27 l.sw 0(r5),r29 The pointers are not checked with access_o...
CVE-2026-89497	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: orangefs: skip leading spaces before parsing client debug masks orangefs_prepare_cdm_array() sizes each client debug keyword buffer with strcspn(cds_head, " "), but then parses the keyword with %s. The %s conversion skips leading whitespace, while strcspn() does not. If a client debug entry starts with a space, the allocation can be sized for a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89508	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: RDMA/ucma: Lock the handler in ucma_set_ib_path() ucma_set_ib_path() calls ucma_event_handler() straight from the write() path, without the handler lock that keeps ctx->file stable while a uevent is queued. The handler re-reads ctx->file for every dereference: mutex_lock(&ctx->file->mut); /* file A */ list_add_tail(&uevent->list, &ctx->fil...
CVE-2026-89510	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: RDMA/cxgb4: Cancel reg_work before freeing device on remove c4iw_uld_state_change() queues reg_work to register the RDMA device. c4iw_remove() can free ctx->dev while this work is pending or running, leaving c4iw_register_device() accessing the freed device. Cancel reg_work before removing the device. The registration work can tear down ctx->d...
CVE-2026-89540	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: sunrpc: init gssp_lock before publishing proc entry create_use_gss_proxy_proc_entry() publishes /proc/net/rpc/use-gss-proxy via proc_create_data() before init_gssp_clnt() runs mutex_init() on sn->gssp_lock. Once the dentry is linked under proc_subdir_lock it is immediately reachable from userspace, so a write that lands in the window drives set...
CVE-2026-89548	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: SUNRPC: always drain cache_cleaner before destroying a cache_detail sunrpc_destroy_cache_detail() only cancels the global cache_cleaner delayed_work when cache_list is empty. During per-netns teardown cache_list is never empty because init_net's caches remain registered, so the cancel never fires. After unlink, the caller proceeds to cache_des...
CVE-2026-89553	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: nouveau/gem: reserve the bo in the info ioctl around the vma lookup In the non-uvmm path, there could be a race between the info lookup finding the vma, and the gem close path closing the vma leading to a use-after-free. Spotted with the help of Opus 4.6.
CVE-2026-89557	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: md: do overflow check for sb->bblog_shift in super_1_load() In super_1_load(), sb->bblog_shift is an __u8 type value loaded from on- disk superblock. It is used for badblocks API badblocks_set() by the following sequence, 1930 rdev->badblocks.shift = sb->bblog_shift; 1931 for (i = 0 ; i < (sectors << (9-3)) ; i++, bbp++) { 1932 ...
CVE-2026-89559	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: libnvdimm/labels: Prevent integer overflow in __nd_label_validate() The on-media namespace index field nslot is a u32 read from the DIMM label storage area. __nd_label_validate() bounds it against the config area size, but sizeof_namespace_label() returns unsigned, so the product nslot * label_size is evaluated in 32-bit and wraps modulo 2^32 b...
CVE-2026-89562	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ip6gre: fix hardware header length for NBMA tunnels ip6gre_tnl_link_config_route() accumulates the lower device's hardware header length into dev->hard_header_len whenever header_ops is set. This is incorrect for both users of header_ops. ip6gretap and ip6erspan have a fixed Ethernet hardware header length. For an NBMA ip6gre tunnel, ip6gre_he...
CVE-2026-89563	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ip6_tunnel: use skb_cow_head() in ip6_tnl_xmit() ip6_tnl_xmit() may need to expand headroom before it can push the outer IPv6 and optional encap headers. It currently does that with skb_realloc_headroom(), copies skb->sk ownership, consumes the original skb, and then continues processing with the replacement skb kept only in its local variable. ...
CVE-2026-89573	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: dm array: reject an array block whose value size is not the caller's array_block_check() can only compare the header against itself, so a block with value_size 4 and max_entries 1018 is internally consistent and passes. dm-cache keeps two arrays -- mappings at 8 bytes and hints at 4 -- and the roots for both live in the superblock. Point the map...
CVE-2026-89579	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: bpf: Harden bloom filter sizing and indexing on 32-bit kernels bloom_map_alloc() has two 32-bit-specific problems when the computed bitmap reaches the U32_MAX fallback case. First, BITS_TO_BYTES(U32_MAX) is evaluated with 32-bit arithmetic. The addition performed by DIV_ROUND_UP wraps, so the map allocates only the fixed-size bloom filter objec...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89585	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: auxdisplay: charlcd: cancel backlight work on registration failure With CONFIG_CHARLCD_BL_FLASH, charlcd_init() schedules bl_work before charlcd_register() calls misc_register(). If registration fails, the caller frees the charlcd object while delayed work still contains its address. Add charlcd_deinit() to cancel the delayed work and turn the ...
CVE-2026-89587	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ACPI: pfr_update: fix stack buffer overflow in query_capability() query_capability() copies four ACPI buffer objects returned by the firmware _DSM into fixed-size u8[16] fields in struct pfru_update_cap_info using memcpy with the firmware-supplied length: memcpy(&cap_hdr->code_type, elements[CAP_CODE_TYPE_IDX].buffer.pointer, ...
CVE-2026-89594	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: hsi: omap_ssi_core: fix missing DMA mask setup for SSI controller device The OMAP SSI driver uses a synthetic HSI controller device allocated via hsi_alloc_controller(), which does not go through the normal OF/platform device initialization path. As a result, the embedded struct device does not have a DMA mask initialized by default. After rec...
CVE-2026-89597	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: fbdev: uvesafb: unregister connector callback on init failure uvesafb_init() registers the v86d connector callback before registering the platform driver. If platform_driver_register() fails, the function returns the error directly and leaves the connector callback registered. The later platform-device failure path already unregisters the callb...
CVE-2026-89605	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ecryptfs: release message context on send failure ecryptfs_send_message_locked() moves a message context from the free list to the allocated list before sending the request to the userspace daemon. If ecryptfs_send_misccdev() fails, the context is left on the allocated list and cannot be reused. Move it back to the free list on failure and clear...
CVE-2026-89606	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ecryptfs: reject too-small tag 70 packets ecryptfs_parse_tag_70_packet() subtracts fixed metadata fields from the parsed packet body size to derive the encrypted filename size. A malformed packet with a body smaller than those fixed fields can underflow that size calculation. Reject tag 70 packets before the subtraction unless the body contain...
CVE-2026-89607	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ecryptfs: reject oversized encrypted_key_size in parse_tag_3_packet parse_tag_3_packet() set encrypted_key_size from the Tag 3 packet body without bounding it against ECRYPTFS_MAX_KEY_BYTES (64). When encrypted_key_size > 64, decrypt_passphrase_encrypted_session_key() sets decrypted_key_size = encrypted_key_size and performs two out-of-bounds wr...
CVE-2026-89609	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ecryptfs: hold msg ctx list lock when cleaning daemon queue ecryptfs_exorcise_daemon() drops queued messages from a dying daemon without holding ecryptfs_msg_ctx_lists_mux, but ecryptfs_msg_ctx_alloc_to_free() requires that lock. Take the list lock while moving the queued contexts back to the free list to avoid racing with other global msg ctx ...
CVE-2026-89617	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate dirty page table on log replay Each DIR_PAGE_ENTRY ends in a page_lcn[] array whose length is the on-disk lcn[] follow field. check_rstbl() validates the table bookkeeping but never checks that this array fits in the entry, so a crafted lcn[] follow lets the v0->v1 conversion memmove and later replay passes run off the entry. ...
CVE-2026-89723	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: nilfs2: fix slab-out-of-bounds in nilfs_direct_propagate after truncation Shuangpeng Bai reported that KASAN detected a slab-out-of-bounds error in nilfs_direct_propagate() during testing. Analysis revealed that after truncating a file, a node block immediately below the B-tree root was not deleted. Instead, it remained in the B-tree node cach...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89724	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: media: vicodec: fix out-of-bounds write in FWHT encoder vidioc_s_fmt_vid_out() sizes the encoder CAPTURE buffer from the compressed descriptor pixfmt_fwht, whose sizeimage_mult is 3: coded_w * coded_h * 3 + sizeof(struct fwht_cframe_hdr). fwht_encode_frame() encodes one plane per component, and an incompressible plane takes the FWHT_FRAME_UNENCO...
CVE-2026-89733	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: usb: gadget: uvc: fix dangling pointers in uvc_function_bind() and uvc_function_unbind() In uvc_function_bind() error path, we use usb_ep_free_request which uses uvc->control_req but does not set it to NULL afterwards. Thus, uvc->control_req is a dangling pointer causing a UAF. Also we do not set the uvc->control_buf pointer to NULL after freein...
CVE-2026-89736	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: usb: gadget: u_audio: Fix use-after-free on sound card disconnect g_audio_cleanup() invokes snd_card_free_when_closed() to initiate sound card teardown and immediately frees the underlying struct snd_uac_chip context. However, snd_card_free_when_closed() returns asynchronously while ALSA control elements (kctls) remain open in userspace. When u...
CVE-2026-89741	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: Revert "media: v4l2-dev: fix error handling in __video_register_device()" This reverts commit 2a934fdb01db6458288fc9386d3d8ceba6dd551a. The intentions of that patch were good, but it doesn't work. The idea is that if device_register fails, you have to do a put_device to let the ref counter release resources. However, the V4L2 API says that if...
CVE-2026-89742	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: rapidio: mport_cdev: fix use-after-free in dma_req_free() dma_req_free() acquires buf_mutex through req->map, drops the mapping reference with kref_put(), and then dereferences req->map again to unlock the mutex. If kref_put() drops the last reference, mport_release_mapping() frees the mapping, and the subsequent mutex_unlock() dereferences a f...
CVE-2026-89746	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: tracing: Fix use-after-free with same-name named triggers When two hist triggers on different events are registered with the same name=, the second one reuses the first as named_data. Both are added to tr->hist_vars by save_hist_vars() during event_hist_trigger_parse(), because save_hist_vars() is called before event_trigger_register() while th...
CVE-2026-89750	7.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: tracing/user_events: Clear copied tracing state before fork duplication dup_task_struct() copies user_event_mm from the parent into the child, without grabbing a reference to it. user_event_mm_dup() should replace it, but it leaves that copied pointer unmodified if user_event_mm_alloc() fails. When the child exits, user_event_mm_remove() decrem...
CVE-2026-16432	7.7	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 IBM DataStage PxXMLInput operator could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection.
CVE-2026-29811	7.7	HIGH		0.003		CyberPanel before 2.4.4 attempts to detect an "alais" domain (i.e., a second domain that serves the same content as a primary domain; normally spelled "alias") via an ORM query filter rather than a Python "if" statement.
CVE-2026-45794	7.7	HIGH				Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, the anonymous Push Notification SNS callback handled by SnsMessageResource falls back to a CTS predicate blob after a messageId expires from the in-memory dispatcher, treats top-level blob keys as Java class names for Class.forName, and deserializes attacker-controlled JSON through Jackson. A low-privileged user who starts Push Regi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47701	7.7	HIGH				The OpenTelemetry Operator is a Kubernetes Operator for the OpenTelemetry Collector. Prior to 0.152.0, cmd/otel-allocator TargetAllocator instances with targetAllocator.prometheusCR.enabled set to true preserve a selected ServiceMonitor endpoint's bearerTokenFile value as HTTPClientConfig.Authorization.CredentialsFile. A tenant who can create or update a ServiceMonitor matched by serviceMonitorSelector and service...
CVE-2026-54155	7.7	HIGH				node-opcua is an OPC UA implementation for TypeScript and Node.js. Prior to 2.166.0, the UserNamelIdentityToken authentication handler in packages/node-opcua-server/source/opcua_server.ts decrypts an RSA-OAEP password blob but does not verify that the trailing bytes match the current session serverNonce. An unauthenticated remote attacker can obtain the server public key through GetEndpoints and forge a blob whose ...
CVE-2026-55253	7.7	HIGH				LangChain MongoDB provides integrations between MongoDB, Atlas, LangChain, and LangGraph. Prior to langgraph-checkpoint-mongodb 0.3.0 and langgraph-store-mongodb 0.4.0, MongoDBSaver.list(), MongoDBSaver.alist(), and MongoDBStore.search() incorporate filter dictionaries into MongoDB queries without recursively rejecting keys prefixed with \$. An authenticated caller who controls a filter argument through HTTP query ...
CVE-2026-73496	7.7	HIGH				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). Prior to 0.22.0, the confluence_upload_attachment and confluence_upload_attachments tools pass a client-controlled file_path through src/mcp_atlassian/confluence/attachments.py upload_attachment, and the jira_update_issue_attachments parameter reaches src/mcp_atlassian/jira/attachments.py upload_attachment, without...
CVE-2026-89466	7.7	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: power: supply: qcom_battmgr: terminate the strings from firmware The qcom_battmgr_sc8280xp_strcpy() takes a Pascal-style string when the firmware sends one. Otherwise it copies all BATTMGR_STRING_LEN bytes and leaves the destination without a terminator. Those destinations are model_number, serial_number and oem_info, each BATTMGR_STRING_LEN an...
CVE-2026-89720	7.7	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ubifs: fix out-of-bounds read in signature length check ubifs_sb_verify_signature() bounds the on-disk ubifs_sig_node->len field before handing the signature payload to verify_pkcs7_signature(), but the check has the wrong sign: if (le32_to_cpu(signode->len) > snod->len + sizeof(struct ubifs_sig_node)) The signature bytes start sizeof(struct ...
CVE-2026-54087	7.6	HIGH				EasyAdmin is a fast and modern admin generator for Symfony applications. From 5.0.0 until 5.0.13, FileField and ImageField can accept browser-executable uploads while templates/crud/field/file.html.twig links to stored files for inline same-origin rendering without a download attribute or Content-Disposition attachment header. When uploads are stored under the public web root, an attacker with access to an affecte...
CVE-2026-15955	7.5	HIGH				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow a remote attacker to perform an arbitrary file write due to improper validation of file paths.
CVE-2026-19290	7.5	HIGH				IBM Sterling File Gateway 6.2.0.0 through 6.2.0.6_1, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 could allow a remote attacker to obtain sensitive information due to improper access control.
CVE-2026-34355	7.5	HIGH		0.012	apache:http_server	A buffer overflow in mod_proxy_html in Apache HTTP Server 2.4.67 and earlier allows an attack by an untrusted backend. Users are recommended to upgrade to version 2.4.68, which fixes this issue.
CVE-2026-42536	7.5	HIGH		0.01	apache:http_server	Heap-based Buffer Overflow vulnerability in Apache HTTP Server with mod_xml2enc, xml2StartParse, and untrusted content This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-50270	7.5	HIGH				dd-trace-java is a Datadog APM client for Java. Prior to 1.62.0, W3C baggage extraction does not enforce DD_TRACE_BAGGAGE_MAX_ITEMS, which defaults to 64, or DD_TRACE_BAGGAGE_MAX_BYTES, which defaults to 8192, although those limits apply during baggage injection. A remote unauthenticated attacker can send a baggage HTTP header containing many comma-separated key-value pairs or a single very large value. The extrac...
CVE-2026-53752	7.5	HIGH				docx4j is an open source Java library for creating, editing, and saving OpenXML packages, including DOCX, PPTX, and XLSX files. Prior to 11.5.14, PropertyResolver and adjacent helpers recursively follow the WordprocessingML w:basedOn style inheritance chain without cycle detection. A well-formed DOCX containing mutually based styles causes unbounded recursion in PropertyResolver.fillPPrStack and related effective-...
CVE-2026-54156	7.5	HIGH				node-opcua is an OPC UA implementation for TypeScript and Node.js. Prior to 2.166.0, the process-global g_alreadyUsedNonce cache used by nonceAlreadyBeenUsed in packages/node-opcua-secure-channel/source/server/server_secure_channel_layer.ts records nonces from OpenSecureChannelRequest and CreateSession without expiration or a size limit. An unauthenticated remote attacker can repeatedly create sessions with unique...
CVE-2026-54629	7.5	HIGH				Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, anyquery server exposes file-backed SQLite virtual table modules such as csv_reader and log_reader through its MySQL-compatible server port without authentication, authorization, or directory restrictions. A remote attacker can use SQLite CREATE VIRTUAL TABLE statements to provide a local path to these modules, which use hashicorp/go-getter un...
CVE-2026-54632	7.5	HIGH				SIPSorcery is a WebRTC, SIP, and VoIP library for C# and .NET. Prior to 10.0.9, RTPChannel.OnRTTPacketReceived and the STUNAttribute.ParseMessageAttributes, STUNXORAddressAttribute, and STUNAddressAttribute parsing path index untrusted bytes without sufficient length checks, while UdpReceiver.EndReceiveFrom closes the channel when those operations raise a non-socket exception. A remote party can send a single shor...
CVE-2026-59960	7.5	HIGH				Argos JavaScript provides official Argos SDKs for JavaScript. Prior to Argos core package version 6.2.1, attacker-controlled CI branch or ref values from GITHUB_HEAD_REF or ARGOS_BRANCH can flow through config.branch and getMergeBaseCommitSha() when hasRemoteContentAccess is false. The gitFetch() and gitMergeBase() functions in packages/core/src/ci-environment/git.ts interpolate these values into execSync() comman...
CVE-2026-64210	7.5	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net/mlx5e: xsk: Fix unlocked writing to ICOSQ During napi poll, when the affinity changes and there's still XSK work to be done, we trigger an ICOSQ interrupt on the new CPU. However, this triggering on the ICOSQ is done unprotected. There are 2 such races: A) mlx5e_trigger_irq() is called while mlx5e_xsk_alloc_rx_mpwqe() is running from a dif...
CVE-2026-67211	7.5	HIGH		0.002		OOM Denial of Service via Unbounded Map Pre-Sizing in Apache OpenNLP SymSpellModelSerializer Versions Affected: - 3.0.0-M4 - 3.0.0-M5 (The opennlp-spellcheck extension was introduced in 3.0.0-M4. Releases 1.x and 2.x do not contain the affected code.) Description: The SymSpellModelSerializer.create() method reads two 32-bit signed integer count fields (unigramCount and bigramCount) from a binary SymSpell mod...
CVE-2026-69514	7.5	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69539	7.5	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69599	7.5	HIGH		0.007	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-73178	7.5	HIGH				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Apache Syncope. An administrator with adequate entitlements can get access via REST to the list of existing Access Tokens, including their signed JWT body. These values can be then used to perform further REST requests, impersonating users with higher administration entitlements. This issue affects Apache Syncope: from 3.0.0-M0 throu...
CVE-2026-73236	7.5	HIGH				Incorrect Authorization vulnerability in Apache Syncope. Delegated administration security checks are based on Realm hierarchy and enforced via prefix matches. Due to incorrect implementation, two sibling Realms whose names begin with the same string cannot be correctly distinguished, resulting in incorrect authorization. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Throug...
CVE-2026-76442	7.5	HIGH				As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco Secure Email Gateway and Cisco Secure Email and Web Manager engineering team has conducted a comprehensive internal security review. This review resulted in software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76442 are related to issues with impr...
CVE-2026-78336	7.5	HIGH				Insertion of sensitive information into sent data vulnerability in Apache Syncope. Any authenticated user can query for the list of available OIDC providers configured for SSO with Console and Enduser. The returned payload contains all configuration settings, including client secrets, regardless of the entitlements owned by the caller. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0...
CVE-2026-80229	7.5	HIGH		0.009	haxx:curl	When performing transfers via libcurl's multi interface, pooled TLS connections can outlive their originating easy handles. In OpenSSL 3 provider configurations, libcurl attaches an allocated library context to the easy handle's state and passes it to OpenSSL without acquiring an ownership reference; destroying the easy handle prematurely frees this context while the active connection retains a dangling pointer, l...
CVE-2026-80987	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: NTB: ntb_transport: Reject oversized TX buffers ntb_process_tx() handles an oversized buffer by calling tx_handler() with a NULL data pointer and returning success. ntb_netdev therefore neither frees the skb in its completion callback nor takes its enqueue error path, leaking it. Reject oversized buffers in ntb_transport_tx_enqueue() before acq...
CVE-2026-85189	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via executable URL schemes in Modals extension for Joomla < 17.0.0 - Modals treats a destination using an executable browser URL scheme as an ordinary modal URL. The value can reach both the generated link and the iframe-loading path. Authored content can consequently become JavaScript in a visitor's browser without using Modals' separate Pro JavaScript Ev...
CVE-2026-85191	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via rtaa-alias option in Tabs & Accordions extension for Joomla < 3.1.0 - Tabs & Accordions rewrites links matching an item alias into calls to its browser API. The affected renderer places the alias inside a quoted JavaScript argument in an HTML onclick attribute without securing both the JavaScript-string and HTML-attribute contexts. A crafted data-rtaa-...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86093	7.5	HIGH		0.005	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-87779	7.5	HIGH				Insertion of sensitive information into log file vulnerability in Apache Syncope. When AES key of non-standard length (not 16/24/32 bytes) is configured, Syncope will pad the provided value with random characters. The resulting key value is logged. This issue affects Apache Syncope: from 3.0.15 through 3.0.16, from 4.0.3 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended to upgrade to versi...
CVE-2026-88853	7.5	HIGH		0.002		Joomla Extension - regularlabs.com - Privileged stored XSS via event handler option in Modals Pro extension for Joomla < 17.0.0 - Modals Pro intentionally supports JavaScript Events such as on-open and on-closed. Affected versions do not distinguish trusted extension configuration from event code supplied in ordinary article content. A lower-privileged author can therefore use a documented executable feature which...
CVE-2026-89476	7.5	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: sctp: fix stream->outcnt underflow on duplicate RECONF responses A cached RECONF chunk may contain more than one request parameter. A duplicate response can therefore find and process the same ADD_OUT request again while another parameter is still outstanding, rolling back outcnt twice and possibly underflowing it. Track outstanding request ty...
CVE-2026-89477	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: sctp: fix NULL deref on untransmitted RECONF completion sctp_process_streset_outreq(), sctp_process_streset_addstrm_out() and sctp_process_streset_resp() complete a pending stream reconfiguration request by stopping the reconf timer on the transport it was sent on: t = asoc->streset_chunk->transport; if (timer_delete(&t->reconf_timer)) ...
CVE-2026-89480	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: reject a read that transferred too few bytes nvme_tcp_recv_data() completes a request once the current C2HData PDU has been consumed. Nothing compares the total bytes received against the length the command asked for: struct nvme_tcp_request has no receive-side counter, queue->data_remaining is per queue, and blk_mq_end_request() compl...
CVE-2026-89481	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nvme-tcp: fix host memory disclosure on R2T for a read command nvme_tcp_handle_r2t() does not check the direction of the request the R2T refers to. A malicious controller can send an R2T for a READ and the host will answer it: nvme_tcp_setup_h2c_data_pdu() builds the H2CData header and nvme_tcp_try_send_data() sends the request's data buffer. Th...
CVE-2026-89483	7.5	HIGH		0.005		In the Linux kernel, the following vulnerability has been resolved: nvme: zero the discard fallback page nvme_setup_discard() always maps sizeof(struct nvme_dsm_range) * NVME_DSM_MAX_RANGES = 4096 bytes as the DSM payload however many ranges the command declares, because some devices ignore the 'Number of Ranges' field - the Fixes: commit records two that read past the declared ranges. A single-range discard fil...
CVE-2026-89511	7.5	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: qede: Fix NULL pointer dereference in TPA fragment processing Under memory pressure, the qede driver encounters NULL pointer dereferences when processing TPA continuation fragments. Commit 8a8633978b84 ("qede: Add build_skb() support.") accidentally dropped the assignment of tpa_info->buffer.data in qede_tpa_start(). When memory pressure cause...
CVE-2026-89549	7.5	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: sunrpc: route to a populated pool in svc_pool_for_cpu() svc_set_num_threads() spreads the requested threads evenly across the service's pools (base = nrservs / sv_nrpoools). When a service runs fewer threads than it has pools -- e.g. an nfsd configured with fewer threads than the host has NUMA nodes while running in "pernode" or "percpu" mode --...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89616	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix info-leak on partial LZNT decompress in ni_read_frame() ni_read_frame() decompresses an LZNT \$DATA frame into the vmapped target pages and then trusts decompress_lznt()'s return value: unc_size = decompress_lznt(frame_ondisk, ondisk_size, frame_mem, frame_size); if ((ssize_t)unc_size < 0) er...
CVE-2026-89657	7.5	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: libceph: validate OSD extent maps before cursor advance net/ceph/osd_client.c:osd_sparse_read() validates that the sparse-read data length matches the summed extent lengths, but it does not validate that each OSD-supplied extent is monotonic and lies inside the original request range. A malformed authenticated OSD reply can advertise a far-forwa...
CVE-2026-89684	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix cpmf publish race in nfs4_init_cp_state nfs4_alloc_init_cpmf_state() published the new cpmf entry into the s2s_cp_stateids IDR (with cs_type set) in one s2s_cp_lock section, then took the lock again to list_add() it onto p_stid->sc_cp_list. In the gap the entry is reachable by so_id but cp_list is still {NULL,NULL} from kzalloc. A r...
CVE-2026-89696	7.5	HIGH		0.007		In the Linux kernel, the following vulnerability has been resolved: nfsd: block non-SAVEFH ops after FOREIGN PUTFH to prevent NULL deref When CONFIG_NFSD_V4_2_INTER_SSC is enabled, nfsd4_putfh() can return success with fh_dentry and fh_export both NULL if fh_verify() returns nfserr_stale and putfh->no_verify is true. The NFSD4_FH_FOREIGN flag is set, but the compound dispatch loop only uses this flag to bypass t...
CVE-2026-89699	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: validate symlink target length in NFSv4 CREATE nfsd4_decode_create() accepts an unbounded cr_data from the wire for NF4LNK symlink targets, allowing a client to force a kcalloc of up to the maximum RPC payload size (several MiB) per COMPOUND op that persists until compound teardown. The VFS rejects oversized targets with ENAMETOOLONG, ...
CVE-2026-89704	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: sample writeback error cursor before async COPY loop _nfsd_copy_file_range() samples dst->f_wb_err into "since" after the copy loop, then uses it to detect writeback errors via filemap_check_wb_err() once vfs_fsync_range() returns. Because the nfsd_file cache reuses a single struct file across requests targeting the same inode, a concurren...
CVE-2026-89706	7.5	HIGH		0.004		In the Linux kernel, the following vulnerability has been resolved: nfsd: Reset write verifier when async COPY writeback fails Async COPY captures nn->writeverf at request time and reports it to the client via CB_OFFLOAD after the worker kthread completes. When the post-copy vfs_fsync_range() or filemap_check_wb_err() in _nfsd_copy_file_range() reports an error, the worker correctly leaves NFSD4_COPY_F_COMMITTED...
CVE-2026-89707	7.5	HIGH		0.006		In the Linux kernel, the following vulnerability has been resolved: nfsd: release path refs on follow_down() error nfsd_cross_mnt() initializes a local struct path with mntget() and dget() before calling follow_down(). On a negative return the error arm jumps to out without releasing those references: err = follow_down(&path, follow_flags); if (err < 0) goto out; follow_down() never drops t...
CVE-2026-53714	7.4	HIGH				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, the xDS gRPC server in GatewayNamespaceMode, configured through provider.kubernetes.deploy.type=GatewayNamespace, installs a JWT StreamInterceptor but no UnaryInterceptor, leaving every unary Fetch RPC unauthenticated. The streaming interceptor also authenticates only ...
CVE-2026-73494	7.4	HIGH				blaze is a Scala library for building asynchronous pipelines, with a focus on network IO. Prior to 0.23.18 and from 1.0.0-M1 until 1.0.0-M42, five HTTP/1.1 conformance laxities in the hand-written Java parser under http/src/main/java/org/http4s/blaze/http/parser/ can cause blaze to derive a different request boundary than a stricter fronting intermediary. A default BlazeServerBuilder accepts invalid or valueless h...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-44185	7.3	HIGH		0.007	apache:http_server	Buffer Over-read vulnerability in Apache HTTP Server via outbound OSCP requests to an attacker controlled OSCP server This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.
CVE-2026-73195	7.3	HIGH				Improper Encoding or Escaping of Output vulnerability in Apache Syncope. Authenticated users can store a spreadsheet formula payload in one of their own plain attributes. When such users are included in a CSV export and the generated CSV file is opened by a spreadsheet application, the formula may be executed. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, fro...
CVE-2026-75092	7.3	HIGH				A privilege escalation flaw was found in the scan_mysql actor of leapp-upgrade-el9toel10 (provided by leapp-repository). During RHEL 9 to RHEL 10 upgrades, the actor runs: mysqld --validate-config --log-error-verbosity=2 directly as root in the Leapp actor context, bypassing the packaged MySQL systemd unit that normally starts the daemon as User=mysql. A process compromised as the mysql OS identity can write a ve...
CVE-2026-81901	7.2	HIGH				In Concrete CMS 9.2.0 through 9.5.2, the REST API page update endpoint (PUT /ccm/api/1.0/pages/{cID}) did not enforce page-property, page-template, or page-type authorization. A user granted only content-editing rights on a page could therefore alter its properties, template, and type through the API, and could set the header_extra_content attribute, which is rendered unescaped into the head element of every page,...
CVE-2025-22039	7.1	HIGH		0.007	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix overflow in dacloffset bounds check The dacloffset field was originally typed as int and used in an unchecked addition, which could overflow and bypass the existing bounds check in both smb_check_perm_dacl() and smb_inherit_dacl(). This could result in out-of-bounds memory access and a kernel crash when dereferencing the DACL pointer...
CVE-2026-12756	7.1	HIGH				IBM Business Automation Workflow containers and traditional is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-13107	7.1	HIGH				IBM Business Automation Workflow containers and traditional may use programming model artifacts that are vulnerable to XML Entity Injection attacks by default.
CVE-2026-13275	7.1	HIGH				IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 Managed File Transfer could allow an authenticated attacker to read arbitrary files or perform server-side request forgery due to XML external entity injection in reply message processing.
CVE-2026-13285	7.1	HIGH				IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-13287	7.1	HIGH				IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-19816	7.1	HIGH				A flaw was found in PackageKit. PackageKit skips the polkit authorization check for transactions carrying the SIMULATE (dry-run) flag. In the dnf5 backend, the RepoRemove handler ignores that contract and always executes the real transaction because its guard is written as (role == REPO_REMOVE !SIMULATE), which is always true for RepoRemove. An unprivileged local user can therefore perform a genuine package uni...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68893	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows Remote Desktop Licensing Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69340	7.1	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69366	7.1	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-69536	7.1	HIGH		0.004	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-81007	7.1	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: ipmi: ipmb: validate write message length ipmb_write() read message fields before validating the length byte. A zero or short write can read uninitialized stack bytes. A length smaller than the SMBus header underflows the block write length. Require a non-empty buffer and the minimum IPMB request length. Also require the length byte plus pay...
CVE-2026-81011	7.1	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: pass validated element count to package parsers The per-type package parsers are handed the wrong element count. hp_init_bios_package_attribute() validates obj->package.count and then calls one of the five hp_populate_*_package_data() wrappers (string, integer, enumeration, ordered list, password). Each wrapper forward...
CVE-2026-82076	7.1	HIGH		0.003	mongodb:mongodb	An integer overflow in the query planning component of MongoDB Server can allow an authenticated user with ordinary database-level read/write privileges to bypass an internal resource limit. Submitting a specially crafted query causes the server to consume memory without bound during query planning, and the resulting exhaustion terminates the server process. This may result in a denial of service affecting all dat...
CVE-2026-89443	7.1	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate level in perf mask ioctls isst_if_get_perf_level_mask() and isst_if_get_base_freq_mask() use the user-provided level as an index into perf_levels[] via _read_pp_level_info() and _read_bf_level_info(), but neither helper validates it first. The adjacent level-info helpers reject levels above max_level before reading ...
CVE-2026-89593	7.1	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: hugetlb: only adjust reservation during unmapping if mapcount is 0 Since df7a6d1f6405, __unmap_hugepage_range can adjust reservations. In the case of folio mapped in both a parent and a child, if the parent unmaps the range first, the reservation adjustment will result in an underflow of the reserved count. Once the child unmaps the range, the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89596	7.1	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: forcedeth: fix off-by-one when saving/restoring non-PCI config space nv_suspend() and nv_resume() walk the non-PCI configuration space with for (i = 0; i <= np->register_size/sizeof(u32); i++) which runs one iteration too many. saved_config_space is declared as u32 saved_config_space[NV_PCI_REGSZ_MAX/4]; and NV_PCI_REGSZ_VER3 is equal to N...
CVE-2026-89608	7.1	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: ecryptfs: pass packet set buffer size to parser ecryptfs_parse_packet_set() receives a pointer into the file header, but it calculates the remaining packet buffer size from PAGE_SIZE - 8. For version 1 headers the packet set starts later in the header, so this can overstate the available buffer. Pass the actual packet set buffer length from th...
CVE-2026-89640	7.1	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: cifs: fix loff_t underflow in cifs_remap_file_range() when len == 0 With len == 0 (clone to EOF), the effective length is computed as: len = src_inode->i_size - off; If off > i_size, this is a negative loff_t, corrupting the ByteCount in the FSCTL_DUPLICATE_EXTENTS_TO_FILE request and inverting the range in filemap_write_and_wait_range(). ...
CVE-2026-91145	7.1	HIGH				Activiti through 7.1.0.M6 fails to validate hash-brace deferred expressions in process variables, allowing attackers to bypass expression filtering. Attackers can inject expressions beginning with #{ that are stored and later evaluated in the full Spring context when a mail task uses variable-backed body fields, enabling method invocation on application beans.
CVE-2026-23191	7.0	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ALSA: aloop: Fix racy access at PCM trigger The PCM trigger callback of aloop driver tries to check the PCM state and stop the stream of the tied substream in the corresponding cable. Since both check and stop operations are performed outside the cable lock, this may result in UAF when a program attempts to trigger frequently while opening/closi...
CVE-2026-68884	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69287	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69379	7.0	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69466	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Time-of-check time-of-use (toctou) race condition in Windows Kernel allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69473	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69501	7.0	HIGH		0.002	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69567	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69578	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Numeric truncation error in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-76159	7.0	HIGH				Incorrect Permission Assignment for Critical Resource in the configuration loader of Duplicati for Windows versions before v2.4.0.0 allows a local low-privileged attacker to escalate privileges to NT AUTHORITY\SYSTEM via an attacker-controlled preload.json file.
CVE-2026-89456	7.0	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Propagate partial completion length across ERP recovery dasd_default_erp_postaction() copies the timing and device state from the finished ERP request back to the original request but drops proc_bytes. A request that was partially completed, an ESE read of a not-yet-allocated track returns fewer bytes than requested, and then recove...
CVE-2026-50025	6.9	MEDI		0.002		Mousehole is a background service to update a seedbox IP for MAM and web app to manage it. Prior to version 0.4.05, Mousehole's HTTP/WebSocket management boundary is reachable without application-layer authentication or browser/LAN provenance checks. The service stores a MyAnonamouse (MAM) session cookie in state and reuses the same cookie-bearing serialization for persisted state, public API responses, and WebSoc...
CVE-2026-90472	6.9	MEDI		0.003		msgpack-java through 0.9.12 contains a stack overflow vulnerability in MessageUnpacker.unpackValue() that recursively deserializes arrays and maps without nesting depth limits. Attackers can craft payloads with deeply nested arrays to exhaust the deserializing thread's stack and trigger StackOverflowError, causing per-request deserialization failures.
CVE-2026-90809	6.9	MEDI				A vulnerability was identified in HKUDS nanobot up to 0.2.1. The affected element is the function ExecTool._guard_command/ExecTool._spawn of the file nanobot/agent/tools/shell.py of the component ExecTool. Such manipulation leads to argument injection. It is possible to launch the attack remotely. The name of the patch is af582246f141311d574551b7571a517bcc3df750. It is best practice to apply a patch to resolve thi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90819	6.9	MEDI				A weakness has been identified in a2aproject a2a-java 1.2.0. The affected element is the function BasePushNotificationSender.dispatchNotification of the file server-common/src/main/java/org/a2aproject/sdk/server/tasks/BasePushNotificationSender.java of the component Authorization Header Construction. This manipulation causes http response splitting. The attack can be initiated remotely. Upgrading to version 1.3.0 ...
CVE-2025-24890	6.8	MEDI				gitoxide is an implementation of git written in Rust. Prior to 0.13.3, the gix-sec crate on Windows incorrectly treats repositories controlled by another user as trusted when an administrator runs a dependent program with an unfiltered elevated token. In gix-sec/src/identity.rs, gix_sec::identity::is_path_owned_by_current_user obtains folder_owner and token_owner, but its administrator-specific IsWellKnownSid and ...
CVE-2026-13265	6.8	MEDI				IBM MQ 9.1.0.0 through 9.1.0.37 LTS, 9.2.0.0 through 9.2.0.43 LTS, 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 CD, and 10.0.0.0 could allow an authenticated attacker with MFT publish authority to obtain sensitive information or cause a denial of service due to XML external entity injection in the mqweb MFT REST API.
CVE-2026-16726	6.8	MEDI		0.001		Buffer overflow vulnerability in Panasonic Industry USB Driver for MINAS A5/A6 allows attackers to stop Windows.
CVE-2026-53196	6.8	MEDI		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: USB: serial: io_ti: fix heap overflow in get_manuf_info() get_manuf_info() reads le16_to_cpu(rom_desc->Size) bytes from the device I2C EEPROM into a buffer allocated with kmalloc_obj(), which is sizeof(struct edge_ti_manuf_descriptor) = 10 bytes. The Size field comes from the device and is only validated (in check_i2c_image()) to make sure the ...
CVE-2026-68833	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-69566	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-12759	6.5	MEDI				IBM Cloud Pak for Business Automation could allow an authenticated user to cause a denial of service due to uncontrolled resource consumption.
CVE-2026-12765	6.5	MEDI				IBM Langflow OSS 1.0.0 through 1.10.2 is vulnerable to server-side request forgery (SSRF). This may allow an unauthenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-12767	6.5	MEDI				IBM Langflow OSS 1.0.0 through 1.11.5 is vulnerable to server-side request forgery (SSRF). This may allow an unauthenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-15396	6.5	MEDI				IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty are vulnerable to HTTP request smuggling, caused by improper parsing of the HTTP transfer-encoding request header. By sending a specially crafted HTTP transfer-encoding request header, an attacker could exploit this vulnerability to poison the web cache, bypass web application firewall protection, and conduct XSS attacks.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-15412	6.5	MEDI				IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty could allow a remote attacker to conduct phishing attacks, using an open redirect attack. By persuading a victim to visit a specially crafted Web site, a remote attacker could exploit this vulnerability to spoof the URL displayed to redirect a user to a malicious Web site that would appear to be trusted. This could allow t...
CVE-2026-15634	6.5	MEDI				IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty are vulnerable to HTTP request smuggling, caused by improper parsing of the HTTP transfer-encoding request header. By sending a specially crafted HTTP transfer-encoding request header, an attacker could exploit this vulnerability to poison the web cache, bypass web application firewall protection, and conduct XSS attacks.
CVE-2026-16187	6.5	MEDI				IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to bypass authentication and obtain sensitive information by sending a crafted unauthenticated request.
CVE-2026-16702	6.5	MEDI				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 for Linux, UNIX and Windows (includes DB2 Connect Server) could allow a remote authenticated attacker to cause a denial of service due to a null pointer dereference.
CVE-2026-17463	6.5	MEDI				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 for Linux, UNIX and Windows (includes DB2 Connect Server) could allow a remote authenticated attacker to cause a denial of service due to uncontrolled resource consumption.
CVE-2026-53716	6.5	MEDI				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, getFileFromGZ in internal/wasm/httpfetcher.go calls io.ReadAll on a gzip.Reader without limiting decompressed output when a tenant-controlled EnvoyExtensionPolicy.spec.wasm[].code.http.url points to a reachable compressed Wasm payload. The 256 MiB compressed-input cap ...
CVE-2026-53717	6.5	MEDI				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, internal/wasm/imagefetcher.go follows tenant-controlled EnvoyExtensionPolicy spec.wasm[].code.image.url values to Docker or OCI Wasm layers, and extractWasmPluginBinary uses the untrusted tar-header h.Size value to allocate memory before validating the entry name or de...
CVE-2026-53719	6.5	MEDI				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, translateSecurityPolicyForRoute in internal/gatewayapi/securitypolicy.go dereferences a nil authorization value when a namespace-scoped tenant creates a SecurityPolicy targeting a TCPRoute and omits spec.authorization. The persistent object triggers the panic on every ...
CVE-2026-54248	6.5	MEDI		0.002		Doco-CD is a GitOps continuous delivery tool that automatically deploys and updates Docker Compose projects/services and Swarm stacks. Prior to version 0.90.1, a trust-boundary flaw in OCI artifact verification allowed artifact-provided deployment config to influence the policy used to verify that same artifact. When global OCI signature verification was enabled via `OCI_TRUST_POLICY` (enabled: true), an attacke...
CVE-2026-54723	6.5	MEDI				devpi is a Python package index staging server and packaging, testing, and release tool. Prior to 6.20.2 and 7.0.0b3, a server configured with the primary or deprecated master role allows an unauthenticated, modified GET request to the +changelog route because verify_primary does not reject a missing identity and therefore fails to require Replicaidentity. The response can disclose complete database content, inclu...
CVE-2026-68570	6.5	MEDI				Incorrect Authorization vulnerability in Apache Doris allows an authenticated user to bypass privilege checks and access data they are not authorized to read, resulting in unauthorized disclosure of information. This issue affects Apache Doris: from 2.0.0 through 2.1.*, from 3.0.0 through 3.0.*, from 4.0.0 before 4.0.8, and from 4.1.0 before 4.1.4. Users are recommended to upgrade to a fixed release (4.0.8 o...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73497	6.5	MEDI				MCP Atlassian is a Model Context Protocol (MCP) server for Atlassian products (Confluence and Jira). From 0.17.0 until 0.22.0, validate_url_for_ssrf resolves the attacker-controlled X-Atlassian-Jira-Url and X-Atlassian-Confluence-Url header host once at middleware time, but the outbound request is built with the raw hostname and resolves it again at connection time with no IP pinning. An attacker-controlled DNS-re...
CVE-2026-77147	6.5	MEDI				Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Syncope. An administrator with adequate entitlements for Implementations can create a malicious Groovy Command class containing untrusted code in their CommandArgs static implementation, bypassing the Groovy security sandbox. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0...
CVE-2026-82426	6.5	MEDI				Description Nimbus accepted the `uploadedJarLocation` argument of `submitTopology` / `submitTopologyWithOpts` as a server-side path and opened it directly, without checking that it referred to a file the caller had actually uploaded. The intended flow is that a client first calls `beginFileUpload`, which returns a path inside the Nimbus inbox, and uploads the jar in chunks to that location; nothing bound submissi...
CVE-2026-82433	6.5	MEDI				Description `getNimbusConf` returned the complete daemon configuration without redaction after only a user-level authorization check. Where the cluster is configured with them, that response includes `storm.zookeeper.auth.payload` and the keystore and truststore passwords for the Thrift, Netty and ZooKeeper TLS configuration. The project masks passwords elsewhere before display, so the omission here is inconsiste...
CVE-2026-84179	6.5	MEDI				Description getTopologyPageInfo merged the Nimbus daemon configuration with the topology's own configuration and returned the result without redaction in the topology_conf field of TopologyPageInfo. The Storm UI copied that value verbatim into the configuration field of GET /api/v1/topology/{id} and of the corresponding metrics endpoint. Where the cluster is configured with them, the merged map includes stor...
CVE-2026-9336	6.5	MEDI		0.002		IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.
CVE-2025-11003	6.4	MEDI		0.002		The UiPress lite Effortless custom dashboards, admin themes and pages plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the 'uip_save_ui_template' function in all versions up to, and including, 3.5.09. This makes it possible for authenticated attackers, with Subscriber-level access and above, to save templates that contain custom JavaScript.
CVE-2026-16185	6.4	MEDI				IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to bypass authentication on an admin console servlet.
CVE-2026-4103	6.4	MEDI				Insufficient HTML sanitization in the Publisher Portal and Developer Portal allows untrusted user input to be rendered without proper encoding or neutralization. This enables the injection and execution of malicious JavaScript when affected API documents are viewed. Successful exploitation may result in the execution of malicious scripts within the user's browser context when viewing API documentation. Users with...
CVE-2026-53718	6.4	MEDI				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, an HTTPRoute can use an extension-managed custom backendRef to reference a backend resource in another namespace without a matching Gateway API ReferenceGrant in the target namespace. The custom-backend branch in internal/gatewayapi/route.go omits validateBackendNamesp...
CVE-2026-14275	6.3	MEDI				IBM i Access Family 1.1.2.0 through 1.1.9.15 IBM i Access Client Solutions could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a STRPCCMD CL command.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-14276	6.3	MEDI				IBM i Access Family 1.1.2.0 through 1.1.9.15 IBM i Access Client Solutions could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a malicious emulator macro RunProgram action.
CVE-2026-14277	6.3	MEDI				IBM i Access Family 1.1.2.0 through 1.1.9.15 could allow an authenticated user to execute arbitrary commands with normal user privileges on the system due to improper validation of user supplied input in a session file.
CVE-2026-19543	6.2	MEDI				IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 performs input validation exclusively on the client side and fails to enforce the same restrictions on the server side. An attacker can modify requests to bypass validation controls and submit unauthorized values, potentially resulting in unintended application behavior.
CVE-2026-55846	6.2	MEDI				Allure 2 is the version 2.x branch of Allure Report, a multi-language test reporting tool. Prior to 2.39.0, the HTTP server started by allure serve and allure open uses URI.getPath() in Commands.setUpServer() in allure-commandline/src/main/java/io/qameta/allure/Commands.java and passes the percent-decoded request path to reportDirectory.resolve() without normalizing the result or confirming that it remains inside ...
CVE-2026-55847	6.1	MEDI				Allure 2 is the version 2.x branch of Allure Report, a multi-language test reporting tool. Prior to 2.39.0, the ansi.js helper at allure-generator/src/main/javascript/helpers/ansi.js passes attacker-influenced statusMessage and statusTrace values through AnsiToHtml without HTML escaping and wraps the result in Handlebars SafeString, disabling template auto-escaping in allure-generator/src/main/javascript/blocks/st...
CVE-2026-62280	6.1	MEDI				Open Access Management (OpenAM) is an access management solution. From 13.0.0 until 16.1.2, the OAuth2 authorize endpoint's display=wap consent page reflects request-derived values through ConsentRequiredResource and wap/authorize.ftl without HTML escaping. An attacker can induce a user with an active OpenAM session to follow a crafted authorization link and execute JavaScript in the OpenAM origin, enabling sessio...
CVE-2026-73191	6.1	MEDI				URL Redirection to Untrusted Site ('Open Redirect') vulnerability in Apache Syncope. When the Syncope SRA is configured for CAS authentication, the target Apereo CAS instance's URL is calculated by unconditionally looking at client-supplied forwarded HTTP headers. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recommended ...
CVE-2026-78318	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache Syncope. The notification message, as optionally shown by Console's and Enduser's login pages can be instructed to display HTML tags with unsafe JS inline, via malicious HTTP link generation. This issue affects Apache Syncope: from 4.0.4 through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recomme...
CVE-2026-90534	6.1	MEDI		0.002		Flowise is a low-code platform for building LLM applications. In versions up to and including 3.1.3, the POST /api/v1/node-load-method/:name endpoint is mounted without any route-level permission check and invokes component loadMethods with an attacker-controlled nodeName, loadMethod, inputs, and credential value. The selected credential is resolved by raw Credential.id via getCredentialData() and decrypted withou...
CVE-2026-18069	6.0	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to obtain ownership of arbitrary file system objects due to a time-of-check to time-of-use (TOCTOU) race condition.
CVE-2026-16435	5.9	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is affected by an authentication bypass vulnerability when using XD or Intelligent-Management features.
CVE-2026-17495	5.9	MEDI				moment is a JavaScript date library for parsing, validating, manipulating, and formatting dates. In versions 2.29.2 through 2.30.1, a specially crafted non-string object passed to moment.locale() can bypass the locale-name path-traversal guard. The guard assumes the input is a string, so an object whose match() method satisfies the check while its toString() returns a traversal path reaches an internal require() c...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78123	5.9	MEDI		0.004	strongswan:strongswan	strongSwan 5.0.2 through 6.0.7 has an Expired Pointer Dereference in PKCS#7 parsing in the openssl plugin.
CVE-2026-88763	5.9	MEDI		0.003		A flaw was found in the skupper-router component of Red Hat Service Interconnect, which is used to provide secure communication between distributed services. The issue occurs when the router processes a specially crafted network message using its AMQP field parser. Due to a lack of bounds on recursion during parsing, the router can run out of stack memory and crash, leading to a denial of service for the interconn...
CVE-2026-55102	5.8	MEDI				hashi-vault-js is a Node.js module for interacting with the HashiCorp Vault API. Prior to 0.5.2, every API method in src/Vault.js passes failed requests through parseAxiosError(), which rethrows the raw AxiosError while retaining AxiosError.config and the equivalent response configuration. These objects can contain the X-Vault-Token request header and err.config.data request body, including submitted passwords or ...
CVE-2026-54246	5.7	MEDI				Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.27.13, the routesrv component serves cluster-wide control-plane data without application-layer authentication through /routes, /routes/{zone}, /swarm/redis/shards, and /swarm/valkey/shards. The handlers registered in routesrv/routesrv.go, eskipBytes.ServeHTTP in routesrv/eskipbytes.go, RedisHandler.ServeHTTP in routesrv/redishandler.go...
CVE-2026-69591	5.7	MEDI		0.009	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information over a network.
CVE-2023-52676	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bpf: Guard stack limits against 32bit overflow This patch promotes the arithmetic around checking stack bounds to be done in the 64-bit domain, instead of the current 32bit. The arithmetic implies adding together a 64-bit register with a int offset. The register was checked to be below 1<<29 when it was variable, but not when it was fixed. The o...
CVE-2024-41062	5.5	MEDI		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bluetooth/l2cap: sync sock recv cb and release The problem occurs between the system call to close the sock and hci_rx_work, where the former releases the sock and the latter accesses it without lock protection. CPU0 CPU1 ---- sock_close hci_rx_wor...
CVE-2024-50017	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: x86/mm/ident_map: Use gbpages only where full GB page should be mapped. When ident_pud_init() uses only GB pages to create identity maps, large ranges of addresses not actually requested can be included in the resulting table; a 4K request will map a full GB. This can include a lot of extra address space past that requested, including areas mar...
CVE-2024-52560	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: Mark inode as bad as soon as error detected in mi_enum_attr() Extended the `mi_enum_attr` function interface with an additional parameter, `struct ntfs_inode *ni`, to allow marking the inode as bad as soon as an error is detected.
CVE-2024-56545	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: HID: hyperv: streamline driver probe to avoid devres issues It was found that unloading 'hid_hyperv' module results in a devres complaint: ... hv_vmbus: unregistering driver hid_hyperv -----[cut here]----- WARNING: CPU: 2 PID: 3983 at drivers/base/devres.c:691 devres_release_group+0x1f2/0x2c0 ... Call Trace: <TASK> ? d...
CVE-2024-56639	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: hsr: must allocate more bytes for RedBox support Blamed commit forgot to change hsr_init_skb() to allocate larger skb for RedBox case. Indeed, send_hsr_supervision_frame() will add two additional components (struct hsr_sup_tlv and struct hsr_sup_payload) syzbot reported the following crash: skbuff: skb_over_panic: text:ffff8af4d4b0a le...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2024-58097	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix RCU stall while reaping monitor destination ring While processing the monitor destination ring, MSDUs are reaped from the link descriptor based on the corresponding buf_id. However, sometimes the driver cannot obtain a valid buffer corresponding to the buf_id received from the hardware. This causes an infinite loop in the dest...
CVE-2025-21649	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: hns3: fix kernel crash when 1588 is sent on HIP08 devices Currently, HIP08 devices does not register the ptp devices, so the hdev->ptp is NULL. But the tx process would still try to set hardware time stamp info with SKBTX_HW_TSTAMP flag and cause a kernel crash. [128.087798] Unable to handle kernel NULL pointer dereference at virtual add...
CVE-2025-22101	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: libwx: fix Tx L4 checksum The hardware only supports L4 checksum offload for TCP/UDP/SCTP protocol. There was a bug to set Tx checksum flag for the other protocol that results in Tx ring hang. Fix to compute software checksum for these packets.
CVE-2025-22103	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: fix NULL pointer dereference in l3mdev_l3_rcv When delete l3s ipvlan: ip link del link eth0 ipvlan1 type ipvlan mode l3s This may cause a null pointer dereference: Call trace: ip_rcv_finish+0x48/0xd0 ip_rcv+0x5c/0x100 __netif_receive_skb_one_core+0x64/0xb0 __netif_receive_skb+0x20/0x80 process_backlog+0xb...
CVE-2025-22124	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: md/md-bitmap: fix wrong bitmap_limit for clustermd when write sb In clustermd, separate write-intent-bitmaps are used for each cluster node: 0 4k 8k 12k ----- idle md super bm super [0] + bits ...
CVE-2025-23129	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: Clear affinity hint before calling ath11k_pcic_free_irq() in error path If a shared IRQ is used by the driver due to platform limitation, then the IRQ affinity hint is set right after the allocation of IRQ vectors in ath11k_pci_alloc_msi(). This does no harm unless one of the functions requesting the IRQ fails and attempt to free t...
CVE-2025-37802	5.5	MEDI		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix WARNING "do not call blocking ops when !TASK_RUNNING" wait_event_timeout() will set the state of the current task to TASK_UNINTERRUPTIBLE, before doing the condition check. This means that ksmbd_durable_scavenger_alive() will try to acquire the mutex while already in a sleeping state. The scheduler warns us by giving the following war...
CVE-2025-37833	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net/niu: Niu requires MSIX ENTRY_DATA fields touch before entry reads Fix niu_try_msix() to not cause a fatal trap on sparc systems. Set PCI_DEV_FLAGS_MSIX_TOUCH_ENTRY_DATA_FIRST on the struct pci_dev to work around a bug in the hardware or firmware. For each vector entry in the msix table, niu chips will cause a fatal trap if any registers in...
CVE-2025-38097	5.5	MEDI		0.002	debian:debian_linux, linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: espintcp: remove encap socket caching to avoid reference leak The current scheme for caching the encap socket can lead to reference leaks when we try to delete the netns. The reference chain is: xfrm_state -> enacp_sk -> netns Since the encap socket is a userspace socket, it holds a reference on the netns. If we delete the espintcp state (thro...
CVE-2025-38266	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: pinctrl: mediatek: eint: Fix invalid pointer dereference for v1 platforms Commit 3ef9f710efcb ("pinctrl: mediatek: Add EINT support for multiple addresses") introduced an access to the 'soc' field of struct mtk_pinctrl in mtk_eint_do_init() and for that an include of pinctrl-mtk-common-v2.h. However, pinctrl drivers relying on the v1 common dri...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-38591	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bpf: Reject narrower access to pointer ctx fields The following BPF program, simplified from a syzkaller repro, causes a kernel warning: r0 = *(u8 *)(r1 + 169); exit; With pointer field sk being at offset 168 in __sk_buff. This access is detected as a narrower read in bpf_skb_is_valid_access because it doesn't match offsetof(struct __s...
CVE-2025-38660	5.5	MEDI		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: [ceph] parse_longname(): strchr() expects NUL-terminated string ... and parse_longname() is not guaranteed that. That's the reason why it uses kmemdup_nul() to build the argument for kstrtou64(); the problem is, kstrtou64() is not the only thing that need it. Just get a NUL-terminated copy of the entire thing and be done with that...
CVE-2025-71142	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpuset: fix warning when disabling remote partition A warning was triggered as follows: WARNING: kernel/cgroup/cpuset.c:1651 at remote_partition_disable+0xf7/0x110 RIP: 0010:remote_partition_disable+0xf7/0x110 RSP: 0018:ffffc90001947d88 EFLAGS: 00000206 RAX: 00000000000007ff RBX: ffff888103b6e000 RCX: 00000000000006f40 RDX: 00000000000006f00 RSI:...
CVE-2026-23137	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: of: unittest: Fix memory leak in unittest_data_add() In unittest_data_add(), if of_resolve_phandles() fails, the allocated unittest_data is not freed, leading to a memory leak. Fix this by using scope-based cleanup helper __free(kfree) for automatic resource cleanup. This ensures unittest_data is automatically freed when it goes out of scope in...
CVE-2026-23201	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ceph: fix oops due to invalid pointer for kfree() in parse_longname() This fixes a kernel oops when reading ceph snapshot directories (.snap), for example by simply running `ls /mnt/my_ceph/.snap`. The variable str is guarded by __free(kfree), but advanced by one for skipping the initial '_' in snapshot names. Thus, kfree() is called with an in...
CVE-2026-31420	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: bridge: mrp: reject zero test interval to avoid OOM panic br_mrp_start_test() and br_mrp_start_in_test() accept the user-supplied interval value from netlink without validation. When interval is 0, usecs_to_jiffies(0) yields 0, causing the delayed work (br_mrp_test_work_expired / br_mrp_in_test_work_expired) to reschedule itself with zero delay....
CVE-2026-43088	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: af_key: zero aligned sockaddr tail in PF_KEY exports PF_KEY export paths use `pfkey_sockaddr_size()` when reserving sockaddr payload space, so IPv6 addresses occupy 32 bytes on the wire. However, `pfkey_sockaddr_fill()` initializes only the first 28 bytes of `struct sockaddr_in6`, leaving the final 4 aligned bytes uninitialized. Not every ...
CVE-2026-43288	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ext4: move ext4_percpu_param_init() before ext4_mb_init() When running `kvm-xfstests -c ext4/1k -C 1 generic/383` with the `DOUBLE_CHECK` macro defined, the following panic is triggered: ===== EXT4-fs error (device vdc): ext4_validate_block_bitmap:423: comm mou...
CVE-2026-43344	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: perf/x86/intel/uncore: Fix die ID init and look up bugs In snbep_pci2phy_map_init(), in the nr_node_ids > 8 path, uncore_device_to_die() may return -1 when all CPUs associated with the UBOX device are offline. Remove the WARN_ON_ONCE(die_id == -1) check for two reasons: - The current code breaks out of the loop. This is incorrect because pci...
CVE-2026-45897	5.5	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_counter: serialize reset with spinlock Add a global static spinlock to serialize counter fetch+reset operations, preventing concurrent dump-and-reset from underrunning values. The lock is taken before fetching the total so that two parallel resets cannot both read the same counter values and then both subtract them. A global loc...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-46158	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: mptcp: pm: ADD_ADDR rtx: always decrease sk refcount When an ADD_ADDR is retransmitted, the sk is held in sk_reset_timer(). It should then be released in all cases at the end. Some (unlikely) checks were returning directly instead of calling sock_put() to decrease the refcount. Jump to a new 'exit' label to call __sock_put() (which will become ...
CVE-2026-46170	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: mptcp: pm: ADD_ADDR rtx: free sk if last When an ADD_ADDR is retransmitted, the sk is held in sk_reset_timer(), and released at the end. If at that moment, it was the last reference being held, the sk would not be freed. sock_put() should then be called instead of __sock_put(). But that's not enough: if it is the last reference, sock_put() wil...
CVE-2026-46305	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: os_dep: avoid NULL pointer dereference in rtw_cbuf_alloc The return value of kzalloc_flex() is used without ensuring that the allocation succeeded, and the pointer is dereferenced unconditionally. Guard the access to the allocated structure to avoid a potential NULL pointer dereference if the allocation fails.
CVE-2026-52944	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix FSCTL permission bypass by adding a permission check for FSCTL_SET_SPARSE FSCTL_SET_SPARSE in fsctl_set_sparse() modifies the file's sparse attribute and saves it through xattr without any permission checks. This exposes two issues: 1) A client on a read-only share can change the sparse attribute on files it opened, even though t...
CVE-2026-52961	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: ceph: fix BUG_ON in __ceph_build_xattrs_blob() due to stale blob size The generic/642 test-case can reproduce the kernel crash: [40243.605254] -----[cut here]----- [40243.605956] kernel BUG at fs/ceph/xattr.c:918! [40243.607142] Oops: invalid opcode: 0000 [#1] SMP PTI [40243.608067] CPU: 7 UID: 0 PID: 498762 Comm: kworker/7:1 No...
CVE-2026-64321	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: nvme: target: rdma: fix ndev refcount leak on queue connect nvmet_rdma_queue_connect() calls nvmet_rdma_find_get_device() which acquires a reference on the returned ndev via kref_get(). On the path where the host queue backlog is exceeded and the function returns NVME_SC_CONNECT_CTRL_BUSY, reference of ndev is not released, leaking the kref. Fi...
CVE-2026-64336	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: USB: serial: keyspan_pda: fix information leak The write() callback is supposed to return the number of characters accepted or a negative errno. Since the addition of write fifo support the keyspan_pda implementation will however return the number characters submitted to the device if the write urb is not already in use. If this number is larger...
CVE-2026-68851	5.5	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-69406	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69504	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-90509	5.5	MEDI		0.003		A weakness has been identified in dromara orion-visor up to 2.5.7. Affected by this issue is the function ExposeApiAspect.beforeExposeApi of the file ExposeApiAspect.java. Executing a manipulation can lead to hard-coded credentials. The attack can be executed remotely. The exploit has been made available to the public and could be used for attacks. The project was informed of the problem early through an issue rep...
CVE-2026-90510	5.5	MEDI		0.003		A security vulnerability has been detected in dromara orion-visor up to 2.5.7. This affects the function HostKeyServiceImpl.encryptKey of the file orion-visor-modules/orion-visor-module-asset/orion-visor-module-asset-service/src/main/java/org/dromara/visor/module/asset/service/impl/HostKeyServiceImpl.java. The manipulation leads to use of hard-coded cryptographic key . The attack is possible to be carried out rem...
CVE-2026-90522	5.5	MEDI		0.005		A vulnerability was determined in jaychouchannel Tourism-Management-System up to d984d172dceca907f8b447efbdb06dc233f7938d. Impacted is the function resetPass of the file UsersController.java of the component Password Recovery. This manipulation causes weak password recovery. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Continious delivery with rolling releases ...
CVE-2026-90523	5.5	MEDI		0.005		A vulnerability was identified in jaychouchannel Tourism-Management-System up to 229956e20dbd4a80eeff14535e44d3099502af09. The affected element is an unknown function of the file travel/src/main/java/com/controller/UsersController.java of the component User Register Endpoint. Such manipulation of the argument UsersEntity leads to improper privilege management. The attack can be launched remotely. The exploit is pu...
CVE-2026-90584	5.5	MEDI		0.004		A weakness has been identified in TooTallNate Java-WebSocket up to 1.6.1. The impacted element is the function processFrameContinuousAndNonFin of the file Draft_6455.java of the component Fragmentation Handler. Executing a manipulation can lead to allocation of resources. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks. The pull request to fi...
CVE-2026-90619	5.5	MEDI		0.014		A vulnerability has been found in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. Impacted is an unknown function of the file hexstrike_server.py of the component Execute Endpoint. The manipulation of the argument code/script leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. This product is using a rolling...
CVE-2026-90620	5.5	MEDI		0.004		A vulnerability was determined in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is an unknown function of the file hexstrike_server.py of the component API Command Endpoint. This manipulation causes missing authentication. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Continious delivery with rolling releases is used by ...
CVE-2026-90690	5.5	MEDI		0.013		A weakness has been identified in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The affected element is the function subprocess.Popen of the file hexstrike_server.py of the component API Tools Endpoint. Executing a manipulation of the argument additional_args/target/username/password/scan_type/payload can lead to os command injection. The attack can be launched remotely. The exploit has been m...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90691	5.5	MEDI		0.004		A security vulnerability has been detected in 0x4m4 HexStrike AI up to d689933ff579d839c676c82b231f8e98326c5f04. The impacted element is the function FileOperationsManager of the file hexstrike_server.py of the component API Files Endpoint. The manipulation of the argument filename leads to path traversal. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. The project wa...
CVE-2026-90710	5.5	MEDI				A vulnerability was determined in taisan tarzan-cms 1.0.0. This issue affects the function openConnection of the file com/tarzan/cms/modules/admin/service/biz/ThemeService.java of the component Theme Download Function. Executing a manipulation of the argument httpUrl can lead to server-side request forgery. The attack may be launched remotely. The exploit has been publicly disclosed and may be utilized. The projec...
CVE-2026-90786	5.5	MEDI				A vulnerability was determined in Dvidelabs flatcc up to 0.6.3. This impacts the function align_order_members of the file src/compiler/semantics.c of the component Duplicate Symbol Handler. This manipulation causes reachable assertion. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Patch name: 8b19ba4e992ebcad7f5970704d1afc5507fa5205. To fix this issue, it is rec...
CVE-2026-90852	5.5	MEDI				A vulnerability has been found in luben zstd-jni up to 1.5.7-13. This vulnerability affects the function ZstdCompressCtx.loadDict of the file ZstdCompressCtx.java of the component Dictionary Sharing. Such manipulation leads to use after free. The attack can be executed remotely. The exploit has been disclosed to the public and may be used. Upgrading to version 1.5.7-14 is able to resolve this issue. The name of th...
CVE-2022-26962	5.4	MEDI		0.002		Italtel NFV 11.1.2-20210318 allows Multiple Stored XSS under NP_BCCAS-RMCTRL-01/IMCSCIWebGui/configuration.jsp?opracion=list&object=announcementAS via the name, username, or mrfAnnouncementNameparameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the page containing it.
CVE-2025-63842	5.4	MEDI		0.002		A Cross-Site Scripting (XSS) vulnerability in the web backend for the Repetico app 1.9.7.31 for Android allows a remote authenticated user to execute arbitrary JavaScript code in the app's context via crafted input in the multiple-choice question text field.
CVE-2026-12758	5.4	MEDI				IBM Cloud Pak for Business Automation could allow a remote attacker to bypass authorization and invoke restricted endpoints due to improper validation of HTTP headers.
CVE-2026-12766	5.4	MEDI				IBM Langflow OSS 1.0.0 through 1.11.2 is vulnerable to server-side request forgery (SSRF). This may allow an authenticated attacker to send unauthorized requests from the system, potentially leading to network enumeration or facilitating other attacks.
CVE-2026-15887	5.4	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is affected by blind server-side request forgery when processing SOAP requests.
CVE-2026-16186	5.4	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is affected by a reflected cross-site scripting vulnerability.
CVE-2026-17047	5.4	MEDI				IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a remote attacker to obtain sensitive information due to improper request validation.
CVE-2026-17628	5.4	MEDI				IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to change the password of an account due to improper authentication.
CVE-2026-19273	5.4	MEDI				IBM Sterling B2B Integrator 6.2.0.0 through 6.2.0.6_2, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 and IBM Sterling File Gateway 6.2.0.0 through 6.2.0.6_2, 6.2.1.0 - 6.2.1.2, 6.2.2.0 - 6.2.2.1 Standard Edition could allow a remote authenticated attacker to bypass security restrictions due to improper authentication.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71802	5.4	MEDI		0.001		A stored Cross-Site Scripting (XSS) vulnerability exists in the announcement preview component of REBUILD 4.4.3. Although the announcement content undergoes HTML escaping on the server side, the client-side preview code reverses the escaped entities using jQuery's <code>`html().text()`</code> method and subsequently injects the result into the DOM. An administrator or attacker capable of controlling the announcement content ca...
CVE-2026-78415	5.4	MEDI				IBM Sterling Secure Proxy 6.2.0.0 through 6.2.1.2 could allow a remote authenticated attacker to perform UI spoofing and phishing attacks due to improper neutralization of user-supplied HTML markup.
CVE-2026-7884	5.4	MEDI				IBM Cognos Analytics 12.1.0 through 12.1.3 FP1, and 12.0.4 through 12.0.4 FP2 allows a non-privileged user to edit their given name and surname to include malicious JavaScript code. When an administrator later accesses the user account management panel and views that user's permissions, the malicious JavaScript code is executed. This could result in the cookies from the administrator being compromised.
CVE-2026-91021	5.4	MEDI				Trilium Notes, version v0.103.0 and earlier, contains a stored cross-site scripting (XSS) vulnerability in the share renderer for webView notes due to improper HTML escaping of user-controlled <code>#webViewSrc</code> values. This vulnerability allows attackers with note-authoring privileges to inject arbitrary JavaScript that executes for any user who opens the shared note, including administrators.
CVE-2026-10556	5.3	MEDI				Mattermost versions 11.9.x <= 11.9.0, 11.8.x <= 11.8.4, 11.7.x <= 11.7.7, 10.11.x <= 10.11.22 fail to validate null entries in Microsoft Graph webhook notification payloads, which allows an unauthenticated attacker to crash the Microsoft Calendar plugin process and deny calendar integration service to all users on the instance via a crafted <code>{{POST}}</code> request to the public webhook endpoint.. Mattermost Advisory ID: ...
CVE-2026-16188	5.3	MEDI				IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to inject forged log entries into the server's administrative log.
CVE-2026-18065	5.3	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote unauthenticated attacker to gain access to sensitive information through session IP binding bypass in Navigator for i.
CVE-2026-3783	5.3	MEDI		0.005	haxx:curl	When an OAuth2 bearer token is used for an HTTP(S) transfer, and that transfer performs a redirect to a second URL, curl could leak that token to the second hostname under some circumstances. If the hostname that the first request is redirected to has information in the used <code>.netrc</code> file, with either of the <code>`machine`</code> or <code>`default`</code> keywords, curl would pass on the bearer token set for the first host also to the seco...
CVE-2026-53496	5.3	MEDI				ExifReader is a JavaScript Exif information parser. Prior to 4.40.1, <code>ExifReader.load()</code> and the asynchronous file and URL loaders can pass attacker-supplied HEIC or AVIF data to the ISO-BMFF parser in <code>src/image-header-iso-bmff.js</code> , where <code>findMetaBox()</code> and <code>parseBox()</code> accept an eight-byte box header without confirming that fields required by the parsed box remain in the <code>DataView</code> . A valid ftyp box followed by an empty ...
CVE-2026-53715	5.3	MEDI				Envoy Gateway is an open source project for managing Envoy Proxy as a standalone or Kubernetes-based application gateway. Prior to 1.7.4 and 1.8.1, <code>HTTPServer.ServeHTTP</code> in <code>internal/wasm/httpserver.go</code> reads the plain mapping <code>Path2Cache</code> map without synchronization while <code>HTTPServer.Get</code> writes the same map during <code>EnvoyExtensionPolicy</code> translation. An attacker with pod-network access to unauthenticated port 18002 and ten...
CVE-2026-54529	5.3	MEDI				SQLAdmin is a flexible Admin interface for SQLAlchemy models. Prior to 0.27.1, <code>ModelView.sort_query</code> in <code>sqladmin/models.py</code> accepts the attacker-controlled <code>sortBy</code> list-view query parameter without enforcing the configured <code>column_sortable_list</code> server-side allow-list in <code>self._sort_fields</code> . The value is resolved with <code>getattr</code> and passed to relationship joins and <code>order_by</code> , allowing requests to sort by columns hidden from ...
CVE-2026-6429	5.3	MEDI		0.005	haxx:curl	When asked to both use a <code>`netrc`</code> file for credentials and to follow HTTP redirects, libcurl could leak the password used for the first host to the followed-to host under certain circumstances.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88011	5.3	MEDI		0.002	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. Prior to 2.11.56, and from 3.0.0 until 3.7.12, a client-supplied dot-form header such as X.Authenticated.User survives ForwardAuth replacement and underscoreHeadersStrategy because Go treats it as distinct from X-Authenticated-User while normalization-prone CGI, WSGI, PHP, and NGINX backends collapse both names. A backend can consequently consume the ...
CVE-2026-88879	5.3	MEDI		0.003	traefik:traefik	Traefik is an HTTP reverse proxy and load balancer. In Traefik v1.x, v2.x through v2.11.55, and v3.0.0 through v3.7.11, header names are canonicalized only on dashes, so X-Auth-User, X_Auth_User and X.Auth.User are treated as three distinct headers by Traefik, while backends that derive variable names from header names (CGI, WSGI, PHP, NGINX and others) collapse them into a single variable. A client can therefore ...
CVE-2026-90583	5.3	MEDI		0.003		A security flaw has been discovered in kagisearch smallweb up to 0ecb9c48edbf98dc7e934b54fbac43869e64b4cf. The affected element is the function index of the file app/sw.py of the component Query String Rendering. Performing a manipulation of the argument qs results in cross site scripting. The attack is possible to be carried out remotely. This product adopts a rolling release strategy to maintain continuous deliv...
CVE-2026-90790	5.3	MEDI				A security vulnerability has been detected in a2aproject a2a-python up to 1.1.3. This affects the function _dispatch_notification of the file src/a2a/server/tasks/base_push_notification_sender.py of the component Push Notification Sender. The manipulation of the argument push_info.url leads to server-side request forgery. Remote exploitation of the attack is possible. Upgrading to version 1.1.4 is able to mitigate...
CVE-2026-90808	5.3	MEDI				A vulnerability was determined in HKUDS nanobot up to 0.2.1. Impacted is the function ExecTool._guard_command/ExecTool._spawn of the file nanobot/agent/tools/shell.py of the component ExecTool. This manipulation causes incomplete blacklist. It is possible to initiate the attack remotely. Patch name: af582246f141311d574551b7571a517bcc3df750. Applying a patch is the recommended action to fix this issue.
CVE-2026-90820	5.3	MEDI				A security vulnerability has been detected in a2aproject a2a-java 1.2.0. The impacted element is the function AuthorizationRequestHandlerDecorator.onListTasks of the file server-common/src/main/java/org/a2aproject/sd k/server/requesthandlers/AuthorizationRequestHandlerDecorator.java. Such manipulation leads to missing authorization. The attack can be launched remotely. Upgrading to version 1.3.0 is sufficient to re...
CVE-2026-90848	5.3	MEDI				A weakness has been identified in Governikus AusweisApp up to 2.5.4. Affected is an unknown function of the component StartPAOSResponse Handler. Executing a manipulation of the argument ResultMessage can lead to cross site scripting. The attack can be launched remotely. Upgrading to version 2.5.5 is able to address this issue. It is recommended to upgrade the affected component. This CVE was requested by the vendor.
CVE-2026-90935	5.3	MEDI				Froxlor before 2.3.7 fails to validate the mysql_server parameter against a customer's allowed_mysqlserver allowlist in the Mysqls.add API command. Attackers can supply a disallowed server index to create MySQL databases and users on forbidden servers, bypassing per-customer access controls.
CVE-2026-91146	5.3	MEDI				Takahe through 0.11.0 fails to restrict URL schemes in link hrefs within federated post content and profile summaries, allowing remote actors to inject javascript: links. Attackers can deliver federated content with malicious javascript: hrefs that execute in the instance origin when clicked, enabling session hijacking or impersonation of viewers.
CVE-2026-91851	5.3	MEDI				Affected versions of MISP incorrectly filter dashboard templates that are restricted to a specific permission flag. DashboardsController::listTemplates() allowed a template when either: - its restrict_to_permission_flag matched one of the current user's permission flags, or - restrict_to_permission_flag equaled integer 0 However, restrict_to_permission_flag is a varchar. MySQL therefore performed num...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-91857	5.3	MEDI				Affected versions of MISP expose several state-changing controller actions without restricting them to POST. The affected actions are: - EventReportsController::purgeUnusedPictures() - NoticelistsController::enableNoticelist() - ServersController::removeOrphanedCorrelations() - WorkflowsController::rebuildRedis() The patch adds allowMethod(['post']) to each action, preventing them from being trig...
CVE-2026-91922	5.3	MEDI				Steedos Platform through 3.0.15-beta.47 contains a reflected cross-site scripting vulnerability in the anonymous /api/page/render endpoint that fails to properly escape query parameters in inline script elements. Attackers can craft malicious links with script-terminating sequences in the schemaApi or data parameters to execute arbitrary JavaScript in victim sessions and steal X-Auth-Token credentials.
CVE-2026-9667	5.3	MEDI		0.003		IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2026-19280	5.2	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a denial of service as a result of a buffer overflow in a PASE process. An authenticated attacker could leverage this to terminate their own process.
CVE-2026-75134	5.1	MEDI		0.002		SEOWriting plugin for WordPress through 1.12.5 contains a stored cross-site scripting vulnerability that allows authenticated contributors to inject malicious JavaScript by exploiting an overly permissive KSES allowlist that explicitly permits the onload event handler on iframe elements. Attackers can store crafted JavaScript payloads in post content that execute when the affected post is viewed or previewed by hi...
CVE-2026-85593	5.1	MEDI		0.001		phpMyFAQ versions before 4.1.8 contain a stored cross-site scripting vulnerability in FaqHelper::convertOldInternalLinks() that calls html_entity_decode() on sanitized FAQ content, reversing entity-encoding protection. Authenticated users with FAQ editing privileges can inject JavaScript payloads that execute in the browsers of all users viewing the affected FAQ pages.
CVE-2026-86742	5.1	MEDI		0.003	snipeitapp:snipe-it	Snipe-IT through 8.6.3 does not neutralize formula elements in the "unaccepted assets" acceptance report CSV export. ReportsController::postAssetAcceptanceReport builds the CSV by hand (stripping commas and joining rows manually) and, unlike the six sibling exports in the same controller, never applies League\Csv\EscapeFormula or honors the config('app.escape_formulas') setting. An authenticated low-privilege user...
CVE-2026-86745	5.1	MEDI		0.004	snipeitapp:snipe-it	Snipe-IT is an IT asset management application. In Snipe-IT master-branch builds after 8.6.3 (the code was never included in a tagged release), SettingsController::downloadLocationScopingReport streams the FMCS location-scoping mismatch report (GET /admin/settings/location-scoping-report.csv) through a bare fputcsv() call without applying League\Csv\EscapeFormula, unlike the other CSV exports which honor config('a...
CVE-2026-89268	5.1	MEDI		0.002		QloApps through 1.7.0 renders back-office list filter POST parameters into HTML input value attributes without escaping them in the list helper template. Attackers can induce authenticated users to submit crafted POST requests with malicious payloads to list controllers, executing arbitrary JavaScript in the victim's session to read administrative data and perform actions.
CVE-2026-90563	5.1	MEDI		0.002		A vulnerability was determined in maliangnansheng bbs-springboot 3.0.0. This affects the function utils.toToc of the file ArticleController.java. This manipulation causes cross site scripting. The attack is possible to be carried out remotely.
CVE-2026-90931	5.1	MEDI				LaraDashboard versions 0.9.0 through 1.2.2 fail to sanitize SVG file content during media upload, allowing authenticated users with only the media.create permission to upload malicious SVG files containing script tags. When any user including administrators opens the stored SVG file served inline from the application origin, the embedded JavaScript executes in the dashboard context, enabling session hijacking and ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90957	5.1	MEDI				Affected versions of MISP serve uploaded SVG images inline without a restrictive browser sandbox. The commit explains that SVG files are XML documents rather than passive bitmap images. While scripts inside SVG do not execute when the SVG is rendered through a normal , they can execute when the SVG is navigated to directly or embedded as a document. In that case, malicious <script> elements, event handlers,...
CVE-2026-55244	5.0	MEDI				ASTEVAL is an evaluator of Python expressions and statements. Prior to 1.0.9, FROM_PY in asteval/astutils.py exposes BaseException, SystemExit, KeyboardInterrupt, and GeneratorExit to expressions evaluated by asteval.Interpreter.eval(), while run() and eval() in asteval/asteval.py catch Exception rather than these non-Exception BaseException subclasses. When an attacker-controlled expression raises one of these cl...
CVE-2026-75015	4.9	MEDI				Insufficiently Protected Credentials vulnerability in Apache Syncope. Audit events, when sent to the configured store, are not sufficiently masked for the sensitive values they might carry on their payloads, thus allowing administrators to access such sensitive values. This issue affects Apache Syncope: from 3.0.0-M0 through 3.0.16, from 4.0.0-M0 Through 4.0.7, from 4.1.0-M0 through 4.1.2. Users are recomm...
CVE-2026-77883	4.9	MEDI				Exposure of sensitive information through data queries vulnerability in Apache Syncope. An administrator with adequate entitlements for Derived Schemas can create a malicious JEXL expression which allows any administrator with sufficient entitlements for User read to access LinkedAccount's (if present) or Manager's (if defined) sensitive information, possibly including hashed credentials. This issue affects Apac...
CVE-2026-16189	4.8	MEDI				IBM WebSphere Application Server 9.0, and 8.5 could allow a remote attacker to inject forged log entries into the server's administrative log.
CVE-2026-86472	4.8	MEDI				fast-uri is a dependency-free RFC 3986 URI parser for Node.js, used by Fastify and ajv. In versions before 2.4.7, from 3.0.0 through 3.1.7, and from 4.0.0 through 4.1.4, fast-uri folds the host to lowercase before it percent-decodes the host, so a percent-encoded uppercase octet such as %41 decodes to a literal A that is never folded. For a scheme-relative reference such as //host there is no scheme, so the host c...
CVE-2026-86818	4.8	MEDI				fast-uri is a dependency-free RFC 3986 URI parser for Node.js, used by Fastify and ajv, that added a mailto scheme parser in version 4.1.3. In versions 4.1.3 and 4.1.4, the mailto parser compares each query field name to the reserved names to, subject, and body while the name is still percent-encoded, and decodes it only when storing it as a generic header, so a percent-encoded spelling of a reserved field name is...
CVE-2026-90569	4.8	MEDI		0.003		A flaw has been found in linlinjava litemall 1.5.0/1.6.0/1.7.0/1.8.0. This vulnerability affects the function AdminTopicController.validate of the file litemall-vue/src/views/items/topic/index.vue of the component Admin Topic Handler. This manipulation causes cross site scripting. The attack may be initiated remotely. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-90570	4.8	MEDI		0.003		A vulnerability has been found in linlinjava litemall 1.4.0/1.5.0/1.6.0/1.7.0/1.8.0. This issue affects the function AdminGoodsService.validate of the file litemall-vue/src/views/items/detail/index.vue of the component Product Detail. Such manipulation of the argument detail leads to cross site scripting. The attack may be launched remotely. The project was informed of the problem early through an issue report but...
CVE-2022-48650	4.7	MEDI		0.002	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix memory leak in __qlt_24xx_handle_abts() Commit 8f394da36a36 ("scsi: qla2xxx: Drop TARGET_SCF_LOOKUP_LUN_FROM_TAG") made the __qlt_24xx_handle_abts() function return early if tcm_qla2xxx_find_cmd_by_tag() didn't find a command, but it missed to clean up the allocated memory for the management command.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-21651	4.7	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: hns3: don't auto enable misc vector Currently, there is a time window between misc irq enabled and service task initd. If an interrupt is reported at this time, it will cause warning like below: [16.324639] Call trace: [16.324641] __queue_delayed_work+0xb8/0xe0 [16.324643] mod_delayed_work_on+0x78/0xd0 [16.324655] hclge_er...
CVE-2026-69425	4.7	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to perform tampering locally.
CVE-2023-40772	4.3	MEDI		0.01		A directory Traversal vulnerability in DataEase before 1.18.10 allows a remote attacker to obtain sensitive information via a crafted request to the StaticResourceController.java component.
CVE-2026-18251	4.3	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to obtain sensitive information due to improper validation of the WebSocket origin.
CVE-2026-18515	4.3	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to place files into the file system with Navigator for i when they should be blocked by Navigator configuration. This could allow attackers to upload files onto the system to places the Navigator support did not intend, but only if the profile could already do that by itself.
CVE-2026-54247	4.3	MEDI				Skipper is an HTTP router and reverse proxy for service composition. Prior to 0.26.22, Handler in dataclients/kubernetes/admission/admission.go passes the body of requests to the Kubernetes admission endpoint at :9443/admission directly to io.ReadAll(r.Body) without a size limit. An attacker with in-cluster network access and a valid Kubernetes client certificate can send a very large body that causes unbounded me...
CVE-2026-75792	4.3	MEDI				IBM Sterling Secure Proxy 6.2.0.0 through 6.2.1.2 could allow a remote authenticated attacker to view administrative user interface components due to client-side authorization bypass.
CVE-2026-82437	4.3	MEDI				Description The Logviewer offers `logs.users` and `logs.groups` so operators can control who may read log content. For daemon logs those settings were not applied: the access decision combined the "this is a daemon log" flag with the authorizer result in a way that discarded the authorizer's answer whenever the flag was set, and the daemon log page and download endpoints reached the handler without consulting an ...
CVE-2026-86087	4.3	MEDI		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-12763	4.2	MEDI				IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to access another user's MCP server context due to improper cache key isolation in the MCP Tools component.
CVE-2026-18151	4.2	MEDI				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to obtain sensitive information due to a race condition during the WebSocket handshake process.
CVE-2026-59341	4.2	MEDI				A security vulnerability exists in the Sealed Secrets controller's unauthenticated POST endpoints. By submitting a modified payload containing custom Go template logic in spec.template.data, an attacker with internal network access can abuse the handler as a decryption oracle to recover the full plaintext of any sealed secret. The POST /v1/verify and /v1/rotate handlers call Unseal() to decrypt target secrets, ...
CVE-2026-78124	3.7	LOW		0.002	strongswan:strongswan	strongSwan 5.0.2 through 6.0.7 allows PKCS#7 certificate enumeration in the openssl plugin that leads to a lack of release of memory after its effective lifetime.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79300	3.5	LOW		0.002		SEP sesam before 5.2.0.24 mishandles User Authorization with MFA. If AD authentication is configured and MFA is enforced, an attacker can create a second OTP access capability. SEP sesam and Active Directory handle username capitalization differently, which may allow multiple SEP sesam user accounts to be created for the same Active Directory (AD) account. Active Directory treats usernames as case-insensitive, whi...
CVE-2026-19086	3.3	LOW				IBM i 7.6, 7.5, 7.4, and 7.3 could allow a denial of service as a result of a buffer overflow in a PASE process. An authenticated attacker could leverage this to terminate their own process.
CVE-2026-16190	3.1	LOW				IBM WebSphere Application Server 9.0, and 8.5 is affected by an authorization bypass vulnerability.
CVE-2026-82019	2.3	LOW				TripleLift's ad rendering script (video-bundle.js) contains a DOM-based cross-site scripting vulnerability that allows unauthenticated attackers to execute arbitrary JavaScript in a publisher's domain by sending crafted postMessage payloads without origin validation. Attackers can cause a victim to visit an attacker-controlled page that sends malicious postMessage events to a publisher page running the ad script, ...
CVE-2026-90487	2.1	LOW		0.002		A vulnerability was found in Xuxueli xxl-job up to 3.4.2. Affected by this issue is some unknown functionality of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobGroupController.java. The manipulation results in improper privilege management. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure bu...
CVE-2026-90488	2.1	LOW		0.002		A vulnerability was determined in Xuxueli xxl-job up to 3.4.2. This affects the function GroovyClassLoader.parseClass of the file xxl-job-core/src/main/java/com/xxl/job/core/glue/GlueFactory.java. This manipulation causes code injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respon...
CVE-2026-90511	2.1	LOW		0.002		A vulnerability was detected in GongShengyue OnlineBooks up to dfc5eacc08d3b0396c266049548618f6fb9587ea. This vulnerability affects unknown code of the file src/cn/ylcto/book/servlet/BooksServlet.java of the component listSplit Interface. The manipulation of the argument column results in sql injection. The attack may be performed from remote. The exploit is now public and may be used. This product utilizes a roll...
CVE-2026-90520	2.1	LOW		0.004		A vulnerability has been found in jaychouchannel Tourism-Management-System up to 84d8ec384f669df3985293dab293bb7b477efa64. This vulnerability affects unknown code of the file AuthorizationInterceptor.java of the component Authorization Interceptor. The manipulation leads to improper authorization. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. This pro...
CVE-2026-90521	2.1	LOW		0.004		A vulnerability was found in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddfff3ee02d1632a70a9a132. This issue affects some unknown processing of the file MenpiaodingdanController.java of the component CRUD. The manipulation of the argument ID results in authorization bypass. It is possible to launch the attack remotely. The exploit has been made public and could be used. This product takes the a...
CVE-2026-90581	2.1	LOW		0.002		A vulnerability was determined in cym1102 nginxWebUI up to 4.4.2. This issue affects the function MainController.autoUpdate of the file /adminPage/main/autoUpdate. This manipulation of the argument url causes code injection. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The pull request to fix this issue awaits acceptance.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-90594	2.1	LOW		0.002		A vulnerability was identified in wxiaoqi Spring-Cloud-Platform 3.0.1/3.1.0. This vulnerability affects the function <code>PermissionService.checkUserPermission</code> of the file <code>/rpc/service/PermissionService.java</code> of the component Permission Service. The manipulation leads to missing authorization. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The project was informed of ...
CVE-2026-90595	2.1	LOW		0.002		A security flaw has been discovered in wxiaoqi Spring-Cloud-Platform 1.0/2.2/3.0. This issue affects the function <code>OnlineController.getOnlineInfo</code> of the file <code>aceModules/ace-admin/auth/controller/OnlineController.java</code> . The manipulation results in missing authorization. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The project was informed of the problem...
CVE-2026-90598	2.1	LOW		0.002		A vulnerability was detected in jaygajera17 E-commerce-project-springBoot up to 5e74a46b4b70623d0e4a0c9c4aee3bd1777185d2. The impacted element is the function <code>UserController.updateUser</code> of the file <code>UserController.java</code> . Performing a manipulation of the argument <code>userid</code> results in authorization bypass. It is possible to initiate the attack remotely. The exploit is now public and may be used. This product is using a ro...
CVE-2026-90835	2.0	LOW				A flaw has been found in michaeliao itranswarp up to 2.19. The impacted element is the function <code>Markdown.toHtml</code> of the file <code>Markdown.java</code> of the component Page Content Rendering. This manipulation causes cross site scripting. The attack may be initiated remotely. The exploit has been published and may be used. The project was informed of the problem early through an issue report but has not responded yet. This vu...
CVE-2026-90622	1.9	LOW		0.002		A security flaw has been discovered in GNU libredwg 0.13.4. This impacts the function <code>DWG_TABLE</code> of the file <code>src/dwg.spec</code> of the component Layer Encoding. Performing a manipulation results in null pointer dereference. The attack needs to be approached locally. The exploit has been released to the public and may be used for attacks. Upgrading to version 0.14 will fix this issue. The patch is named f5b548c4c1697d66c3...
CVE-2025-64059	1.8	LOW		0.002		Grav 1.7.50.2 allows admins to enter JavaScript via the Home Page editor. NOTE: the relevance of this for stored XSS is disputed because admins are allowed to modify templates, install plugins, and upload other executable content.
CVE-2025-39991				0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix NULL dereference in <code>ath11k_qmi_m3_load()</code> If <code>ab->fw.m3_data</code> points to data, then <code>fw</code> pointer remains null. Further, if <code>m3_mem</code> is not allocated, then <code>fw</code> is dereferenced to be passed to <code>ath11k_err</code> function. Replace <code>fw->size</code> by <code>m3_len</code> . Found by Linux Verification Center (linuxtesting.org) with SVACE.
CVE-2026-13260						IBM Verify Identity Access could allow a remote attacker to cause a denial of service due to insufficient validation of incoming request resources.
CVE-2026-13272						IBM Verify Identity Access is missing origin validation which could allow a remote attacker to perform operations as the victim and potentially launch further attacks against the systems.
CVE-2026-13276						IBM Verify Identity Access 11.0.0 through 11.0.3 Interim Fix 001 and IBM Security Verify Access 10.0.0 through 10.0.9.2 Interim Fix 001 and IBM Verify Identity Access Container 11.0.0 through 11.0.3 Interim Fix 001 and IBM Security Verify Access Container 10.0.0 through 10.0.9.2 Interim Fix 001.
CVE-2026-13277						IBM Verify Identity Access could allow a remote attacker to conduct phishing attacks, using an open redirect attack. By persuading a victim to visit a specially crafted Web site, a remote attacker could exploit this vulnerability to spoof the URL displayed to redirect a user to a malicious Web site that would appear to be trusted. This could allow the attacker to obtain highly sensitive information or conduct furt...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72131				0.002		In the Linux kernel, the following vulnerability has been resolved: nvme-apple: Prevent shared tags across queues on Apple A11 On Apple A11, tags of pending commands must be unique across the admin and IO queues, else the firmware crashes with "duplicate tag error for tag N", with N being the tag. Apply the existing workaround for M1 of reserving two tags for the admin queue to A11.
CVE-2026-80689				0.002		In the Linux kernel, the following vulnerability has been resolved: tracing/mmioTRACE: Add NULL check for mmio_trace_array in logging functions mmio_trace_rw() and mmio_trace_mapping() retrieve mmio_trace_array into tr and pass it to __trace_mmioTRACE_rw() and __trace_mmioTRACE_map(). If these functions are invoked while mmio_trace_array is NULL (e.g. before initialization or after disabled), accessing tr->array...
CVE-2026-80878				0.002		In the Linux kernel, the following vulnerability has been resolved: afs: Fix leak of ungot volume Fix afs_lookup_volume_rcu() so that it doesn't leak a dying volume if afs_try_get_volume() fails.
CVE-2026-80888				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/vmwgfx: drop dma_buf reference on foreign-fd prime import ttm_prime_fd_to_handle() returns -ENOSYS when the imported fd's dma_buf->ops do not match the ttm_object_device's ops, but does so without releasing the reference acquired by dma_buf_get(). Any unprivileged renderD client passing a non-vmwgfx prime fd through the DRM_VMW_GB_SURFACE_R...
CVE-2026-80912				0.002		In the Linux kernel, the following vulnerability has been resolved: selinux: reject an unclaimed class value in security_get_classes() security_get_classes() sizes an array by p_classes.nprim and fills it at value - 1, so a class value the policy never defines leaves a NULL. sel_make_classes() passes every entry to sel_make_dir(), reaching the same d_alloc_name() dereference as the permission array. The class sy...
CVE-2026-80930				0.002		In the Linux kernel, the following vulnerability has been resolved: tpm: tpm_i2c_nuvoton: disable IRQ on wait timeout i2c_nuvoton_wait_for_stat() enables the IRQ before waiting for the interrupt handler to report a status change. If the wait times out, or is interrupted before the handler runs, the function returns without balancing the enable_irq() call. Disable the IRQ before leaving the failed wait path. Als...
CVE-2026-80938				0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7615: avoid waiting for mac work under the mt76 mutex mt7615_suspend() acquired the mt76 mutex and then called cancel_delayed_work_sync() on mac_work. mt7615_mac_work() acquires the same mutex via mt7615_mutex_acquire() at the top of the worker, so if mac_work is already running and blocked on the mutex, the suspend path deadlocks...
CVE-2026-80939				0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: rtw89: pci: add .shutdown callback to stop rkill polling on reboot Since the hardware rkill polling was introduced, arm64 platforms can panic with an asynchronous SError during warm reboot: SError Interrupt on CPU8, code 0x00000000be000011 -- SError Workqueue: events_power_efficient rkill_poll [rkill] rtw89_pci_ops_read8+0x94/...
CVE-2026-80941				0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: rtw88: Fix potential memory leak in rtw_txq_push_skb() The skb passed to the rtw_hci_tx_write() is expected to be freed when the function fails, but the error path in rtw_txq_push_skb() does not free the skb before returning. This can lead to a memory leak in rtw_txq_push() where a dequeued skb is passed to rtw_txq_push_skb().
CVE-2026-80949				0.002		In the Linux kernel, the following vulnerability has been resolved: wifi: brcmfmac: Fix memory leak in brcmf_sdio_read_control() The memory allocated for buf is not freed in some of the error paths in brcmf_sdio_read_control(). Fix that by adding vfree() calls. [arend: rework as suggested by Johannes]
CVE-2026-80951				0.002		In the Linux kernel, the following vulnerability has been resolved: i3c: master: svc: bound IBI payload to the requested max_payload_len svc_i3c_master_handle_ibi() reads the IBI payload from the RX FIFO into the IBI slot. The loop is bounded by the hardware FIFO size (SVC_I3C_FIFO_SIZE), not by the slot size. slot->data points into the IBI pool, which i3c_generic_ibi_alloc_pool() sizes at max_payload_len per s...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80963				0.002		In the Linux kernel, the following vulnerability has been resolved: dm-stats: fix a crash if allocation of per-cpu data fails If "dm_kvzalloc(percpu_alloc_size, cpu_to_node(cpu))" fails, the code jumps to the "out" label and calls dm_stat_free. dm_stat_free does "for_each_possible_cpu(cpu) { dm_kvfree(s->stat_percpu[cpu][0].histogram, s->histogram_alloc_size);", which crashes with NULL pointer dereference if s->...
CVE-2026-80964				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: virmidi: Check card index validity at probe virmidi driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB acc...
CVE-2026-80965				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: serial-u16550: Check card index validity at probe serial-u16550 driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this lead...
CVE-2026-80966				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: portman2x4: Check card index validity at probe Although portman2x4 driver has a check of the given devptr->id value, it doesn't check for a negative id, which is often given as "none" or such value when bound via sysfs. This may lead to OOB access for index[] and other parameters. Add a sanity check for the card index and warn/correct it...
CVE-2026-80968				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: mts64: Check card index validity at probe Although mts64 driver has a check of the given devptr->id value, it doesn't check for a negative id, which is often given as "none" or such value when bound via sysfs. This may lead to OOB access for index[] and other parameters. Add a sanity check for the card index and warn/correct it if it's a...
CVE-2026-80969				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: mpu401: Check card index validity at probe mpu401 driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB acces...
CVE-2026-80970				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: FCP: do not copy out an uninitialised init response fcp_ioctl_init() allocates its response buffer with kmalloc() and copies the whole buffer back to userspace: buf_size = init.step0_resp_size + init.step2_resp_size; void *resp __free(kfree) = kmalloc(buf_size, GFP_KERNEL); ... if (copy_to_user(arg->resp, resp, buf_size)) return ...
CVE-2026-80972				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: aloop: Check card index validity at probe aloop driver blindly trusts that the given devptr->id value is within the proper card index range at probe. It's OK for the devices the driver itself creates at the module probe time, but if the device is bound manually via sysfs interface, this could be -1 as "none", and this leads to OOB access ...
CVE-2026-80973				0.002		In the Linux kernel, the following vulnerability has been resolved: ALSA: 6fire: bound the MIDI event length from the device usb6fire_comm_receiver_handler() forwards a MIDI event using a length byte the device supplies, with no bound and no check that the transfer delivered that many bytes: if (!urb->status) { if (rt->receiver_buffer[0] == 0x10) /* midi in event */ if (midi_rt) midi_rt->in_received(m...
CVE-2026-80983				0.002		In the Linux kernel, the following vulnerability has been resolved: net/smc: fix socket refcount leak in smc_switch_conns() smc_switch_conns() takes a reference on the SMC socket before dropping lgr->conns_lock, so the connection stays alive while the CDC slot is fetched: sock_hold(&smc->sk); read_unlock_bh(&lgr->conns_lock); /* pre-fetch buffer outside of send_lock, might sleep */ ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80984				0.002		In the Linux kernel, the following vulnerability has been resolved: net/smc: do not dereference an unset send buffer on the SMC-D teardown path smc_close_stream_wait() calls smc_tx_prepared_sends() from inside its sk_wait_event() condition, and sk_wait_event() evaluates that condition once with the socket lock released. smcd_buf_detach() clears conn->sndbuf_desc from smc_conn_kill() under lock_sock(), so a link ...
CVE-2026-80988				0.002		In the Linux kernel, the following vulnerability has been resolved: NTB: ntb_transport: Fail TX enqueue when the QP link is down Commit f195a1a6fe41 ("ntb: Drop packets when qp link is down") meant to make ntb_transport_tx_enqueue() drop packets submitted while the QP link is down, but it only returns 0 without consuming the packet. Zero means success by this function's contract, so ntb_netdev reports NETDEV_TX_...
CVE-2026-80990				0.002		In the Linux kernel, the following vulnerability has been resolved: net: thunderbolt: Release the Rx HopID that was handed out on mismatch tb_xdomain_alloc_in_hopid() passes the wanted HopID to ida_alloc_range() as the lower bound, so a taken id is not an error there: the allocator returns the next free one above it. tbnet_connected_work() asks for the peer's transmit path, treats any other id as a failure and r...
CVE-2026-81005				0.002		In the Linux kernel, the following vulnerability has been resolved: ipmi: si: Fix NULL pointer dereference after failed registration try_smi_init() allocates new_smi->si_sm and later calls ipmi_register_smi_mod(), which maps to ipmi_add_smi(). During ipmi_add_smi(), the upper IPMI message handler obtains the initial BMC device information through __bmc_get_device_id(). This can fail if the BMC does not return a...
CVE-2026-81013				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix heap OOB read on empty password write validate_password_input() computes length = strlen(buf) and then checks buf[length - 1] to strip a trailing newline, without checking that length is nonzero first. Writing an empty string (a bare '\n') to current_password or new_password gives length == 0, and buf[length - 1] re...
CVE-2026-81014				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix heap OOB read in sk_store() and kek_store() sk_store() and kek_store() strip a trailing newline from the sysfs write before allocating the key buffer: length = count; if (buf[length - 1] == '\n') length--; bioscfg_drv.spm_data.signing_key = kmemdup(buf, length, GFP_KERNEL); but then pass the original "count" ...
CVE-2026-89437				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: int1092: Fix potential memory leak in sar_probe() The memory allocated for device_mode_info in parse_package() called by sar_get_data() is not freed in some of the error paths in sar_probe(). Fix that by converting to use device managed allocations.
CVE-2026-89438				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: ISST: Validate logical CPU id and clos id Validate max CLOS ID and logical CPU ID for core power feature. Reject any clos level or logical CPU number greater than the supported maximum. These are used to calculate MMIO offset.
CVE-2026-89444				0.002		In the Linux kernel, the following vulnerability has been resolved: platform/x86: dell-wmi-sysman: Don't hex dump attribute security buffer set_attribute() populates the security area of the BIOS attribute request buffer with the current admin password via populate_security_buffer(), then dumps the whole request buffer with print_hex_dump_bytes(). This can expose the plaintext admin password in the kernel log. ...
CVE-2026-89457				0.002		In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Guard sysfs discipline callbacks against unallocated private data Several sysfs show/store handlers call a discipline callback that dereferences device->private, either directly or through the DASD_DEFINE_ATTR() macro. During dasd_generic_set_online() the discipline is assigned before check_device() allocates device->private, so an un...
CVE-2026-89458				0.002		In the Linux kernel, the following vulnerability has been resolved: s390/dasd: Do not complete a failed ESE read as successful dasd_int_handler() completes an NRF read of an unallocated ESE track by calling ese_read() and unconditionally marking the request DASD_CQR_SUCCESS. dasd_eckd_ese_read() can return an error before it has zeroed the destination buffer: a failed sense-data parse or a current track outside ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89460				0.002		In the Linux kernel, the following vulnerability has been resolved: s390/cpum_cf: Handle CPU hotplug via prepare/dead callbacks The command 'perf stat -e cycles -- <command>' crashes the kernel when CPUs are hotplug added during that run. Root cause is the allocation of struct cpu_cf_events at first event initialization. The allocation is dynamic and the first event that has task context creates such a structur...
CVE-2026-89461				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: max17040: synchronize work cancellation on suspend max17040_work() requeues itself after every poll. cancel_delayed_work() only cancels a pending instance and does not wait for a callback that is already running. If system suspend races with the polling callback, the callback can continue accessing the fuel gauge and requeue itse...
CVE-2026-89463				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: ucs1002: fix use-after-free on remove ucs1002 has no remove callback, so unbind runs entirely through devm. The alert IRQ handler queues the health_poll delayed work, and the work reschedules itself while the chip reports a bad-health condition. devm frees the alert IRQ, which only synchronizes the handler; it does not cancel the...
CVE-2026-89464				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: twl4030_charger: cancel workers via devm bci is devm-allocated. Two workers (bci->work and bci->current_worker) dereference it. twl4030_bci_remove() disables charging and masks interrupts. It cancels neither worker. A worker pending at remove() can run after devm frees bci. The USB transceiver comes from devm_usb_get_phy_by_node(...
CVE-2026-89473				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: bq25890: Fix power_supply reference leak bq25890_fw_probe() acquires a reference to a secondary charger using power_supply_get_by_name(), but the reference is not released on later probe failures or on driver detach. In particular, failures after bq25890_fw_probe() returns successfully, such as a failure in bq25890_hw_init(), als...
CVE-2026-89474				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: bq256xx: drain usb_work before freeing the charger The USB-PHY notifier queues usb_work, whose handler calls power_supply_changed(bq->charger). The reset devm action only unregisters the notifier and was registered before the power supplies, so devm frees bq->charger on unwind before the action runs; a usb_work still queued can th...
CVE-2026-89475				0.002		In the Linux kernel, the following vulnerability has been resolved: power: supply: bq24257: fix use-after-free on remove The STAT-pin interrupt is devm-managed, so it stays armed until the devm cleanup that runs after remove() returns. remove() cancels bq->iilimit_setup_work while the threaded handler can still fire; that handler reschedules the work and dereferences bq, so the work runs against freed memory onc...
CVE-2026-89490				0.002		In the Linux kernel, the following vulnerability has been resolved: ocfs2: fix readdir position truncation on 32-bit kernels In ocfs2_dir_foreach_blk_el(), the directory cookie position is rebuilt with ctx->pos = (ctx->pos & ~(sb->s_blocksize - 1)) offset; `ctx->pos` is loff_t (signed 64-bit), while `sb->s_blocksize` is unsigned long. On 32-bit kernels unsigned long is 32-bit, so the mask ~(sb->s_blocksi...
CVE-2026-89491				0.002		In the Linux kernel, the following vulnerability has been resolved: ocfs2: cluster: don't sleep while holding o2hb_live_lock in o2hb_region_pin() Patch series "ocfs2: cluster: o2hb_region_pin() fixes", v2. This series fixes three related issues in o2hb_region_pin(), all are from the original implementation in commit: 58a3158a5d17 ("ocfs2/cluster: Pin/unpin o2hb regions"): 1) It is called with o2hb_live_lock (a...
CVE-2026-89496				0.002		In the Linux kernel, the following vulnerability has been resolved: ocfs2: always run deallocs on copy-on-write completion Local fuzzing of 6.12.94 has found the following memory leak caused by doing 'copy_file_range()' within the same filesystem: unreferenced object 0xffff88812192c980 (size 32): comm "syz.0.49", pid 12095, jiffies 4294964143 hex dump (first 32 bytes): 00 00 00 00 00 00 00 00 00 08 00 00 00 0...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89498				0.002		In the Linux kernel, the following vulnerability has been resolved: orangefs: fix double-free of trailer_buf on readdir copy failure On a readdir downcall, orangefs_devreq_write_iter() frees op->downcall.trailer_buf with vfree() when copy_from_iter_full() fails, but does not clear the pointer before goto Efault. The waiter in do_readdir() is then woken with a negative status and frees the same pointer again on i...
CVE-2026-89512				0.002		In the Linux kernel, the following vulnerability has been resolved: remoteproc: scp: Fix device reference leak on failed lookup Make sure to drop the reference taken to the SCP device when attempting to look up its driver data before the driver has been bound. Note that holding a reference to a device does not prevent its driver data from going away.
CVE-2026-89515				0.002		In the Linux kernel, the following vulnerability has been resolved: scsi: core: Fill in DMA padding bytes in scsi_alloc_sgtables() During fuzz testing, the following issue was discovered: BUG: KMSAN: uninit-value in __dma_map_sg_attrs+0x217/0x310 __dma_map_sg_attrs+0x217/0x310 dma_map_sg_attrs+0x4a/0x70 ata_qc_issue+0x9f8/0x1420 __ata_scsi_queuecmd+0x1657/0x1740 ata_scsi_queuecmd+0x79a/0x920 scsi_queue_rq...
CVE-2026-89525				0.002		In the Linux kernel, the following vulnerability has been resolved: udf: reject VAT indexes equal to the entry count UDF 1.50 virtual partition mapping uses the VAT as an array of physical block mappings. s_num_entries stores the number of entries in that array, not the highest valid index. The valid VAT indexes are therefore below s_num_entries. udf_get_pblock_virt15() currently rejects only indexes greater th...
CVE-2026-89565				0.002		In the Linux kernel, the following vulnerability has been resolved: ipip: fix skb leak in collect_md mode when metadata_dst allocation fails In collect_md mode ipip_tunnel_rcv() returns 0 without freeing the skb when ip_tun_rx_dst() fails to allocate the metadata_dst. ipip_rcv() and mplsip_rcv() are registered as xfrm_tunnel handlers, so tunnel4_rcv() and tunnelmpls4_rcv() read the zero return as "the packet has...
CVE-2026-89575				0.002		In the Linux kernel, the following vulnerability has been resolved: dm raid1: reserve space for NUL-terminator in build_constructor_string() Reserve space for the termination NUL after the maximum 20 decimal digits of a long long value to avoid buffer overflow in sprintf().
CVE-2026-89576				0.002		In the Linux kernel, the following vulnerability has been resolved: dm-era: fix shadowed superblock leak on take-snap failure metadata_take_snap() bumps the live superblock refcount and then dm_tm_shadow_block() allocates a new block for the metadata snapshot. If the subsequent dm_sm_inc_block() of writeset_tree_root or era_array_root fails, the function only unlocks the clone and returns. The newly allocated s...
CVE-2026-89582				0.002		In the Linux kernel, the following vulnerability has been resolved: bnx2x: fix double free in bnx2x_init_firmware() error path bnx2x_init_firmware() frees bp->init_ops, bp->init_data and bp->init_ops_offsets in its error path without setting them to NULL. The cleanup function bnx2x_release_firmware() frees the same three pointers unconditionally, so if init_firmware fails and release_firmware is later called (e....
CVE-2026-89595				0.002		In the Linux kernel, the following vulnerability has been resolved: fsnotify: Fix stale object mask after concurrent mark updates When a mark gets a new event bit, fanotify and inotify may avoid recalculating the object mask if the cached aggregate already contains that bit. This is racy with a recalculation triggered by a concurrent update to another mark on the same connector. The concurrent scan can read the...
CVE-2026-89598				0.002		In the Linux kernel, the following vulnerability has been resolved: fbdev: ssd1307fb: defer I2C transfers from damage callbacks The fbdev damage callbacks may run from fbcon while printk has disabled preemption. They currently update the display synchronously, which enters the sleeping I2C transfer path from atomic context. A complete report from an RK3566 system follows: [258.129004] watchdog: watchdog0:...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89604				0.002		In the Linux kernel, the following vulnerability has been resolved: efivarfs: Rate limit statfs() handler Ravi reports that statfs() may be called by unprivileged users on the efivarfs mount point, which may result in a flood of calls to the QueryVariableInfo() runtime service. These calls are disproportionately costly on x86 systems where the variable store is backed by SMM, as each SMM entry requires a rendez-...
CVE-2026-89618				0.002		In the Linux kernel, the following vulnerability has been resolved: eventfs: Initialize ei->children and ei->list in init_ei() eventfs_create_dir() allocates the eventfs_inode and initializes it with init_ei(). But this does not initialize the eventfs_inode list_heads. If the eventfs_create_dir() fails due to memory pressure, it will call free_ei() before it initialized the lists, and that checks to make sure th...
CVE-2026-89621				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: mcp2221: validate report size in mcp2221_raw_event() mcp2221_raw_event() never validates the size of incoming HID reports. In the MCP2221_I2C_GET_DATA path it trusts the device-supplied data[3] as the copy length without checking that 4 + data[3] bytes actually exist in the received report. A malicious or misbehaving USB device can send a s...
CVE-2026-89623				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: mcp2221: stop device IO before hid_hw_stop Quiesce device IO at the start of the devm cleanup callback mcp2221_hid_unregister() so that incoming HID reports cannot race with hardware teardown during probe failure or device removal, addressing a potential use-after-free. Guard the call to hid_device_io_stop() with io_started. On normal remo...
CVE-2026-89627				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: roccat: free buffered reports when destroying device roccat_report_event() duplicates each report with kmemdup() and stores the allocation in a circular-buffer slot. The allocation is released only when that slot is reused. The device destruction paths free struct roccat_device without releasing reports still stored in cbuf[]. This makes t...
CVE-2026-89628				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: picolcd: clamp eeprom debugfs read to bytes actually received picolcd_debug_eeprom_read() trusts resp->raw_data[2] -- a length byte supplied by the device in its REPORT_EE_DATA reply -- clamped only to the caller's read() count: ret = resp->raw_data[2]; if (ret > s) ret = s; if (copy_to_user(u, resp->raw_data+3, ret)) It never checks...
CVE-2026-89673				0.002		In the Linux kernel, the following vulnerability has been resolved: nfsd: fix XDR padding calculation in ff_encode_getdeviceinfo nfsd4_ff_encode_getdeviceinfo() computes the da_addr_body reservation as 16 + netid_len + addr_len, but the subsequent xdr_encode_opaque() calls emit 8 + round_up(netid_len, 4) + round_up(addr_len, 4) bytes. The mismatch means the declared da_addr_body length exceeds the actual encoded...
CVE-2026-89694				0.002		In the Linux kernel, the following vulnerability has been resolved: nfsd: check client ownership when cancelling a copy-notify stateid On the OFFLOAD_CANCEL path (clp != NULL), manage_cpntf_state() freed the target cpntf state without checking ownership. The lookup key st->si_opaque.so_id is allocated cyclically (guessable) and the embedded clientid is the fixed per-net nn->s2s_cp_cl_id, so any authenticated NFS...
CVE-2026-89710				0.002		In the Linux kernel, the following vulnerability has been resolved: NFSv4.1: fix layout segment leak on the pnfs_layout_process() forget path When the server returns a new layout stateid while a valid one is still held, pnfs_layout_process() calls pnfs_mark_matching_lsegs_return() on the on-stack free_me list and jumps to out_forget. Segments whose reference count drops to zero are unlinked from lo->plh_segs and...
CVE-2026-89726				0.002		In the Linux kernel, the following vulnerability has been resolved: lib/ucs2_string.c: fix out-of-bounds read in ucs2_strnlen() Patch series "lib/ucs2_string.c: fix out-of-bounds read in ucs2_strnlen()", v2. This series fixes an off-by-one out-of-bounds read in ucs2_strnlen(). The first patch is the real fix, the second patch comes as a bonus and fixes the code indentation. This patch (of 2): ucs2_strnlen()...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89730				0.002		In the Linux kernel, the following vulnerability has been resolved: fpga: altera-cvp: Avoid out-of-bounds read in trailing byte write The trailing byte path in altera_cvp_send_block() dereferences a u32 pointer even when only 1-3 bytes remain in the input buffer. If the buffer ends at a page or scatterlist boundary, this can read past the valid image data and fault. Copy the remaining bytes into a zero-initiali...
CVE-2026-89732				0.002		In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_fs: Prevent deadlock during ep0 read loop Currently, ffs_ep0_read() holds ffs->mutex when it prepares to go to sleep waiting for an event. When no setup events are pending, it calls wait_event_interruptible_exclusive_locked_irq() with the mutex still held. The wait macro deliberately drops the waitqueue spinlock before sleeping bu...
CVE-2026-89735				0.002		In the Linux kernel, the following vulnerability has been resolved: usb: gadget: midi2: remove default configfs groups on teardown f_midi2_alloc_inst() creates default configfs child groups for the default endpoint and default block using configfs_add_default_group(), setting their internal refcount to 1. However, during function teardown in f_midi2_free_inst() or EP cleanup in f_midi2_ep_opts_release(), config...
CVE-2026-89749				0.002		In the Linux kernel, the following vulnerability has been resolved: tracing: Fix crash passing ERR_PTR to kthread_stop() event_test_stuff() calls kthread_run() and unconditionally passes the returned task_struct pointer to kthread_stop(). kthread_run() returns an error pointer such as ERR_PTR(-ENOMEM) when kthread creation fails, for example under memory pressure during the boot-time event self-test. kthread_sto...
CVE-2026-89751				0.002		In the Linux kernel, the following vulnerability has been resolved: x86/tdx: Fix off-by-one in port I/O handling handle_in() and handle_out() in arch/x86/coco/tdx/tdx.c use: u64 mask = GENMASK(BITS_PER_BYTE * size, 0); GENMASK(h, l) includes bit h. For size=1 (INB), this produces GENMASK(8, 0) = 0xFF (9 bits) instead of GENMASK(7, 0) = 0xFF (8 bits). The mask is one bit too wide for all I/O sizes. Fix th...
CVE-2026-89752				0.002		In the Linux kernel, the following vulnerability has been resolved: mm: memcg: stop reclaim when a limit update is superseded kernfs serializes file operations only per open file, so separate open files can update the same memory.high or memory.max file concurrently. Both handlers store the new limit before synchronous reclaim, but continue to use the writer's local target in the reclaim loop. If another write...
CVE-2026-89753				0.002		In the Linux kernel, the following vulnerability has been resolved: mm/vmscan: report RCU-tasks quiescent states in shrink_lruvec() I am seeing some rcu_tasks stalls in the Meta fleet during reclaim. INFO: rcu_tasks detected stalls on tasks: 0000000088620d09: .. nvcs: 6735/6735 holdout: 1 idle_cpu: -1/8 task:GlobalCPUThread state:R running task pid:2552016 tgid:2524552 Call Trace: shrink_lruvec m...
CVE-2026-89756				0.002		In the Linux kernel, the following vulnerability has been resolved: mm/migrate: report RCU-tasks quiescent states in migrate_pages_batch() migrate_pages_batch() unmaps each folio before moving it, and every unmap runs the mmu_notifier invalidate callbacks. On KVM hosts try_to_migrate() ends up in kvm_mmu_notifier_invalidate_range_start() -> tdp_mmu_zap_leafs(), which is expensive, so unmapping a large batch kee...
CVE-2026-89765				0.002		In the Linux kernel, the following vulnerability has been resolved: timers/itimer: Zero-init old itimerval before copy to userspace On native sparc64, struct __kernel_old_timeval contains a four-byte hole after tv_usec because tv_sec is 64-bit while __kernel_suseconds_t is 32-bit. put_itimerval() fills only the named fields in a stack-allocated __kernel_old_itimerval and copies the entire object to userspace, so...